BỘ LAO ĐỘNG – THƯƠNG BINH VÀ XÃ HỘI

**TRƯỜNG CAO ĐẲNG CÔNG NGHỆ THÔNG TIN TP.HCM**

**KHOA CÔNG NGHỆ THÔNG TIN – ĐIỆN TỬ**

———— ✦ ————

# BÁO CÁO ĐỒ ÁN MÔN HỌC

## CHUYÊN ĐỀ BACK-END

**ĐỀ TÀI:**

# XÂY DỰNG HỆ THỐNG BACK-END CHO WEBSITE THƯƠNG MẠI ĐIỆN TỬ BÁN LAPTOP LAPTOPNEW

*Express.js · MongoDB Atlas · JWT · PayOS · Telegram Bot · Gemini AI*


| | |
|---|---|
| Giảng viên hướng dẫn: | **ThS. Nguyễn Minh Hải** |
| Sinh viên thực hiện: | **Lê Minh Trí – 501240045** |
| | **Âu Lê Thành Tài – 501250054** |
| Lớp / Khóa: | CD24CT.N4 |


TP. Hồ Chí Minh, tháng 10 năm 2026

# LỜI MỞ ĐẦU

Mua một chiếc laptop không giống mua một món đồ thông thường. Khách hàng phải so sánh cấu hình, giá, bảo hành, rồi mới dám đặt hàng và chuyển tiền. Phía sau mỗi lần bấm nút "Đặt hàng" là cả một hệ thống chạy ngầm: lưu dữ liệu, kiểm tra người dùng, trừ kho, nhận tiền, gửi email. Phần chạy ngầm đó gọi là **Back-End**, và đó cũng là nội dung của môn Chuyên đề Back-End.

Nhóm chúng em chọn đề tài **"Xây dựng hệ thống Back-End cho website thương mại điện tử bán laptop LaptopNew"**. Hệ thống dùng Node.js với Express 5, lưu dữ liệu trên MongoDB Atlas, xác thực bằng JSON Web Token và mã hóa mật khẩu bằng bcrypt. Mã nguồn chia thành các lớp rõ ràng (Route, Middleware, Controller, Service, Model) để người mới vào đọc cũng dễ theo dõi.

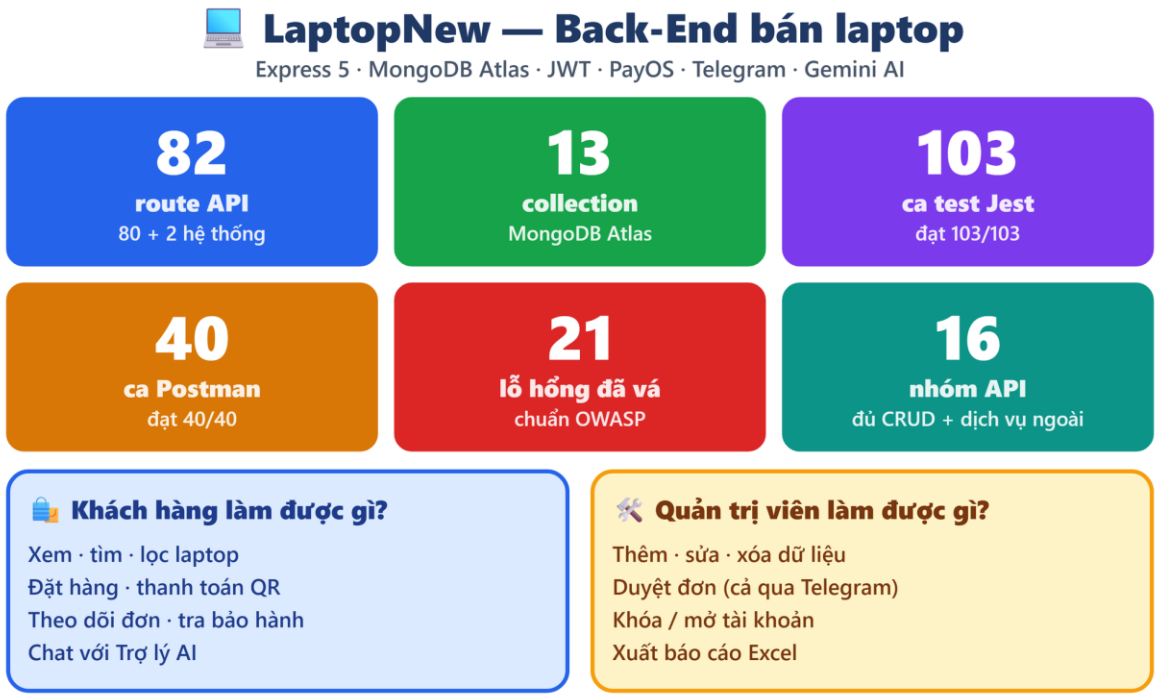
Ngoài các chức năng cơ bản như sản phẩm, đơn hàng, người dùng, mã giảm giá, hệ thống còn kết nối nhiều dịch vụ có thật: gửi mã OTP và hóa đơn qua email, nhận tiền chuyển khoản tự động qua PayOS và VietQR, thông báo và duyệt đơn qua Telegram, và Trợ lý AI tư vấn laptop dùng Google Gemini.

Báo cáo được viết để **bất kỳ ai đọc cũng hiểu**, kể cả người chưa học lập trình: mỗi chức năng đều có sơ đồ, bảng tóm tắt và ảnh chụp giao diện thật. Chương 1 giới thiệu đề tài, Chương 2 trình bày thiết kế, Chương 3 là kết quả chạy thực tế, Chương 4 nói về xử lý lỗi, bảo mật và kiểm thử, Chương 5 là kết luận. Riêng phần bảo mật, nhóm tự đóng vai kẻ tấn công để tìm và vá **21 lỗ hổng** theo chuẩn OWASP API Security Top 10.

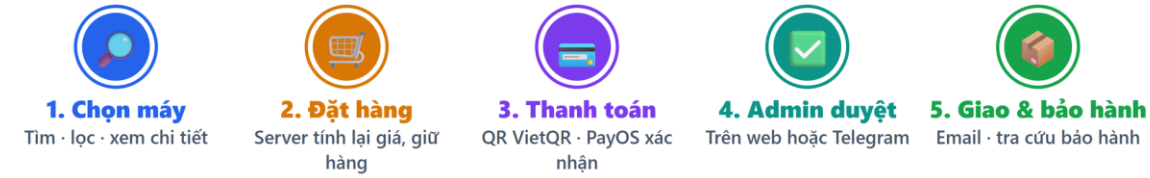
Hệ thống đã được triển khai thật tại **https://trikun.site** (website) và **https://api.trikun.site** (API), chạy trên Railway, có Cloudflare đứng trước để bảo vệ. Tài liệu API tương tác nằm tại **https://api.trikun.site/api-docs**. Nhóm hy vọng đồ án vừa hoàn thành yêu cầu môn học, vừa là bước chuẩn bị cho công việc sau này.

# TÓM TẮT DỰ ÁN BẰNG HÌNH

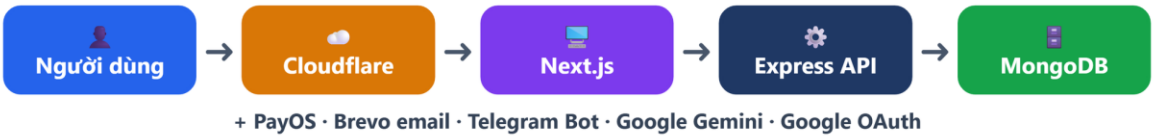
Hai hình dưới đây tóm tắt toàn bộ dự án để người đọc nắm nhanh trước khi vào chi tiết ở các chương.



## Một đơn hàng đi qua 5 bước




## Hệ thống chạy ở đâu?




+ PayOS · Brevo email · Telegram Bot · Google Gemini · Google OAuth

# LỜI CẢM ƠN

Trước hết, chúng em xin gửi lời cảm ơn chân thành đến Ban Giám hiệu và quý Thầy Cô Khoa Công nghệ Thông tin – Điện tử, Trường Cao đẳng Công nghệ Thông tin TP.HCM đã tạo môi trường học tập và truyền đạt nền tảng kiến thức trong suốt thời gian qua.

Đặc biệt, chúng em xin bày tỏ lòng biết ơn đến **Thầy Nguyễn Minh Hải**, giảng viên phụ trách môn Chuyên đề Back-End. Những bài giảng về Node.js, Express, MongoDB, cách tổ chức mã nguồn và bảo mật API của Thầy là nền tảng để nhóm hoàn thành đồ án này.

Chúng em cũng cảm ơn các thành viên trong nhóm đã hỗ trợ nhau trong quá trình thực hiện, cùng gia đình và bạn bè đã luôn động viên.

Do thời gian và kinh nghiệm còn hạn chế, báo cáo khó tránh khỏi thiếu sót. Nhóm rất mong nhận được nhận xét và góp ý của quý Thầy Cô để hoàn thiện hệ thống tốt hơn.

Chúng em xin chân thành cảm ơn!

TP. Hồ Chí Minh, tháng 10 năm 2026

**Nhóm sinh viên thực hiện**

# NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Điểm đánh giá: .....

TP. Hồ Chí Minh, ngày ..... tháng ..... năm 2026

**Giảng viên hướng dẫn**

*(Ký và ghi rõ họ tên)*

# MỤC LỤC

**LỜI MỞ ĐẦU** ..... **i**

**TÓM TẮT DỰ ÁN BẰNG HÌNH** ..... **ii**

**LỜI CẢM ƠN** ..... **iv**

**NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN** ..... **v**

**DANH MỤC TỪ VIẾT TẮT VÀ THUẬT NGỮ** ..... **ix**

**DANH MỤC HÌNH ẢNH** ..... **x**

**DANH MỤC BẢNG** ..... **xiii**

**CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI** ..... **1**

1.1. Lý do chọn đề tài ..... 1

1.2. Mục tiêu của đồ án ..... 1

1.3. Phạm vi và đối tượng sử dụng ..... 2

1.4. Vai trò của phần Back-End ..... 2

1.5. Yêu cầu của hệ thống ..... 3

1.5.1. Yêu cầu chức năng ..... 3

1.5.2. Yêu cầu phi chức năng ..... 3

1.6. Công nghệ sử dụng ..... 4

1.7. Lý do chọn công nghệ ..... 7

**CHƯƠNG 2. THIẾT KẾ KIẾN TRÚC HỆ THỐNG** ..... **7**

2.1. Kiến trúc tổng thể ..... 7

2.2. Cấu trúc thư mục ..... 9

2.3. Sơ đồ Use Case ..... 10

2.4. Thiết kế cơ sở dữ liệu ..... 10

2.4.1. Collection san_pham ..... 12

2.4.2. Collection don_hang ..... 12

2.4.3. Collection nguoi_dung và dang_ky_tam ..... 13

2.4.4. Các collection còn lại và chỉ mục ..... 14

2.5. Các API chính ..... 15

2.6. Các luồng xử lý chính ..... 17

2.6.1. Luồng đăng ký tài khoản bằng OTP ..... 17

2.6.2. Luồng đăng nhập và xác thực bằng JWT ..... 18

2.6.3. Luồng quên mật khẩu ..... 19

2.6.4. Luồng đặt hàng, giữ hàng và trạng thái đơn ..... 20
2.6.5. Luồng thanh toán PayOS và VietQR ..... 22
2.6.6. Luồng mã giảm giá (voucher) ..... 23
2.6.7. Luồng tra cứu bảo hành điện tử ..... 24
2.6.8. Luồng duyệt đơn qua Telegram ..... 25
2.6.9. Luồng Trợ lý AI tư vấn laptop ..... 26
**CHƯƠNG 3. CÀI ĐẶT THỰC NGHIỆM VÀ KẾT QUẢ ..... 27**
3.1. Môi trường cài đặt ..... 27
3.2. Giao diện phía khách hàng ..... 28
3.2.1. Trang chủ ..... 28
3.2.2. Danh sách và chi tiết sản phẩm ..... 29
3.2.3. So sánh sản phẩm và giỏ hàng ..... 29
3.3. Chức năng tài khoản ..... 30
3.3.1. Đăng ký và kích hoạt bằng OTP ..... 30
3.3.2. Đăng nhập, đăng nhập Google và quên mật khẩu ..... 31
3.4. Chức năng mua hàng ..... 32
3.4.1. Trang thanh toán và địa chỉ hành chính mới ..... 32
3.4.2. Thanh toán QR và xác nhận tự động ..... 33
3.4.3. Tra cứu tiến độ đơn hàng ..... 34
3.5. Bảo hành, liên hệ, Trợ lý AI và Telegram ..... 35
3.6. Trang quản trị ..... 38
3.6.1. Quản lý sản phẩm, thương hiệu và đơn hàng ..... 38
3.6.2. Tin tức, banner khuyến mãi và showroom ..... 41
3.6.3. Phiếu tư vấn, khách hàng và mã giảm giá ..... 43
3.7. Giao diện tự đồng bộ khi Admin thay đổi ..... 45
3.8. Kết quả đạt được ..... 48
**CHƯƠNG 4. XỬ LÝ LỖI, BẢO MẬT VÀ KIỂM THỬ ..... 48**
4.1. Xử lý lỗi trong ứng dụng ..... 49
4.2. Bảo mật hệ thống ..... 50
4.2.1. Đối chiếu với OWASP API Security Top 10 ..... 50
4.2.2. Rà soát và vá 21 lỗ hổng ..... 51
4.2.3. Giới hạn tần suất (Rate Limiting) ..... 52
4.2.4. Mật khẩu, OTP và thu hồi phiên ..... 53
4.2.5. Thử tấn công thật ..... 54
4.2.6. Chống bán lố và chống xử lý trùng ..... 55

4.3. Kiểm thử hệ thống ..... 55
4.3.1. Kiểm thử tự động bằng Jest ..... 55
4.3.2. Kiểm thử API bằng Postman ..... 56
4.3.3. Chất lượng mã nguồn và tích hợp liên tục ..... 56
4.3.4. Kiểm thử chịu tải nhẹ ..... 57
4.4. Kiểm chứng dữ liệu trong MongoDB ..... 58
4.5. Triển khai thực tế trên Internet ..... 61
**CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN ..... 64**
5.1. Kết luận ..... 64
5.2. Hạn chế ..... 65
5.3. Hướng phát triển ..... 65
**TÀI LIỆU THAM KHẢO ..... 65**
**PHỤ LỤC A. DANH SÁCH API ĐẦY ĐỦ ..... 67**

# DANH MỤC TỪ VIẾT TẮT VÀ THUẬT NGỮ

| Thuật ngữ | Giải thích dễ hiểu |
|---|---|
| Front-End | Phần giao diện người dùng nhìn thấy và bấm vào (website). |
| Back-End | Phần chạy trên máy chủ, âm thầm xử lý dữ liệu, tiền, tài khoản và trả kết quả cho giao diện. |
| API | Các "cửa" mà Front-End gõ vào để nhờ Back-End làm việc, ví dụ lấy danh sách laptop hay tạo đơn hàng. |
| REST | Cách đặt tên và dùng các "cửa" API cho thống nhất: GET để xem, POST để tạo, PUT để sửa, DELETE để xóa. |
| Database / Collection | Database là kho lưu dữ liệu lâu dài. Collection giống một "ngăn tủ" chứa một loại dữ liệu (sản phẩm, đơn hàng…). |
| MongoDB, Mongoose | MongoDB là loại database lưu dữ liệu dạng văn bản linh hoạt. Mongoose giúp mô tả và kiểm tra dữ liệu trước khi lưu. |
| JWT (token) | Một "vé" có chữ ký do server cấp sau khi đăng nhập. Khách đưa vé này mỗi lần gọi API để chứng minh mình là ai. |
| bcrypt | Cách biến mật khẩu thành chuỗi ký tự không thể đọc ngược lại, nên kể cả quản trị viên cũng không biết mật khẩu của khách. |
| OTP | Mã 6 số dùng một lần, gửi qua email, hết hạn sau 10 phút, để xác nhận đúng người đang thao tác. |
| RBAC / phân quyền | Mỗi tài khoản có vai trò (khách hàng hoặc admin) và chỉ làm được việc đúng với vai trò đó. |
| Middleware | Các "trạm kiểm soát" mà mọi yêu cầu phải đi qua trước khi vào xử lý (kiểm tra vé, kiểm tra quyền, giới hạn số lần gọi…). |
| Webhook | Dịch vụ bên ngoài (như PayOS) tự gọi ngược vào hệ thống để báo tin, ví dụ "khách vừa chuyển tiền xong". |
| Rate limit | Giới hạn số lần một người được gọi trong một khoảng thời gian, để chống đoán mật khẩu và spam. |
| OWASP | Tổ chức công bố danh sách các lỗi bảo mật phổ biến nhất của API; nhóm dùng danh sách này để tự kiểm tra hệ thống. |
| IDOR | Lỗi cho phép xem hoặc sửa dữ liệu của người khác chỉ bằng cách đổi mã trên đường dẫn. |
| NoSQL Injection | Kiểu tấn công gửi lệnh lạ vào ô nhập liệu để đánh lừa database. |
| CORS | Quy tắc chỉ cho phép website của mình gọi API, chặn website lạ. |
| CI | Hệ thống tự động chạy kiểm thử mỗi khi có mã nguồn mới, báo ngay nếu có lỗi. |
| Swagger / OpenAPI | Trang tài liệu API có thể bấm gọi thử ngay trên trình duyệt. |
| SKU | Mã định danh của từng mẫu sản phẩm. |
| COD | Thanh toán khi nhận hàng. |

# DANH MỤC HÌNH ẢNH

Hình 1.1. Bộ công nghệ sử dụng trong hệ thống LaptopNew, chia theo từng lớp.....5
Hình 1.2. Biểu tượng các công nghệ và dịch vụ được dùng trong đồ án .....5
Hình 2.1. Sơ đồ kiến trúc tổng thể hệ thống LaptopNew.....8
Hình 2.2. Vòng đời xử lý một yêu cầu qua các tầng của máy chủ.....9
Hình 2.3. Cấu trúc thư mục mã nguồn Back-End .....9
Hình 2.4. Sơ đồ use case của hệ thống Back-End LaptopNew .....10
Hình 2.5. Sơ đồ quan hệ giữa các collection (ERD) .....11
Hình 2.6. Các collection trong database laptop_store trên MongoDB Atlas (số tài liệu và dung lượng).....12
Hình 2.7. Bản ghi tạm sau khi đăng ký: mật khẩu là chuỗi bcrypt, OTP là chuỗi băm 64 ký tự.....14
Hình 2.8. Sau khi kích hoạt: tài khoản chính thức xuất hiện trong nguoi_dung.....14
Hình 2.9. Trang chủ tài liệu Swagger: mô tả, quy ước chung và danh sách nhóm API16
Hình 2.10. Chi tiết API đăng nhập: mô tả nghiệp vụ, ví dụ dữ liệu gửi lên và phản hồi .....17
Hình 2.11. Sơ đồ tuần tự đăng ký và kích hoạt tài khoản bằng OTP .....18
Hình 2.12. Sơ đồ tuần tự đăng nhập và gọi API được bảo vệ.....19
Hình 2.13. Sơ đồ tuần tự quên mật khẩu bằng OTP.....20
Hình 2.14. Lưu đồ xử lý tạo đơn hàng .....21
Hình 2.15. Vòng đời trạng thái đơn hàng và quy tắc giữ / hoàn lại tồn kho .....21
Hình 2.16. Giữ hàng nguyên tử: tồn kho giảm khi đặt và hoàn lại khi hủy .....22
Hình 2.17. Sơ đồ tuần tự thanh toán PayOS / VietQR với Webhook .....23
Hình 2.18. Lưu đồ kiểm tra và tính tiền mã giảm giá .....24
Hình 2.19. Lưu đồ tra cứu bảo hành điện tử.....25
Hình 2.20. Sơ đồ thông báo và duyệt đơn qua Telegram Bot .....26
Hình 2.21. Luồng xử lý của Trợ lý AI với cơ chế dự phòng nhiều tầng.....27
Hình 3.1. Cửa sổ lệnh khi khởi động Back-End thành công.....28
Hình 3.2. Trang chủ website LaptopNew.....28
Hình 3.3. Danh sách sản phẩm với bộ lọc .....29
Hình 3.4. Chi tiết sản phẩm: ảnh, cấu hình, giá, phiên bản.....29
Hình 3.5. Trang so sánh chi tiết các laptop .....30
Hình 3.6. Giỏ hàng: sản phẩm, tóm tắt đơn và nút thanh toán.....30
Hình 3.7. Biểu mẫu đăng ký, kiểm tra từng ô .....31

Hình 3.8. Nhập mã OTP 6 số để xác thực ..... 31
Hình 3.9. Biểu mẫu đăng nhập có nút Google ..... 32
Hình 3.10. Trang thanh toán: thông tin người nhận và tóm tắt đơn ..... 32
Hình 3.11. Chọn Tỉnh/Thành và Phường/Xã theo địa giới mới ..... 33
Hình 3.12. Mã VietQR có sẵn số tiền và nội dung ..... 33
Hình 3.13. Thanh toán thành công, đơn tự chuyển trạng thái ..... 34
Hình 3.14. Email xác nhận đơn hàng gửi tới khách (hóa đơn HTML) ..... 34
Hình 3.15. Trang tra cứu tiến độ đơn hàng ..... 35
Hình 3.16. Trang tra cứu bảo hành điện tử ..... 36
Hình 3.17. Trang liên hệ: showroom, bản đồ và biểu mẫu tư vấn ..... 36
Hình 3.18. Hộp chat Trợ lý AI trả lời câu hỏi và gợi ý sản phẩm thật ..... 37
Hình 3.19. Tin nhắn đơn mới kèm các nút duyệt ..... 37
Hình 3.20. Kết quả lệnh /thongke ..... 37
Hình 3.21. Tổng quan: doanh thu, đơn hàng, khách hàng, kho ..... 38
Hình 3.22. Danh sách sản phẩm trong kho ..... 39
Hình 3.23. Danh sách thương hiệu và danh mục ..... 39
Hình 3.24. Danh sách đơn hàng, bộ lọc, nút tạo đơn và xuất Excel ..... 40
Hình 3.25. Chi tiết đơn, lộ trình giao hàng, nút in phiếu ..... 40
Hình 3.26. Tệp Excel báo cáo kế toán do chức năng Xuất Excel tạo ra ..... 41
Hình 3.27. Danh sách bài viết tin tức ..... 41
Hình 3.28. Cấu hình banner và khuyến mãi, có xem trước ..... 42
Hình 3.29. Cấu hình showroom, tọa độ GPS và bản đồ ..... 42
Hình 3.30. Danh sách phiếu yêu cầu tư vấn ..... 43
Hình 3.31. Danh sách tài khoản khách hàng ..... 44
Hình 3.32. Tài khoản đang bị khóa hiện nhãn “Tạm khóa” màu đỏ ..... 44
Hình 3.33. Kho mã giảm giá và voucher ..... 45
Hình 3.34. Cơ chế tự đồng bộ: Admin thay đổi → chữ ký phiên bản → trình duyệt khách tải lại đúng phần ..... 46
Hình 3.35. Luồng xử lý sản phẩm ẩn, hết hàng và đổi giá ..... 47
Hình 3.36. Luồng giỏ hàng theo tài khoản: hợp nhất khi đăng nhập, dùng nhiều thiết bị ..... 47
Hình 3.37. Cùng một tài khoản hiển thị cùng giỏ hàng trên hai trình duyệt ..... 47
Hình 3.38. Thông báo giá thay đổi “cũ → mới” trong giỏ ..... 48
Hình 4.1. Mô hình bảo mật nhiều lớp: một yêu cầu phải qua 9 lớp kiểm tra ..... 50

Hình 4.2. Trong MongoDB: matKhau là chuỗi bcrypt ($2b$10$…), maOtp là chuỗi băm 64 ký tự, không phải mã 6 số.....53
Hình 4.3. Mười kịch bản tấn công thử và phản ứng của hệ thống .....54
Hình 4.4. Kết quả chạy Jest: 11 tệp, 103/103 ca đạt, kèm độ phủ mã .....56
Hình 4.5. Một lần chạy CI thành công: cả 3 việc (Back-End, Front-End, kiểm tra máy chủ thật) đều đạt .....57
Hình 4.6. ESLint, Prettier và npm audit: không có lỗi, không có lỗ hổng thư viện.....57
Hình 4.7. Đơn hàng vừa tạo nằm trong collection don_hang .....58
Hình 4.8. Trước: tồn kho 25, đã bán 114 .....59
Hình 4.9. Sau khi đơn được xử lý: tồn kho 24, đã bán 115.....59
Hình 4.10. Sau khi hủy đơn: hoàn lại 25 và 114 .....59
Hình 4.11. Trước khi lưu: voucher ASUSVIP1TR còn 50 lượt.....59
Hình 4.12. Sau khi lưu: còn 49 lượt, đã dùng 51% .....60
Hình 4.13. Đánh giá mới (da_mua_hang = true).....60
Hình 4.14. Trước: trangThai = hoat_dong, tokenVersion = 0 .....60
Hình 4.15. Sau khi Admin khóa: biKhoa = true, tokenVersion = 1.....61
Hình 4.16. Phiếu yêu cầu tư vấn mới trong collection lien_he .....61
Hình 4.17. Mô hình triển khai production: Cloudflare, Railway, MongoDB Atlas và dịch vụ ngoài .....62
Hình 4.18. Service Back-End trên Railway: bản triển khai mới nhất đang chạy tốt ....63
Hình 4.19. Bản ghi DNS trên Cloudflare: hai CNAME ở chế độ Proxied .....63
Hình 4.20. SSL/TLS chế độ Full: mã hóa cả hai chặng .....63
Hình 4.21. Luật giới hạn tần suất chong-do-mat-khau cho /api/auth/*.....64

# DANH MỤC BẢNG

Bảng 1.1. Những bài toán của website bán laptop và cách đồ án giải quyết .....1
Bảng 1.2. Các nhóm đối tượng sử dụng hệ thống .....2
Bảng 1.3. Front-End và Back-End khác nhau thế nào .....2
Bảng 1.4. Các chức năng chính của hệ thống.....3
Bảng 1.5. Các yêu cầu phi chức năng .....3
Bảng 1.6. Các công nghệ sử dụng trong đồ án.....4
Bảng 1.7. Lý do lựa chọn các công nghệ chính.....7
Bảng 2.1. Vai trò của từng lớp trong máy chủ Express .....8
Bảng 2.2. Các thư mục chính của Back-End.....9
Bảng 2.3. Danh sách collection và số bản ghi thực tế (13/10/2026).....11
Bảng 2.4. Các trường chính của san_pham .....12
Bảng 2.5. Các trường chính của don_hang .....12
Bảng 2.6. Các trường chính của nguoi_dung .....13
Bảng 2.7. Chỉ mục và ràng buộc dữ liệu quan trọng.....14
Bảng 2.8. Số route theo nhóm chức năng.....15
Bảng 2.9. Các mức quyền truy cập.....15
Bảng 2.10. Ai được đổi trạng thái đơn hàng .....21
Bảng 3.1. Môi trường cài đặt hệ thống.....27
Bảng 3.2. Các trạng thái của đơn hàng.....35
Bảng 3.3. Kết quả của cơ chế đồng bộ và giỏ hàng theo tài khoản.....46
Bảng 3.4. Tổng hợp kết quả các chức năng chính.....48
Bảng 4.1. Các mã trạng thái HTTP được sử dụng .....49
Bảng 4.2. Một số tình huống lỗi và cách hệ thống phản ứng.....49
Bảng 4.3. Đối chiếu hệ thống với OWASP API Security Top 10 (2023).....50
Bảng 4.4. 21 lỗ hổng đã phát hiện và cách khắc phục .....51
Bảng 4.5. Hạn mức giới hạn tần suất đang áp dụng.....52
Bảng 4.6. Các kịch bản tấn công thử và kết quả .....54
Bảng 4.7. Các nhóm kiểm thử tự động.....55
Bảng 4.8. Tóm tắt kết quả kiểm thử Postman .....56
Bảng 4.9. Kết quả kiểm thử chịu tải nhẹ trên máy chủ thật (19/10/2026) .....57
Bảng 4.10. Dữ liệu thay đổi đúng sau mỗi thao tác .....58
Bảng 4.11. Các lớp trong mô hình triển khai .....62
Bảng 5.1. Tóm tắt kết quả đồ án.....64

Bảng 5.2. Hướng phát triển tiếp theo .....65
Bảng A.1. API nhóm Xác thực (/api/auth) .....67
Bảng A.2. API nhóm Sản phẩm, Danh mục, Tin tức, Showroom .....67
Bảng A.3. API nhóm Đơn hàng, Thanh toán, Giỏ hàng, Yêu thích.....68
Bảng A.4. API nhóm Mã giảm giá, Đánh giá, Bảo hành, Liên hệ, Người dùng, AI ....68

# CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

## 1.1. Lý do chọn đề tài

Laptop có rất nhiều cấu hình (CPU, RAM, ổ cứng, card đồ họa, màn hình), giá trị cao và thay đổi nhanh theo từng đời máy. Vì vậy một website bán laptop gặp những bài toán rất điển hình của Back-End, và đó cũng là lý do nhóm chọn đề tài này để học cho đủ bài bản.

**Bảng 1.1. Những bài toán của website bán laptop và cách đồ án giải quyết**

| Bài toán thực tế | Cách đồ án giải quyết |
|---|---|
| Mỗi máy có hàng chục thông số, nhiều phiên bản cấu hình | Lưu dạng tài liệu lồng nhau trong MongoDB, một sản phẩm gọn trong một bản ghi |
| Khách và quản trị viên có quyền khác nhau | Đăng nhập bằng JWT, phân quyền theo vai trò, kiểm tra ở từng API |
| Tài khoản ảo, đăng ký rác | Bắt buộc xác nhận email bằng mã OTP trước khi tạo tài khoản |
| Đơn hàng nhiều bước, tồn kho dễ sai lệch | Trạng thái đơn rõ ràng; trừ và hoàn kho bằng thao tác nguyên tử, không bán lố |
| Chuyển khoản thủ công dễ nhầm | Thanh toán QR qua PayOS, hệ thống tự đối soát bằng Webhook |
| Cần tư vấn nhanh, thông báo kịp thời | Trợ lý AI trả lời tiếng Việt; Telegram Bot báo và duyệt đơn trên điện thoại |
| Dễ bị tấn công khi chạy thật trên Internet | Bảo mật nhiều lớp theo OWASP, kiểm thử bằng chính các kịch bản tấn công |

## 1.2. Mục tiêu của đồ án

- Xây dựng Back-End hoàn chỉnh cho website bán laptop, gồm **82 route API** chia thành 16 nhóm tài nguyên.
- Thiết kế cơ sở dữ liệu MongoDB gồm **13 collection**, có chỉ mục và ràng buộc dữ liệu.
- Tích hợp dịch vụ thật: email, thanh toán QR, Telegram, trí tuệ nhân tạo, đăng nhập Google.
- Bảo mật theo chuẩn OWASP; tự kiểm thử bằng **103 ca Jest**, **40 ca Postman** và các kịch bản tấn công thử.

- Triển khai thật trên Internet với tên miền riêng, có tài liệu API (Swagger) và quy trình kiểm thử tự động (CI).

## 1.3. Phạm vi và đối tượng sử dụng

Đồ án tập trung vào phần Back-End (thư mục `BE/`). Phần Front-End Next.js (thư mục `FE/`) được dùng để minh họa kết quả bằng giao diện thật. Hệ thống phục vụ bốn nhóm đối tượng ở Bảng 1.2.

**Bảng 1.2. Các nhóm đối tượng sử dụng hệ thống**

| Đối tượng | Nhận diện thế nào | Làm được gì |
|---|---|---|
| Khách vãng lai | Không gửi token | Xem sản phẩm, tin tức; đăng ký, đăng nhập; tra cứu bảo hành; gửi liên hệ; chat AI |
| Thành viên | Có token, vai trò khach_hang | Mọi việc của khách, thêm đặt hàng, thanh toán, xem đơn của mình, ví voucher, giỏ hàng |
| Quản trị viên | Có token, vai trò admin | Mọi việc của thành viên, thêm quản lý sản phẩm, đơn, người dùng, voucher, tin tức |
| Hệ thống ngoài | Webhook có chữ ký / Bot token | PayOS báo đã nhận tiền; Telegram gửi thao tác duyệt đơn của Admin |

## 1.4. Vai trò của phần Back-End

Có thể hình dung website như một nhà hàng: Front-End là phòng ăn đẹp, nơi khách gọi món; Back-End là nhà bếp và kho hàng, nơi món ăn thật sự được làm ra. Khách chỉ thấy phòng ăn, nhưng nhà bếp mới quyết định món có đúng, có nhanh và có an toàn hay không.

**Bảng 1.3. Front-End và Back-End khác nhau thế nào**

| | Front-End (giao diện) | Back-End (máy chủ) |
|---|---|---|
| Chạy ở đâu | Trên trình duyệt của khách | Trên máy chủ (Railway) |
| Nhiệm vụ | Hiển thị, nhận thao tác bấm và gõ | Kiểm tra, tính toán, lưu và bảo vệ dữ liệu |
| Ví dụ | Nút "Đặt hàng", giỏ hàng, trang tra cứu | Tính lại giá, trừ kho, đối soát tiền, gửi email |
| Có tin được không | Không, vì người dùng có thể sửa được | Có, đây là nơi quyết định cuối cùng |

Vì thế một nguyên tắc xuyên suốt đồ án là **không tin bất cứ dữ liệu nào từ trình duyệt**: giá tiền, quyền hạn, trạng thái thanh toán đều được Back-End tự kiểm tra lại.

## 1.5. Yêu cầu của hệ thống

### 1.5.1. Yêu cầu chức năng

**Bảng 1.4. Các chức năng chính của hệ thống**

| Nhóm | Chức năng | Ai dùng |
|---|---|---|
| Tài khoản | Đăng ký có OTP, đăng nhập (email hoặc Google), quên / đổi mật khẩu, hồ sơ và sổ địa chỉ | Khách, thành viên |
| Sản phẩm | Xem, tìm kiếm, lọc theo hãng / giá / nhu cầu, sắp xếp, so sánh, yêu thích | Mọi người |
| Giỏ hàng, voucher | Giỏ hàng đi theo tài khoản; kiểm tra, lưu mã giảm giá vào ví | Thành viên |
| Đơn hàng | Đặt hàng, xem lịch sử, tra cứu bằng mã đơn + SĐT, hủy đơn, theo dõi tiến độ | Thành viên, khách |
| Thanh toán | Mã QR VietQR / PayOS, tự xác nhận khi tiền về | Thành viên |
| Chăm sóc khách | Đánh giá sản phẩm, tra cứu bảo hành điện tử, gửi yêu cầu tư vấn, chat AI | Mọi người |
| Quản trị | Thêm / sửa / xóa sản phẩm, hãng, tin tức, voucher, showroom; duyệt đơn; khóa tài khoản; xuất Excel | Admin |
| Thông báo | Email OTP và hóa đơn; Telegram báo đơn mới, duyệt đơn, thống kê | Admin, khách |

### 1.5.2. Yêu cầu phi chức năng

**Bảng 1.5. Các yêu cầu phi chức năng**

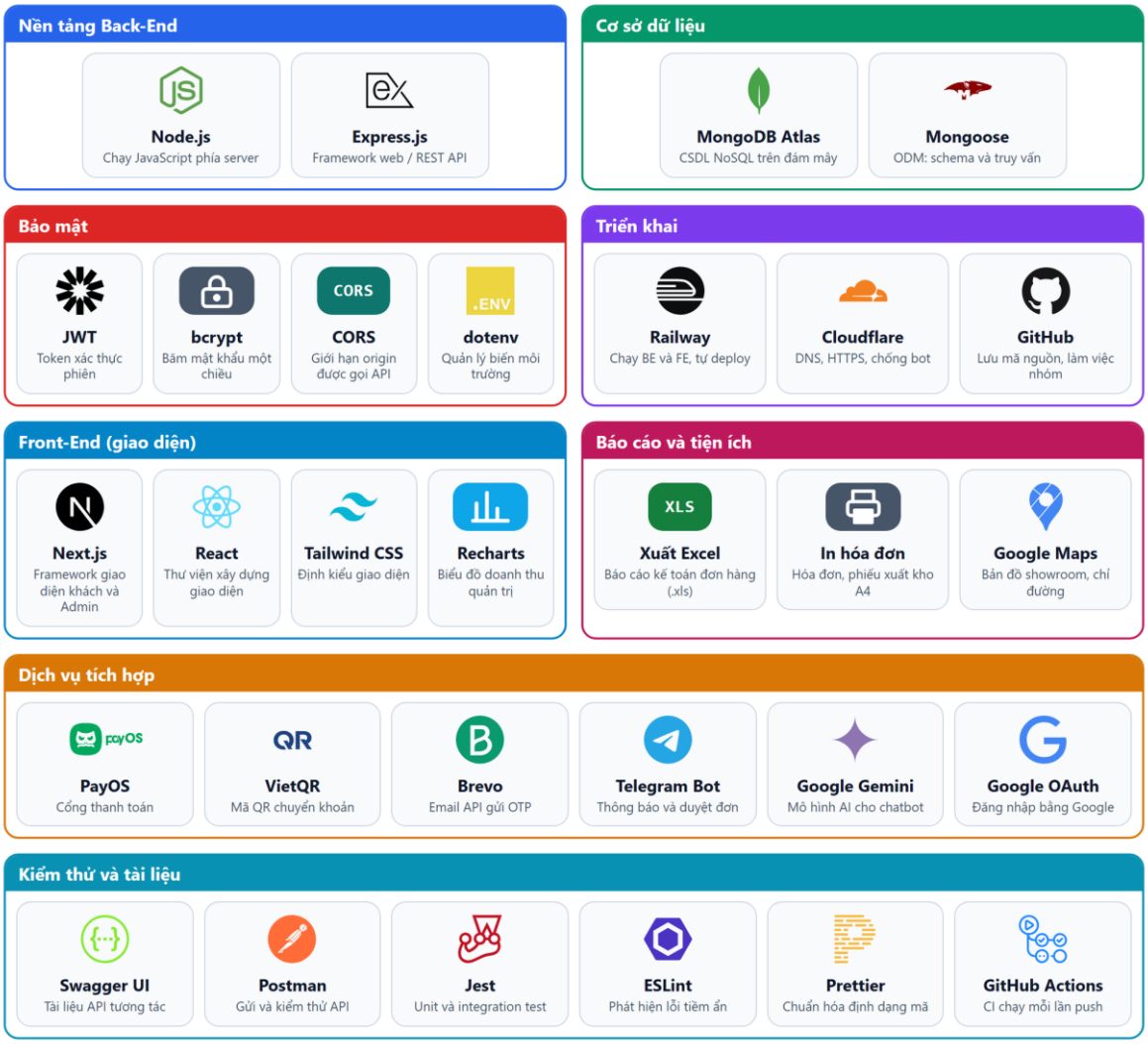
| Tiêu chí | Yêu cầu đặt ra | Cách đáp ứng |
|---|---|---|
| Bảo mật | Không lộ dữ liệu, không bị giả mạo | JWT, bcrypt, RBAC, rate limit, lọc dữ liệu vào, 21 lỗ hổng đã vá |
| Toàn vẹn dữ liệu | Không bán lố, không trừ tiền hai lần | Thao tác nguyên tử, Webhook xử lý một lần |
| Tốc độ | Phản hồi nhanh với danh sách sản phẩm | Cache 60 giây, chỉ mục, chọn trường cần thiết |
| Dễ bảo trì | Người mới đọc cũng hiểu | Chia lớp rõ ràng, đặt tên tiếng Việt, ESLint + Prettier |
| Tin cậy | Một dịch vụ ngoài lỗi không làm hỏng đơn | Gọi dịch vụ ngoài có hạn chờ và phương án dự phòng |
| Dễ dùng | Thông báo lỗi tiếng Việt, rõ ràng | Mọi lỗi đều có mã HTTP đúng và câu thông báo dễ hiểu |

## 1.6. Công nghệ sử dụng

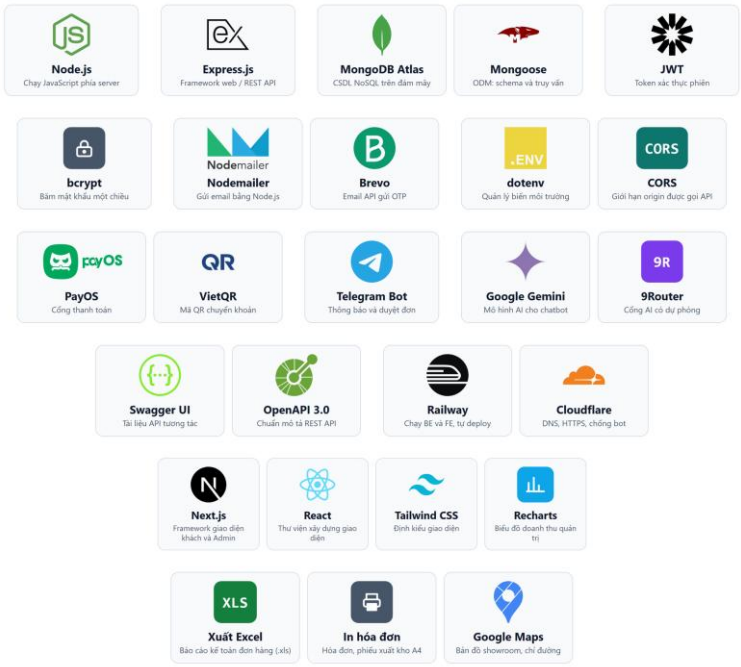
Bảng 1.6 tóm tắt các công nghệ chính. Hình 1.1 cho thấy toàn bộ công nghệ theo từng lớp, Hình 1.2 là biểu tượng của từng công nghệ.

**Bảng 1.6. Các công nghệ sử dụng trong đồ án**

| Công nghệ | Dùng để làm gì |
|---|---|
| Node.js 24 + Express 5 | Chạy máy chủ và xây dựng các API |
| MongoDB Atlas + Mongoose | Lưu trữ dữ liệu trên đám mây, mô tả và kiểm tra dữ liệu |
| JWT + bcrypt | Xác thực người dùng, mã hóa mật khẩu |
| Nodemailer + Brevo | Gửi email OTP và hóa đơn |
| PayOS + VietQR | Thanh toán chuyển khoản bằng mã QR, tự đối soát |
| Telegram Bot API | Báo đơn mới và duyệt đơn trên điện thoại |
| Google Gemini + 9Router | Trợ lý AI tư vấn laptop |
| Google OAuth | Đăng nhập một chạm bằng tài khoản Google |
| Swagger UI (OpenAPI 3) | Tài liệu API gọi thử được ngay trên trình duyệt |
| Jest + Supertest + GitHub Actions | Kiểm thử tự động và tích hợp liên tục |
| Railway + Cloudflare | Chạy thật trên Internet, có HTTPS và lớp bảo vệ |
| Next.js 16 + React 19 + Tailwind | Xây dựng giao diện website |




**Hình 1.1. Bộ công nghệ sử dụng trong hệ thống LaptopNew, chia theo từng lớp**




**Hình 1.2. Biểu tượng các công nghệ và dịch vụ được dùng trong đồ án**

Mỗi công nghệ được giải thích ngắn gọn dưới đây để người không chuyên cũng nắm được vai trò của nó.

- **Node.js và Express:** Node.js cho phép chạy JavaScript trên máy chủ, xử lý được nhiều yêu cầu cùng lúc mà không phải chờ. Express là bộ khung giúp khai báo các API gọn gàng, chia nhỏ thành các "trạm kiểm soát" (middleware).
- **MongoDB Atlas và Mongoose:** MongoDB lưu dữ liệu dạng tài liệu, rất hợp với laptop vì mỗi máy có thông số khác nhau. Atlas là dịch vụ MongoDB trên đám mây, có sẵn sao lưu. Mongoose giúp mô tả kiểu dữ liệu và kiểm tra trước khi lưu.
- **JWT và bcrypt:** Sau khi đăng nhập đúng, server cấp một "vé" JWT có chữ ký, hạn 7 ngày. Mật khẩu không được lưu nguyên văn mà được bcrypt biến thành chuỗi không thể đọc ngược.
- **Email: Nodemailer và Brevo:** Nhiều nền tảng đám mây chặn cổng gửi email thông thường, nên hệ thống ưu tiên gọi Brevo qua HTTPS và dùng Gmail khi chạy ở máy cá nhân.
- **PayOS và VietQR:** Khách quét một mã QR đã có sẵn số tiền và nội dung. Khi tiền về, PayOS tự báo cho hệ thống (Webhook) và đơn được xác nhận mà không cần người đối soát.
- **Telegram Bot:** Admin nhận tin nhắn đơn mới kèm các nút Xác nhận, Giao hàng, Hủy ngay trên điện thoại và dùng được các lệnh thống kê.
- **Google Gemini và 9Router:** Trợ lý AI hiểu câu hỏi tiếng Việt, tìm laptop thật trong kho rồi mới trả lời. Nếu nhà cung cấp này lỗi sẽ tự chuyển sang nhà cung cấp khác.
- **Swagger, Jest, GitHub Actions:** Swagger biến danh sách API thành trang tài liệu bấm thử được. Jest chạy các bài kiểm thử, GitHub Actions tự chạy chúng mỗi lần có mã mới.
- **Railway và Cloudflare:** Railway chạy ứng dụng và tự cập nhật khi có mã nguồn mới. Cloudflare đứng trước để cấp HTTPS, chống bot và giới hạn số lần gọi.

## 1.7. Lý do chọn công nghệ

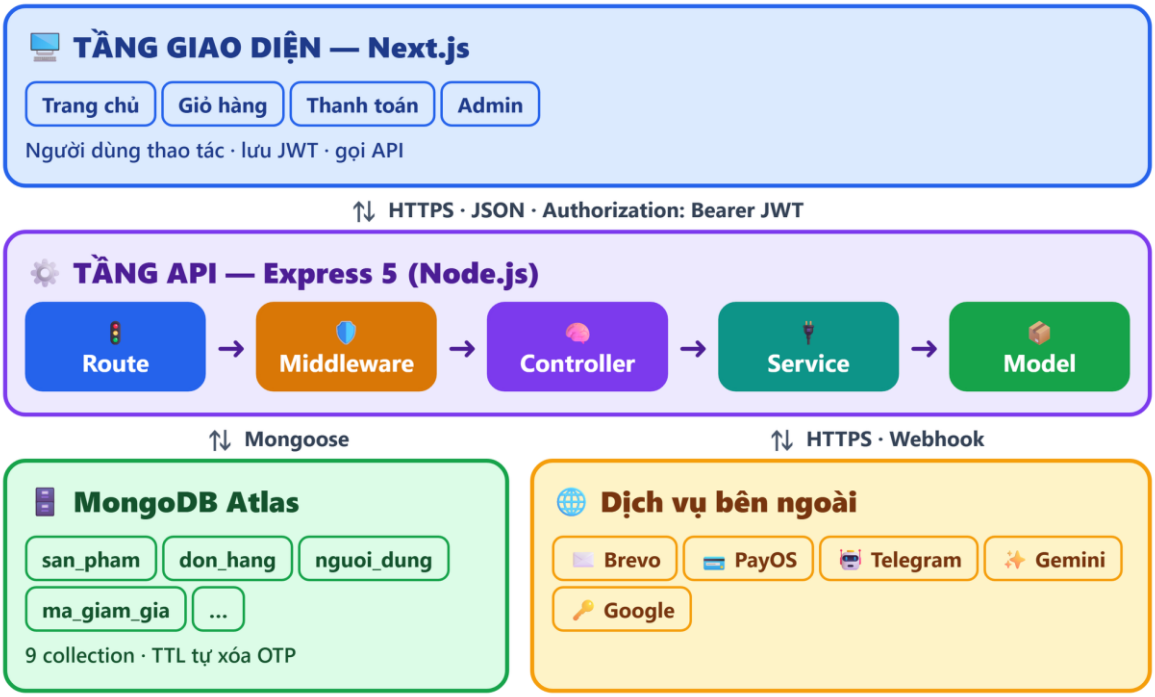
**Bảng 1.7. Lý do lựa chọn các công nghệ chính**

| Công nghệ | Lý do chọn |
|---|---|
| Node.js | Dùng chung JavaScript cho cả giao diện và máy chủ; xử lý nhiều yêu cầu cùng lúc tốt; kho thư viện npm rất lớn |
| Express | Đơn giản, linh hoạt; cơ chế middleware giúp tách xác thực, phân quyền và xử lý lỗi rõ ràng |
| MongoDB | Dữ liệu laptop nhiều tầng, thay đổi thường xuyên nên linh hoạt hơn bảng cứng; Atlas có gói miễn phí cho học tập |
| JWT | Không cần lưu phiên trên server, hợp với website Next.js; vẫn thu hồi được nhờ trường tokenVersion |
| PayOS | Tự đối soát chuyển khoản, bớt thao tác thủ công; có tài liệu và chữ ký bảo vệ rõ ràng |
| Railway + Cloudflare | Triển khai nhanh từ GitHub, có HTTPS, tên miền riêng, chống bot và giới hạn tần suất ở lớp biên |

# CHƯƠNG 2. THIẾT KẾ KIẾN TRÚC HỆ THỐNG

## 2.1. Kiến trúc tổng thể

Hệ thống gồm ba tầng nối với nhau: **giao diện** (Next.js) → **API** (Express) → **cơ sở dữ liệu** (MongoDB Atlas), cùng một số dịch vụ bên ngoài. Người dùng chỉ làm việc với giao diện; mọi quyết định quan trọng đều nằm ở tầng API.



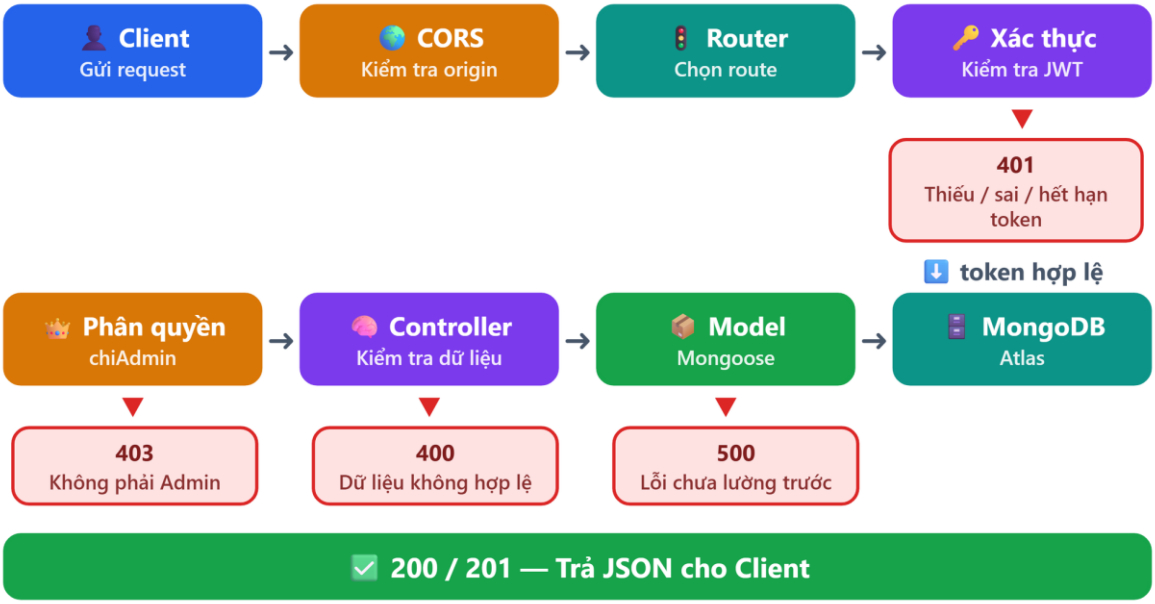

**Hình 2.1. Sơ đồ kiến trúc tổng thể hệ thống LaptopNew**

Bên trong tầng API, mã nguồn được chia thành năm lớp, mỗi lớp lo một việc. Cách chia này giúp người mới đọc biết ngay cần tìm ở đâu khi muốn sửa một chức năng.

**Bảng 2.1. Vai trò của từng lớp trong máy chủ Express**

| Lớp | Thư mục | Nhiệm vụ | Ví dụ |
|---|---|---|---|
| Route | routes/ | Khai báo đường dẫn API và gắn các trạm kiểm soát | POST /api/don-hang |
| Middleware | middleware/ | Kiểm tra trước khi vào xử lý: vé JWT, quyền, giới hạn tần suất, lọc dữ liệu độc hại | xacThucToken, chiAdmin |
| Controller | controllers/ | Đọc dữ liệu gửi lên, kiểm tra, thực hiện nghiệp vụ, trả kết quả | Tạo đơn, tính tiền giảm |
| Service | services/ | Làm việc với dịch vụ ngoài: email, Telegram, AI, kho hàng | Gửi mail, trừ kho |
| Model | models/ | Mô tả và kiểm tra dữ liệu, làm việc với MongoDB | SanPham, DonHang |

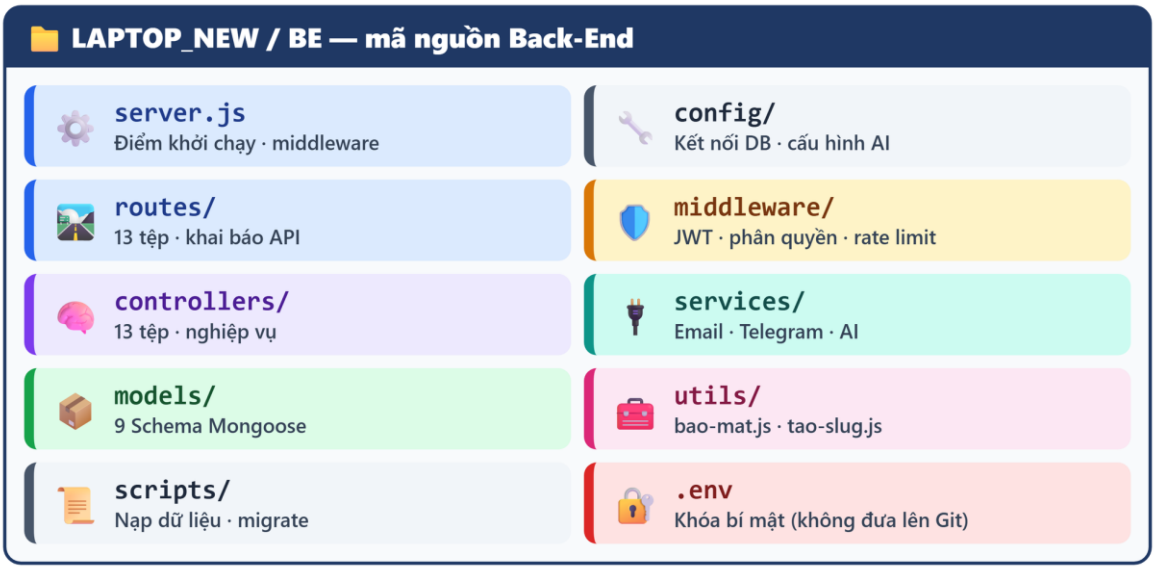
Mỗi yêu cầu từ khách đi qua các lớp theo thứ tự cố định. Nếu một "trạm" thấy có vấn đề, yêu cầu bị chặn ngay và trả lỗi, không đi tiếp (Hình 2.2).




**Hình 2.2. Vòng đời xử lý một yêu cầu qua các tầng của máy chủ**

## 2.2. Cấu trúc thư mục

Toàn bộ mã nguồn Back-End nằm trong thư mục `BE/`. Hình 2.3 và Bảng 2.2 giải thích từng thư mục.




**Hình 2.3. Cấu trúc thư mục mã nguồn Back-End**

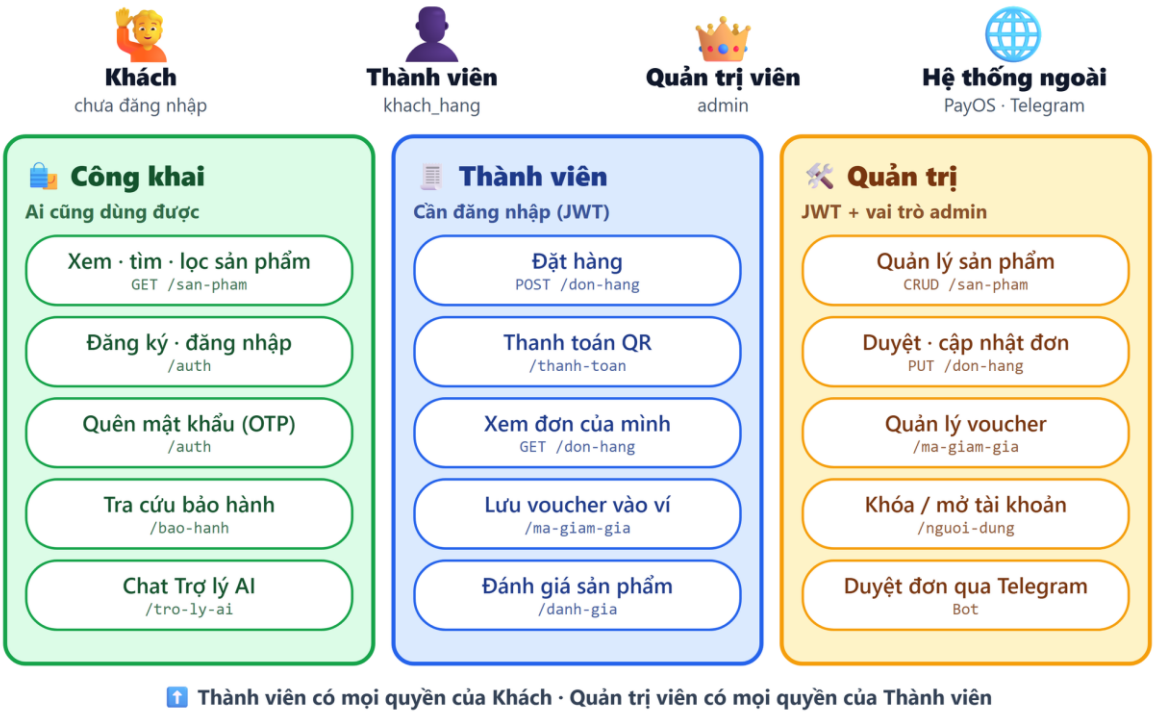
**Bảng 2.2. Các thư mục chính của Back-End**

| Thư mục | Số tệp | Nội dung |
|---|---|---|
| routes/ | 16 | Mỗi nhóm API một tệp (auth, san-pham, don-hang, thanh-toan…) |
| controllers/ | 16 | Logic nghiệp vụ của từng nhóm API |

| Thư mục | Số tệp | Nội dung |
|---|---|---|
| services/ | 7 | Email, Telegram Bot, Trợ lý AI, tìm sản phẩm bằng AI, quản lý tồn kho |
| models/ | 12 | Mô tả dữ liệu từng collection |
| middleware/ | 3 | Xác thực JWT, bảo mật dữ liệu vào, giới hạn tần suất |
| utils/ | 3 | Hàm dùng chung: tạo slug, bảo mật (OTP, mật khẩu), kiểm tra hạn voucher |
| tests/ | 11 tệp test | 103 ca kiểm thử tự động (Jest + Supertest) |
| docs/ | 1 | Đặc tả OpenAPI cho trang Swagger |
| scripts-local/ | — | Các công cụ chạy tay: nạp dữ liệu mẫu, đồng bộ dữ liệu |

## 2.3. Sơ đồ Use Case

Hình 2.4 cho biết ai được làm gì. Có ba nhóm người dùng chính, mỗi nhóm có đủ quyền của nhóm bên dưới cộng thêm quyền riêng.




**Hình 2.4. Sơ đồ use case của hệ thống Back-End LaptopNew**

## 2.4. Thiết kế cơ sở dữ liệu

Dữ liệu nằm trong database `laptop_store` trên MongoDB Atlas. MongoDB không có "khóa ngoại" như bảng quan hệ, nên nhóm chọn hai cách liên kết: **nhúng** (đặt luôn dữ liệu con vào bên trong) cho những gì luôn đọc cùng nhau, và **tham chiếu** (lưu mã của bản ghi khác) cho các liên kết còn lại. Hình 2.5 thể hiện các quan hệ chính.




**Hình 2.5. Sơ đồ quan hệ giữa các collection (ERD)**

**Bảng 2.3. Danh sách collection và số bản ghi thực tế (13/10/2026)**

| Collection | Lưu gì | Số bản ghi |
|---|---|---|
| san_pham | Laptop, phụ kiện: giá, thông số, phiên bản, tồn kho theo chi nhánh | 61 |
| don_hang | Đơn hàng, giao hàng, thanh toán, lộ trình | 31 |
| nguoi_dung | Tài khoản, vai trò, ví voucher, sổ địa chỉ | 16 |
| dang_ky_tam | Đăng ký chờ xác nhận OTP (tự xóa sau 10 phút) | tạm thời |
| ma_giam_gia | Mã giảm giá tiền mặt hoặc phần trăm | 14 |
| danh_gia | Đánh giá sao và bình luận | 33 |
| danh-muc | Thương hiệu, nhu cầu, phân khúc | 21 |
| tin_tuc | Bài viết tin tức công nghệ | 10 |
| lien_he | Phiếu yêu cầu tư vấn của khách | 5 |
| cai_dat | Cấu hình showroom và khuyến mãi | 1 |
| gio_hang | Giỏ hàng theo tài khoản (chỉ lưu mã và số lượng) | 2 |
| yeu_thich | Sản phẩm yêu thích theo tài khoản | 0 |
| bao_hanh_ghi_de | Admin ghi đè số serial / thời hạn bảo hành | 0 |



| Collection name | Properties | Storage size | Data size | Documents | Avg. document size | Indexes | Total index size |
|---|---|---|---|---|---|---|---|
| cai_dat | - | 36.86 kB | 1.19 kB | 1 | 1.19 kB | 2 | 73.73 kB |
| dang_ky_tam | - | 24.58 kB | 0 B | 0 | 0 B | 2 | 57.34 kB |
| danh-muc | - | 36.86 kB | 6.87 kB | 21 | 327.00 B | 4 | 147.46 kB |
| danh_gia | - | 53.25 kB | 23.52 kB | 33 | 712.00 B | 1 | 36.86 kB |
| don_hang | - | 102.40 kB | 101.60 kB | 30 | 3.39 kB | 6 | 221.18 kB |
| gio_hang | - | 36.86 kB | 194.00 B | 1 | 194.00 B | 2 | 73.73 kB |
| lien_he | - | 36.86 kB | 1.95 kB | 5 | 389.00 B | 4 | 147.46 kB |
| ma_giam_gia | - | 36.86 kB | 6.07 kB | 14 | 433.00 B | 2 | 73.73 kB |
| nguoi_dung | - | 45.06 kB | 9.01 kB | 15 | 600.00 B | 3 | 110.59 kB |
| san_pham | - | 192.51 kB | 168.48 kB | 61 | 2.76 kB | 3 | 110.59 kB |

**Hình 2.6. Các collection trong database laptop_store trên MongoDB Atlas (số tài liệu và dung lượng)**

### 2.4.1. Collection san_pham

**Bảng 2.4. Các trường chính của san_pham**

| Trường | Ý nghĩa |
|---|---|
| id, slug, ma_san_pham | Mã định danh, đường dẫn thân thiện (SEO) và mã SKU; không trùng nhau |
| ten_san_pham, hang_san_xuat, danh_muc | Tên, hãng (asus, dell…) và nhu cầu (gaming, văn phòng…) |
| gia_goc, gia_khuyen_mai, phan_tram_giam_gia | Giá niêm yết, giá bán thật và phần trăm giảm (server tự tính) |
| thong_so | CPU, RAM, ổ cứng, màn hình, pin… (nhiều thông số lồng nhau) |
| tuy_chon_phien_ban, qua_tang, ton_kho | Các phiên bản cấu hình, quà tặng, tồn kho theo từng chi nhánh |
| so_luong_ton_kho, so_luong_da_ban, con_hang | Tổng tồn kho, số đã bán, còn bán hay không |
| diem_danh_gia_tb, so_luong_danh_gia | Điểm trung bình và số lượt đánh giá (tính lại mỗi khi có đánh giá mới) |

### 2.4.2. Collection don_hang

**Bảng 2.5. Các trường chính của don_hang**

| Trường | Ý nghĩa |
|---|---|
| ma_don_hang, id_nguoi_dung | Mã đơn hiển thị (LPN-2026-…) và tài khoản sở hữu đơn |
| trang_thai | cho_xac_nhan → da_xac_nhan → dang_giao → da_giao (hoặc da_huy) |
| thong_tin_giao_hang | Họ tên, số điện thoại, email, địa chỉ nhận hàng |

| Trường | Ý nghĩa |
|---|---|
| danh_sach_san_pham | Từng món trong đơn, lưu kèm giá tại lúc mua để không đổi khi sản phẩm được sửa sau này |
| tam_tinh, tien_giam_gia, tong_tien_thanh_toan | Tạm tính, số tiền giảm và số tiền phải trả (do server tính) |
| hinh_thuc_thanh_toan, da_thanh_toan, trang_thai_thanh_toan | Hình thức, đã thu tiền chưa, trạng thái thanh toán |
| payos_order_code, da_tru_ton_kho | Mã giao dịch PayOS để đối soát; cờ đã giữ hàng trong kho (chống trừ kho hai lần) |

### 2.4.3. Collection nguoi_dung và dang_ky_tam

**Bảng 2.6. Các trường chính của nguoi_dung**

| Trường | Ý nghĩa |
|---|---|
| email, hoTen, soDienThoai | Thông tin tài khoản; email là duy nhất, dùng để đăng nhập |
| matKhau | Chuỗi bcrypt, không bao giờ trả về cho người dùng |
| vaiTro | khach_hang (mặc định) hoặc admin |
| viVoucher, danhSachDiaChi | Ví mã giảm giá và sổ địa chỉ |
| maOtp, hanOtp, loaiOtp | OTP đang hiệu lực (chỉ lưu bản băm), hạn 10 phút, mục đích (kích hoạt / quên / đổi mật khẩu) |
| tokenVersion | Số phiên bản phiên đăng nhập; tăng lên thì mọi token cũ mất hiệu lực |
| soLanNhapSaiOtp, soLanDangNhapSai, khoaDangNhapDen | Bộ đếm chống đoán OTP và đoán mật khẩu |
| biKhoa, trangThai, lyDoKhoa | Tài khoản có bị khóa không và lý do |

Đăng ký chưa xác nhận được giữ ở collection tạm `dang_ky_tam` với "chỉ mục tự xóa" (TTL): MongoDB tự dọn bản ghi khi OTP hết hạn. Nhờ vậy collection `nguoi_dung` chỉ chứa tài khoản đã xác thực, không bị đầy tài khoản rác (Hình 2.7).




**Hình 2.7. Bản ghi tạm sau khi đăng ký: mật khẩu là chuỗi bcrypt, OTP là chuỗi băm 64 ký tự**




**Hình 2.8. Sau khi kích hoạt: tài khoản chính thức xuất hiện trong nguoi_dung**

### 2.4.4. Các collection còn lại và chỉ mục

**Bảng 2.7. Chỉ mục và ràng buộc dữ liệu quan trọng**

| Collection | Ràng buộc / chỉ mục | Để làm gì |
|---|---|---|
| san_pham | id, slug duy nhất | Tra nhanh theo mã hoặc đường dẫn, không trùng |
| don_hang | ma_don_hang duy nhất; chỉ mục payos_order_code, id_nguoi_dung | Tra đơn và đối soát Webhook nhanh |
| nguoi_dung | email duy nhất | Không đăng ký trùng email |
| dang_ky_tam | Chỉ mục TTL trên hanOtp | Tự xóa đăng ký chưa xác nhận khi hết hạn |
| ma_giam_gia | ma_code duy nhất, viết HOA | Mỗi mã chỉ tồn tại một lần |
| lien_he | ma_yeu_cau duy nhất | Mỗi phiếu có mã riêng dạng LH-YYMMDD-XXXX |
| danh_gia | so_sao từ 1 đến 5 | Không nhận điểm sai |

## 2.5. Các API chính

Toàn bộ API nằm dưới đường dẫn `/api/...`, trả dữ liệu JSON. Hệ thống có **82 route** (80 route nghiệp vụ trong 16 nhóm và 2 route kiểm tra máy chủ); một số route là bí danh của nhau nên có **74 chức năng khác nhau**. Bảng 2.8 thống kê theo nhóm; danh sách đầy đủ nằm ở Phụ lục A.

**Bảng 2.8. Số route theo nhóm chức năng**

| Nhóm | Đường dẫn gốc | Số route | Mục đích |
|---|---|---|---|
| Xác thực | /api/auth | 13 | Đăng ký, OTP, đăng nhập, Google, mật khẩu, hồ sơ |
| Sản phẩm | /api/san-pham | 5 | Xem, tìm, lọc; Admin thêm sửa xóa |
| Danh mục | /api/danh-muc | 4 | Thương hiệu, nhu cầu, phân khúc |
| Đơn hàng | /api/don-hang | 5 | Đặt, xem, tra cứu, cập nhật, xóa |
| Thanh toán | /api/thanh-toan | 6 | Tạo QR, kiểm tra, Webhook (3 bí danh) |
| Mã giảm giá | /api/ma-giam-gia | 7 | Kiểm tra, lưu vào ví, quản lý |
| Đánh giá | /api/danh-gia | 7 | Gửi, xem, thích; Admin ẩn / xóa |
| Người dùng | /api/nguoi-dung | 4 | Admin quản lý tài khoản |
| Tin tức | /api/tin-tuc | 5 | Bài viết công nghệ |
| Bảo hành | /api/bao-hanh | 4 | Tra cứu; Admin ghi đè thời hạn |
| Liên hệ | /api/lien-he | 5 | Phiếu tư vấn |
| Cài đặt | /api/cai-dat | 5 | Showroom và khuyến mãi |
| Trợ lý AI | /api/tro-ly-ai | 4 | Chat, chat stream, trạng thái |
| Đồng bộ | /api/dong-bo | 1 | Chữ ký dữ liệu để giao diện tự cập nhật |
| Giỏ hàng | /api/gio-hang | 2 | Giỏ theo tài khoản |
| Yêu thích | /api/yeu-thich | 3 | Danh sách yêu thích theo tài khoản |
| Hệ thống | / và /api/health | 2 | Kiểm tra máy chủ còn sống |

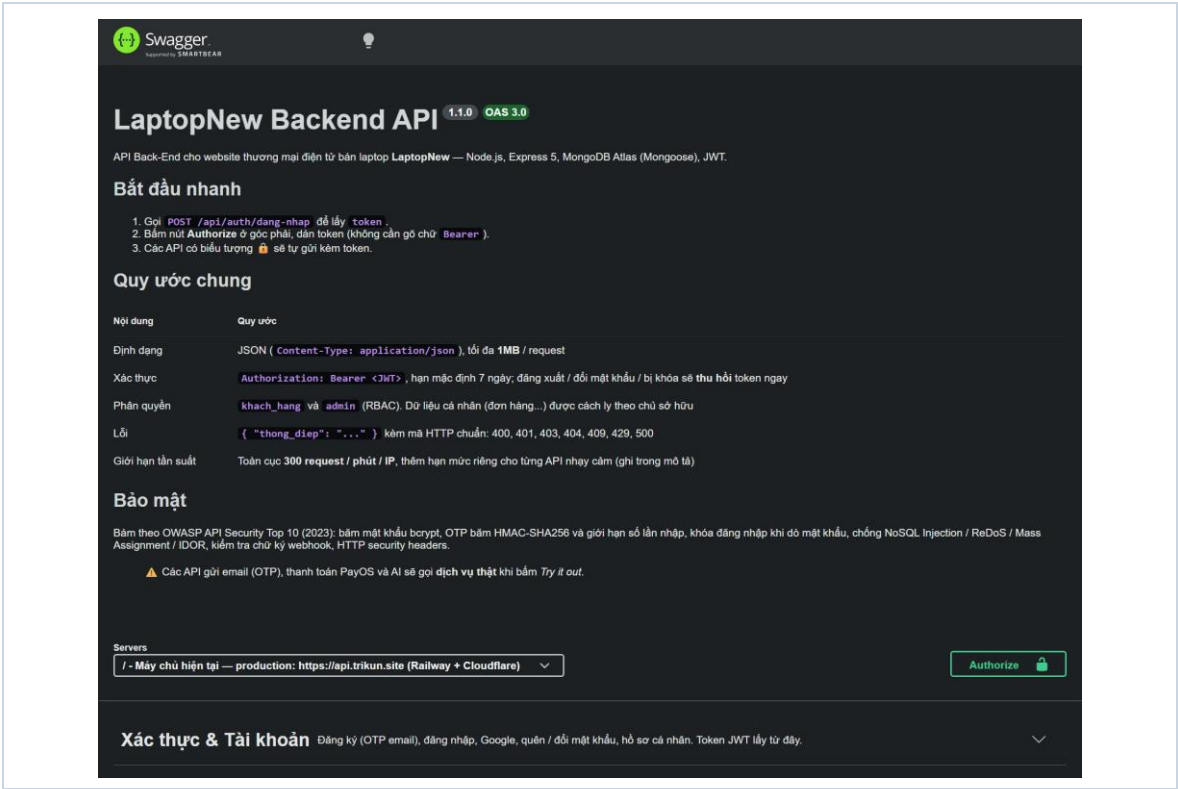
Mỗi API được gắn một trong bốn mức quyền (Bảng 2.9). Đây là cơ sở của toàn bộ phần phân quyền và bảo mật ở Chương 4.

**Bảng 2.9. Các mức quyền truy cập**

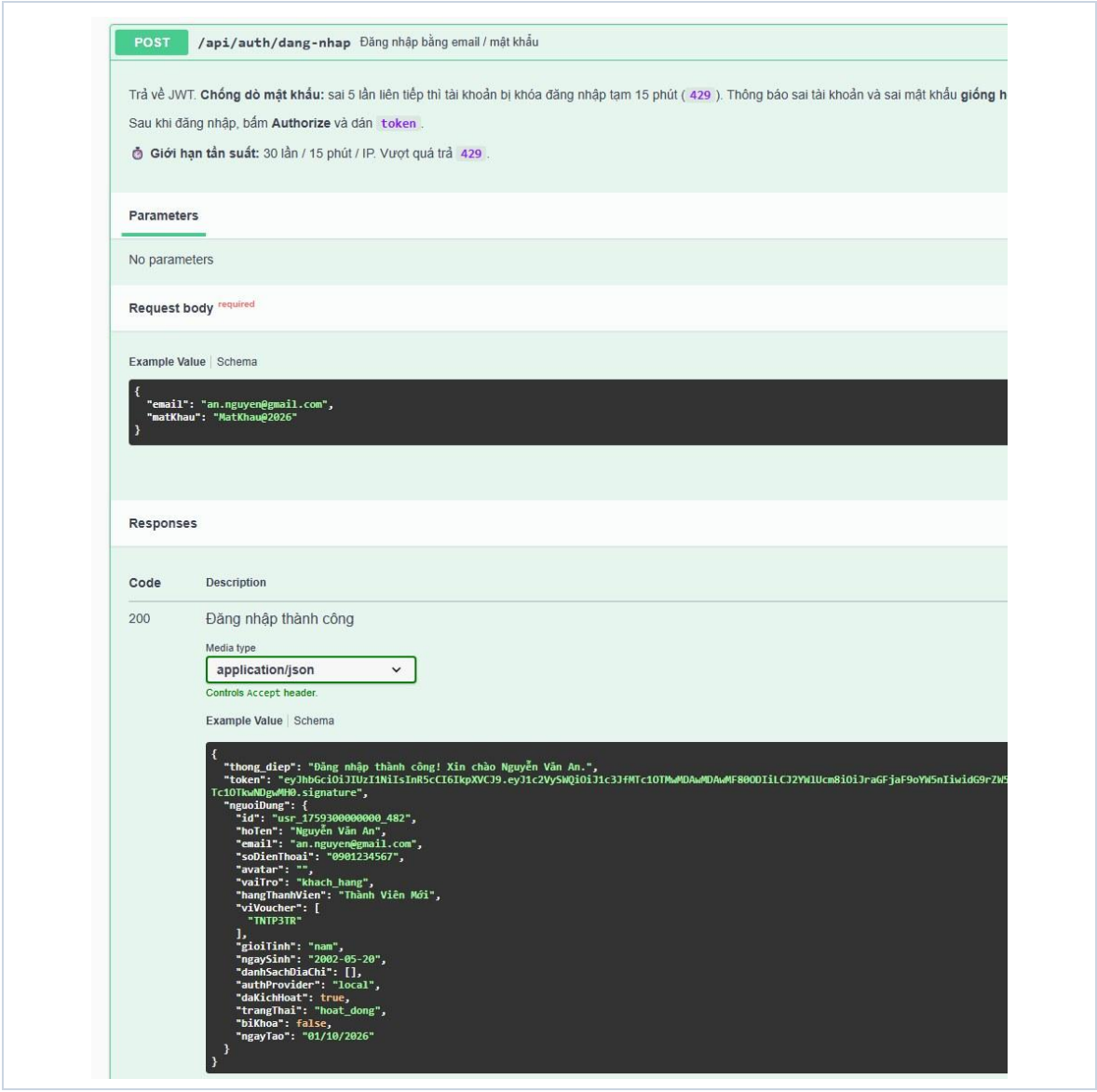
| Mức quyền | Ý nghĩa | Không đạt thì |
|---|---|---|
| Công khai | Ai cũng gọi được | — |
| Đăng nhập (JWT) | Phải có token hợp lệ, chưa bị thu hồi | 401 Unauthorized |
| Admin | Token phải thuộc tài khoản vai trò admin | 403 Forbidden |

| Mức quyền | Ý nghĩa | Không đạt thì |
|---|---|---|
| Webhook | Phải có chữ ký đúng của PayOS | 400 Bad Request |

Để bất kỳ ai cũng xem và thử được, toàn bộ API được công bố dưới dạng **trang tài liệu Swagger** ngay trên máy chủ thật. Người dùng chỉ cần mở trang, bấm "Try it out" là gọi được API (Hình 2.9).




**Hình 2.9. Trang chủ tài liệu Swagger: mô tả, quy ước chung và danh sách nhóm API**




**Hình 2.10. Chi tiết API đăng nhập: mô tả nghiệp vụ, ví dụ dữ liệu gửi lên và phản hồi**

## 2.6. Các luồng xử lý chính

Phần này kể lại từng luồng quan trọng bằng sơ đồ và các bước ngắn gọn, không cần đọc mã nguồn vẫn hiểu.

### 2.6.1. Luồng đăng ký tài khoản bằng OTP

Mục tiêu: chỉ tạo tài khoản khi người dùng chứng minh được họ sở hữu email, và không để lại tài khoản rác nếu họ bỏ dở (Hình 2.11).

**Bước 1:** Người dùng nhập họ tên, email, số điện thoại, mật khẩu. Server kiểm tra từng ô; mật khẩu phải từ 8 ký tự, có cả chữ và số.

**Bước 2:** Server băm mật khẩu bằng bcrypt, sinh mã OTP 6 số ngẫu nhiên và chỉ lưu **bản băm** của OTP vào bảng tạm.

**Bước 3:** Server gửi email chứa OTP. Nếu gửi lỗi, báo lỗi 502 và cho phép gửi lại.

**Bước 4:** Người dùng nhập OTP. Sai thì báo còn mấy lần thử, sai 5 lần thì hủy đăng ký tạm.

**Bước 5:** OTP đúng: tạo tài khoản chính thức, xóa bản ghi tạm và cấp token để đăng nhập luôn.




**Hình 2.11. Sơ đồ tuần tự đăng ký và kích hoạt tài khoản bằng OTP**

### 2.6.2. Luồng đăng nhập và xác thực bằng JWT

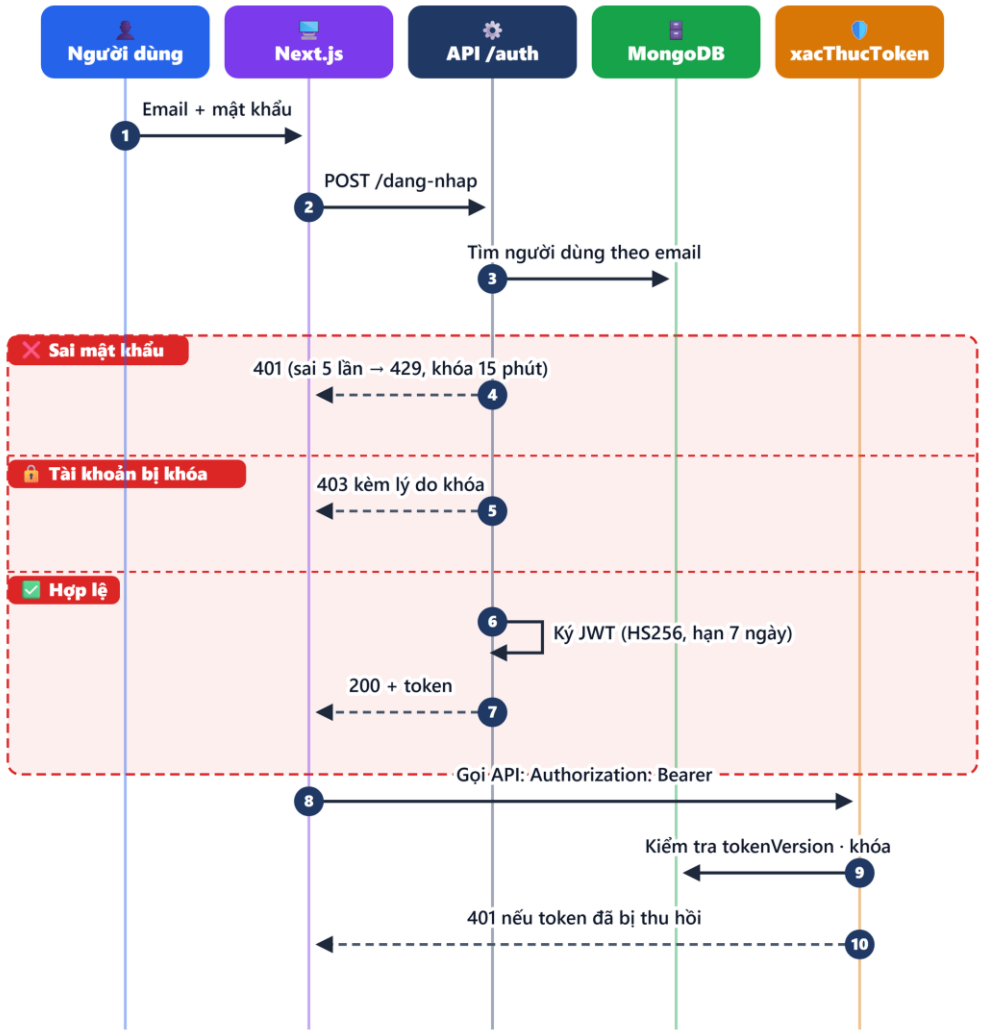
Mục tiêu: cho đăng nhập bằng email và mật khẩu, chặn tài khoản bị khóa, và nhận ra người dùng ở những lần gọi tiếp theo (Hình 2.12).

**Bước 1:** Người dùng gửi email và mật khẩu. Sai thì báo chung một câu "Tài khoản hoặc mật khẩu không chính xác", không tiết lộ ô nào sai.

**Bước 2:** Sai 5 lần liên tiếp thì tài khoản bị khóa đăng nhập 15 phút (lỗi 429).

**Bước 3:** Đúng và tài khoản không bị khóa: server ký token JWT (hạn 7 ngày) gửi về.

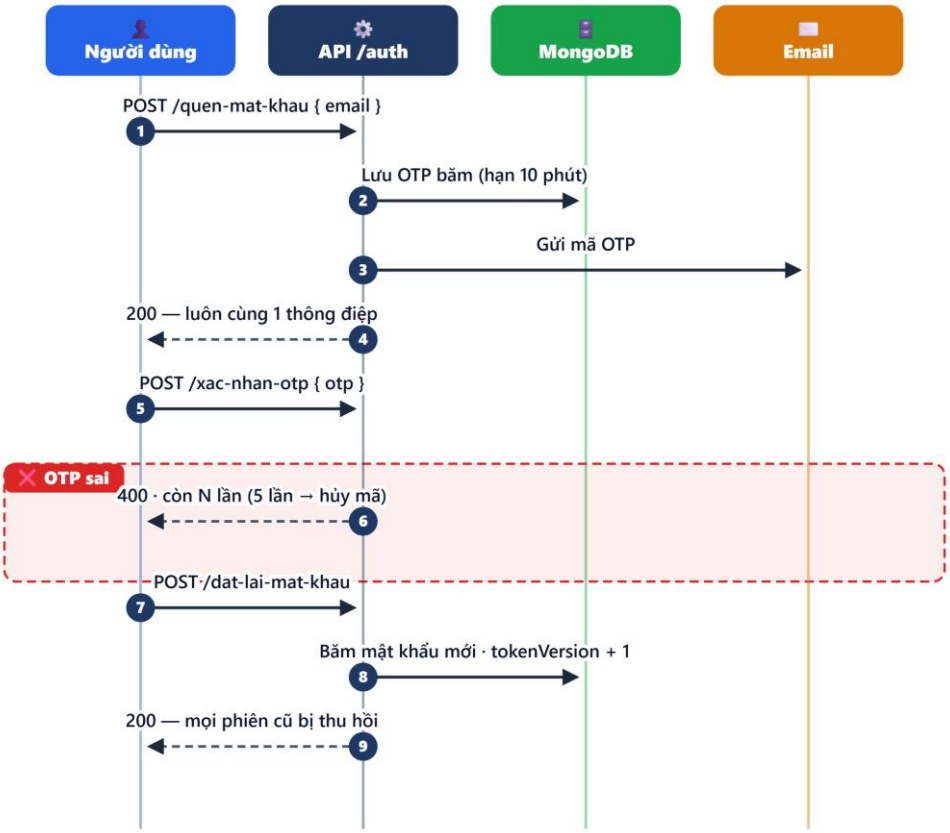
**Bước 4:** Từ lần sau, người dùng đưa token kèm mỗi yêu cầu. Server kiểm tra chữ ký, tài khoản chưa bị khóa và token chưa bị thu hồi rồi mới cho đi tiếp.




**Hình 2.12. Sơ đồ tuần tự đăng nhập và gọi API được bảo vệ**

### 2.6.3. Luồng quên mật khẩu

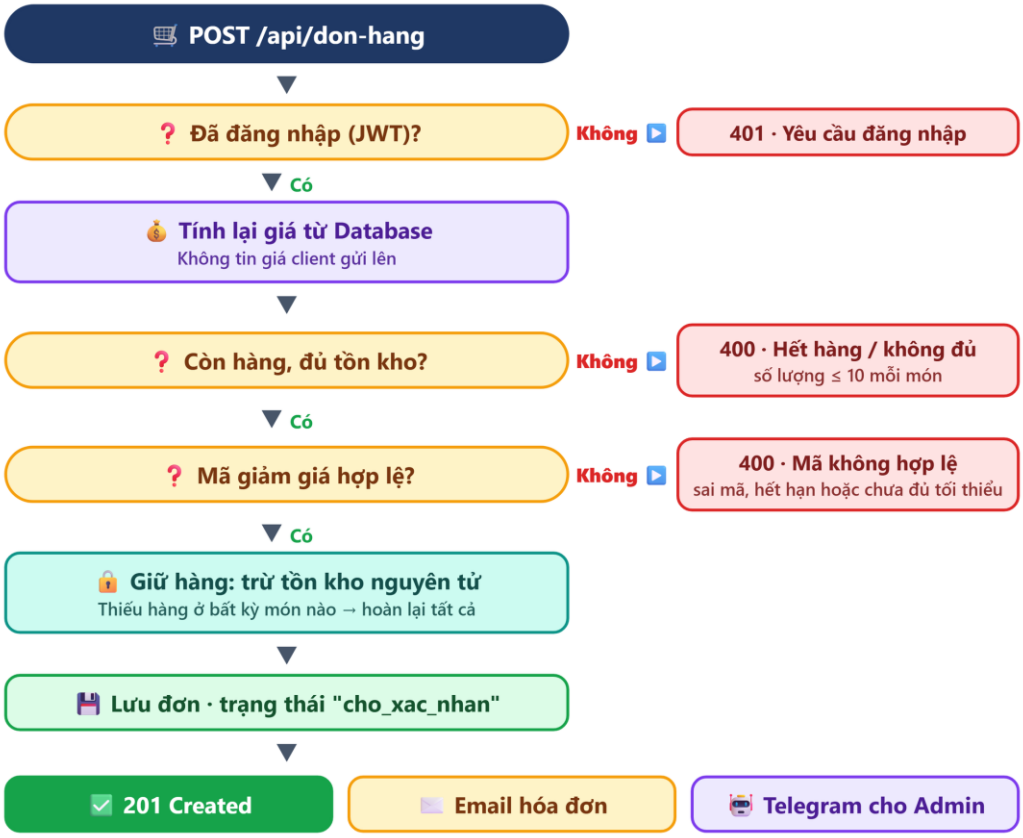
Quên mật khẩu cũng dùng OTP. Điểm đáng chú ý là hệ thống **luôn trả cùng một câu trả lời** dù email có tồn tại hay không, để kẻ xấu không dò được ai đã đăng ký (Hình 2.13). Khi đặt lại mật khẩu thành công, mọi phiên đăng nhập cũ bị thu hồi.




**Hình 2.13. Sơ đồ tuần tự quên mật khẩu bằng OTP**

### 2.6.4. Luồng đặt hàng, giữ hàng và trạng thái đơn

Khi khách bấm đặt hàng, Back-End không tin giá và số lượng trình duyệt gửi lên mà tự tính lại từ database. Quan trọng nhất là bước **giữ hàng**: tồn kho được trừ ngay, bằng một lệnh nguyên tử, nên hai khách cùng mua chiếc máy cuối cùng thì chỉ một người thành công (Hình 2.14, 2.15).



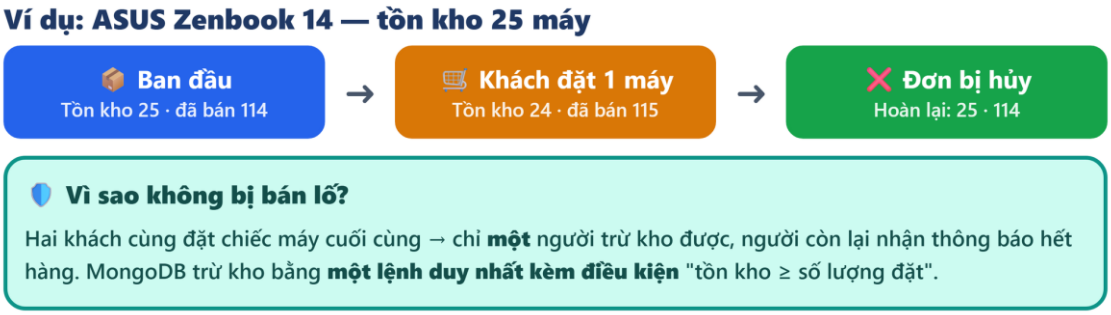

**Hình 2.14. Lưu đồ xử lý tạo đơn hàng**




**Hình 2.15. Vòng đời trạng thái đơn hàng và quy tắc giữ / hoàn lại tồn kho**

**Bảng 2.10. Ai được đổi trạng thái đơn hàng**

| Người thao tác | Được làm gì |
|---|---|
| Admin | Đổi sang mọi trạng thái; đổi sang "đã hủy" thì hoàn kho; khôi phục đơn hủy thì giữ hàng lại |
| Chủ đơn (thành viên) | Chỉ được hủy đơn khi còn "chờ xác nhận"; hủy là hoàn kho ngay |
| Người khác | Bị từ chối (403), không xem cũng không sửa được |
| Khách chưa đăng nhập | Chỉ tra cứu được khi nhập đúng mã đơn và số điện thoại nhận hàng; thông tin cá nhân bị che |




**Hình 2.16. Giữ hàng nguyên tử: tồn kho giảm khi đặt và hoàn lại khi hủy**

### 2.6.5. Luồng thanh toán PayOS và VietQR

Khách chọn chuyển khoản, hệ thống tạo mã QR có sẵn số tiền và nội dung. Khi tiền về, PayOS tự gọi ngược vào hệ thống (Webhook) để xác nhận, không cần nhân viên đối soát (Hình 2.17).

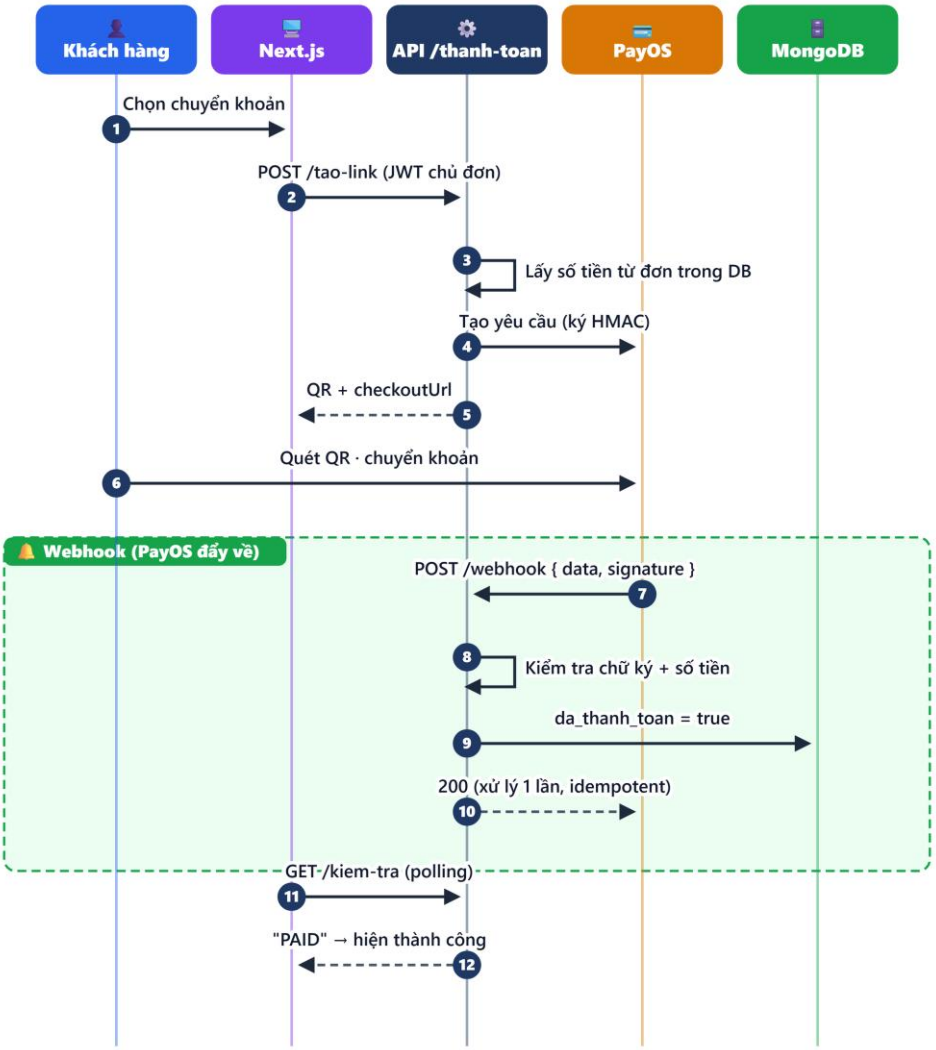
**Bước 1:** Chủ đơn gửi yêu cầu tạo thanh toán. Số tiền **luôn lấy từ đơn trong database**; đơn đã trả tiền hoặc đã hủy bị từ chối.

**Bước 2:** Server ký yêu cầu bằng chữ ký HMAC-SHA256, gọi PayOS và dựng sẵn ảnh VietQR để luôn có mã QR ngay cả khi PayOS phản hồi chậm.

**Bước 3:** Khách quét mã và chuyển khoản. PayOS gọi Webhook về server.

**Bước 4:** Server kiểm tra chữ ký, kiểm tra số tiền khớp đơn, bỏ qua nếu đơn đã xử lý rồi (tránh xử lý trùng) rồi mới đánh dấu đã thanh toán, gửi email và báo Telegram.

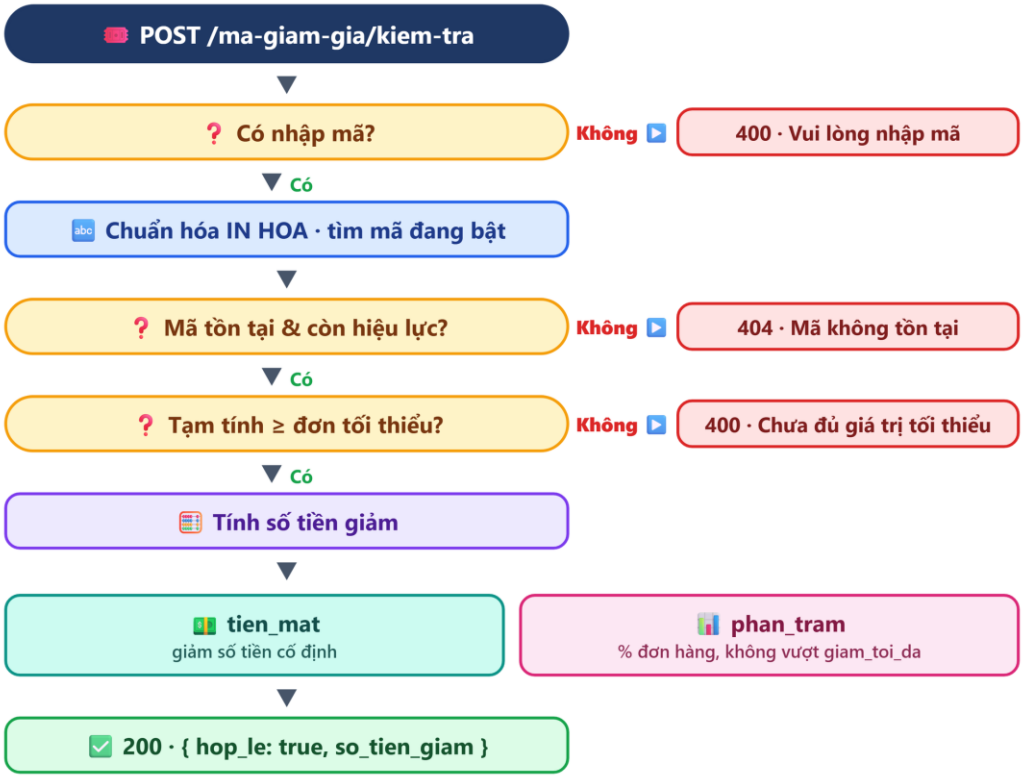
**Bước 5:** Song song, trang thanh toán hỏi trạng thái định kỳ để hiện “Thanh toán thành công” cho khách.




**Hình 2.17. Sơ đồ tuần tự thanh toán PayOS / VietQR với Webhook**

### 2.6.6. Luồng mã giảm giá (voucher)

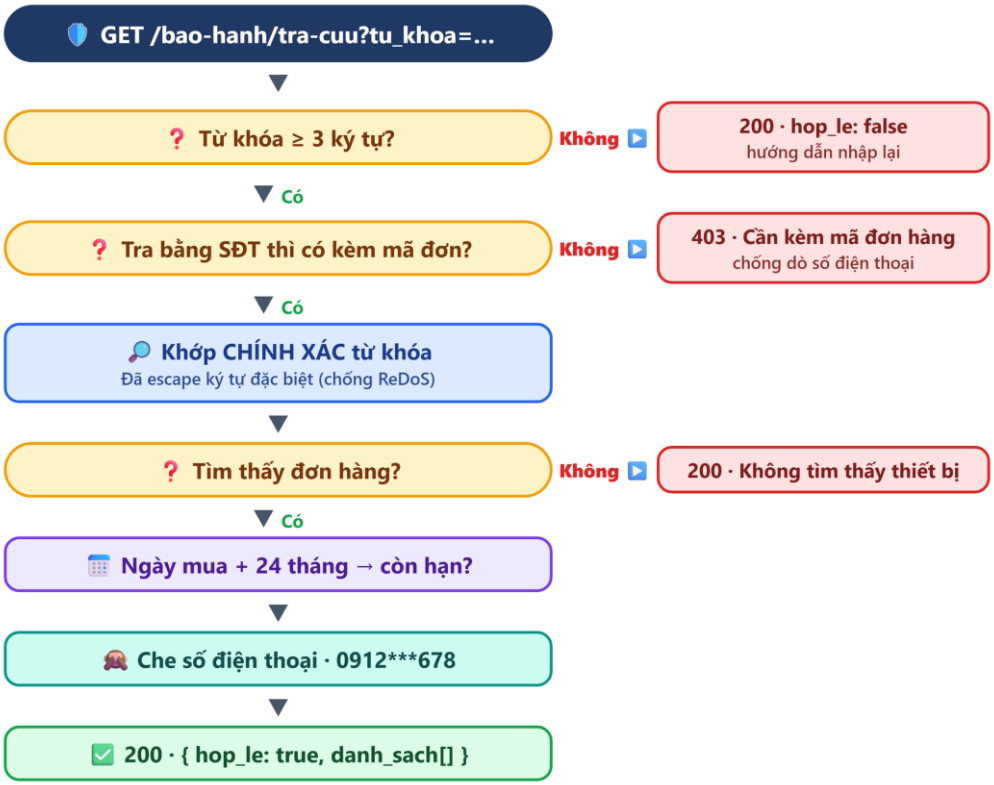
Mã giảm giá được kiểm tra lại ở server mỗi lần áp dụng: mã có tồn tại, còn hạn, đủ giá trị đơn tối thiểu không rồi mới tính số tiền giảm (Hình 2.18). Khách có thể "săn mã" để lưu vào ví; số lượt còn lại được trừ bằng thao tác nguyên tử nên không bao giờ phát vượt số lượng.




**Hình 2.18. Lưu đồ kiểm tra và tính tiền mã giảm giá**

### 2.6.7. Luồng tra cứu bảo hành điện tử

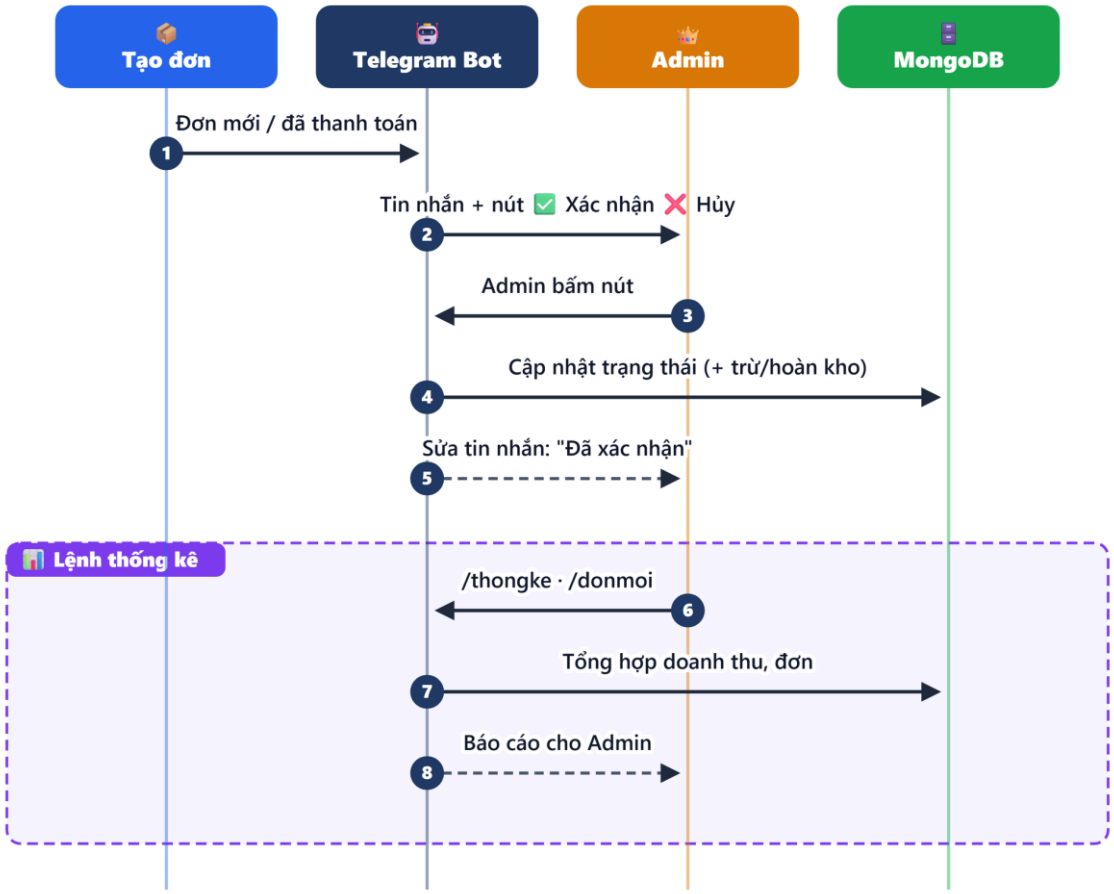
Khách tra cứu bảo hành bằng mã đơn, số serial hoặc mã sản phẩm, không cần phiếu giấy. Từ khóa phải khớp chính xác; tra bằng số điện thoại thì bắt buộc kèm mã đơn và số điện thoại được che một phần. Hạn bảo hành được tính bằng ngày mua cộng 24 tháng (Hình 2.19).




**Hình 2.19. Lưu đồ tra cứu bảo hành điện tử**

### 2.6.8. Luồng duyệt đơn qua Telegram

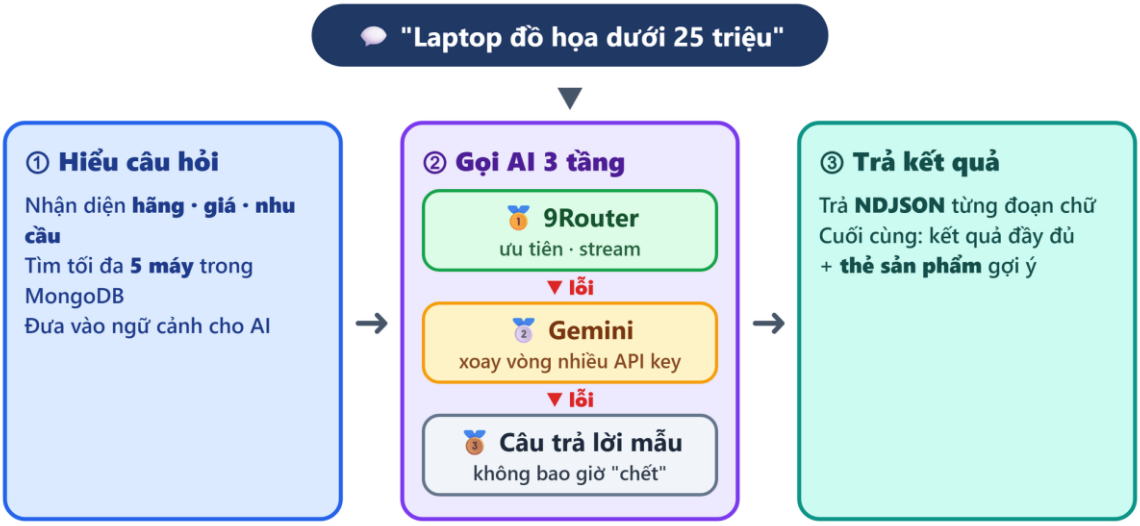
Khi có đơn mới hoặc đơn vừa thanh toán, bot gửi tin nhắn kèm các nút bấm cho Admin. Admin bấm nút ngay trên điện thoại, bot cập nhật trạng thái trong database và sửa lại tin nhắn. Bot cũng hiểu các lệnh thống kê như `/thongke` và `/donmoi` (Hình 2.20). Chỉ chat của quản trị viên đã đăng ký mới điều khiển được bot.




**Hình 2.20. Sơ đồ thông báo và duyệt đơn qua Telegram Bot**

### 2.6.9. Luồng Trợ lý AI tư vấn laptop

Trợ lý AI không trả lời "chung chung" mà đi qua ba bước (Hình 2.21): hiểu câu hỏi, lấy tối đa 5 laptop phù hợp trong database làm bằng chứng, rồi nhờ mô hình ngôn ngữ viết câu trả lời. Có ba tầng dự phòng nên một nhà cung cấp AI lỗi không làm trợ lý ngừng hoạt động.




**Hình 2.21. Luồng xử lý của Trợ lý AI với cơ chế dự phòng nhiều tầng**

# CHƯƠNG 3. CÀI ĐẶT THỰC NGHIỆM VÀ KẾT QUẢ

Chương này cho thấy hệ thống **chạy thật** thế nào: từ cách cài đặt, đến từng màn hình khách hàng và quản trị viên. Tất cả hình chụp từ website đang chạy tại trikun.site; số điện thoại và email của khách thật đã được che.

## 3.1. Môi trường cài đặt

**Bảng 3.1. Môi trường cài đặt hệ thống**

| Thành phần | Yêu cầu / giá trị |
|---|---|
| Hệ điều hành phát triển | Windows 11 |
| Node.js | Từ phiên bản 20 trở lên (nhóm dùng 24) |
| Cơ sở dữ liệu | Tài khoản MongoDB Atlas, mở Network Access cho máy chạy server |
| Tùy chọn | PayOS, Telegram Bot, Brevo, Google Cloud (đăng nhập Google), Gemini API key |
| Công cụ | Visual Studio Code, Postman, Git và GitHub, trình duyệt Chrome |
| Chạy thật | Railway (2 service Back-End và Front-End) và Cloudflare (tên miền trikun.site) |

Các bước cài đặt ở máy cá nhân gồm 5 bước:

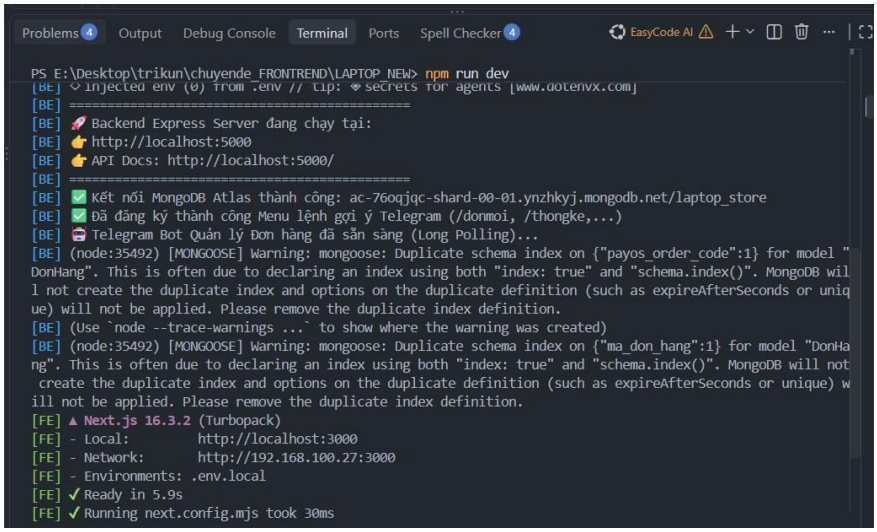
**Bước 1:** Tải mã nguồn từ GitHub về máy.

**Bước 2:** Vào thư mục `BE`, chạy `npm install` để cài thư viện.

**Bước 3:** Tạo tệp `.env` theo mẫu `.env.example`, điền chuỗi kết nối MongoDB và các khóa bí mật.

**Bước 4:** Chạy `npm run dev`; khi thấy dòng "Kết nối MongoDB Atlas thành công" là server đã sẵn sàng ở cổng 5000.

**Bước 5:** Vào thư mục `FE`, chạy `npm install` rồi `npm run dev` để mở website ở cổng 3000.




**Hình 3.1. Cửa sổ lệnh khi khởi động Back-End thành công**

## 3.2. Giao diện phía khách hàng

### 3.2.1. Trang chủ

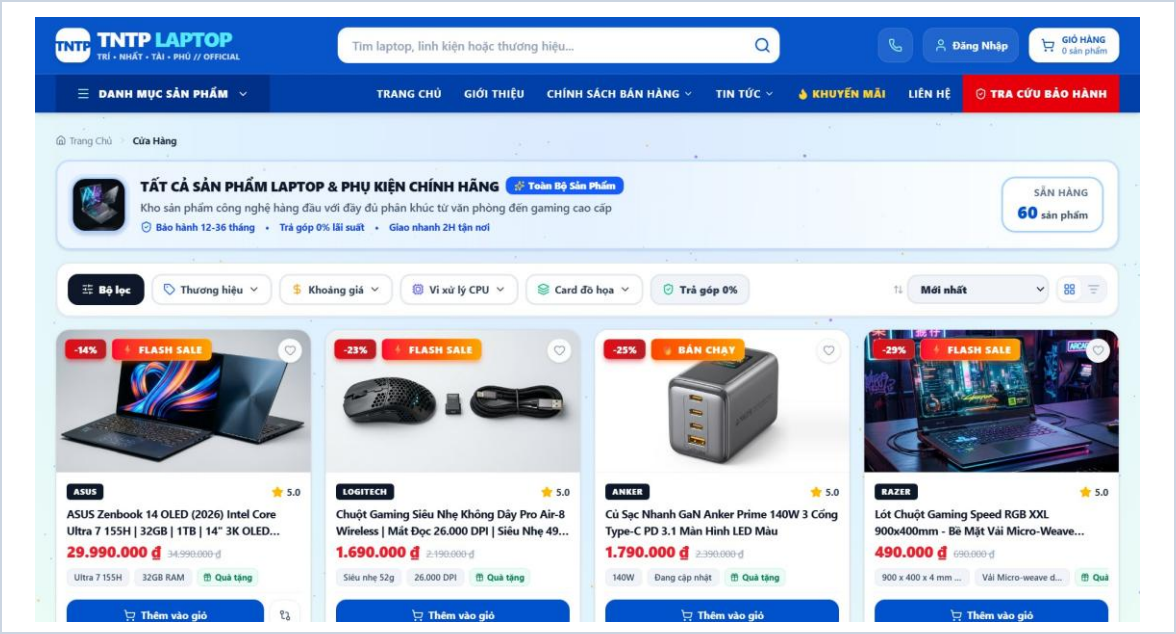
Trang chủ giới thiệu thương hiệu, banner Flash Sale đếm ngược, các nhóm sản phẩm bán chạy, tin tức công nghệ và hộp chat với Trợ lý AI. Dữ liệu trên trang đều lấy từ API (Hình 3.2).



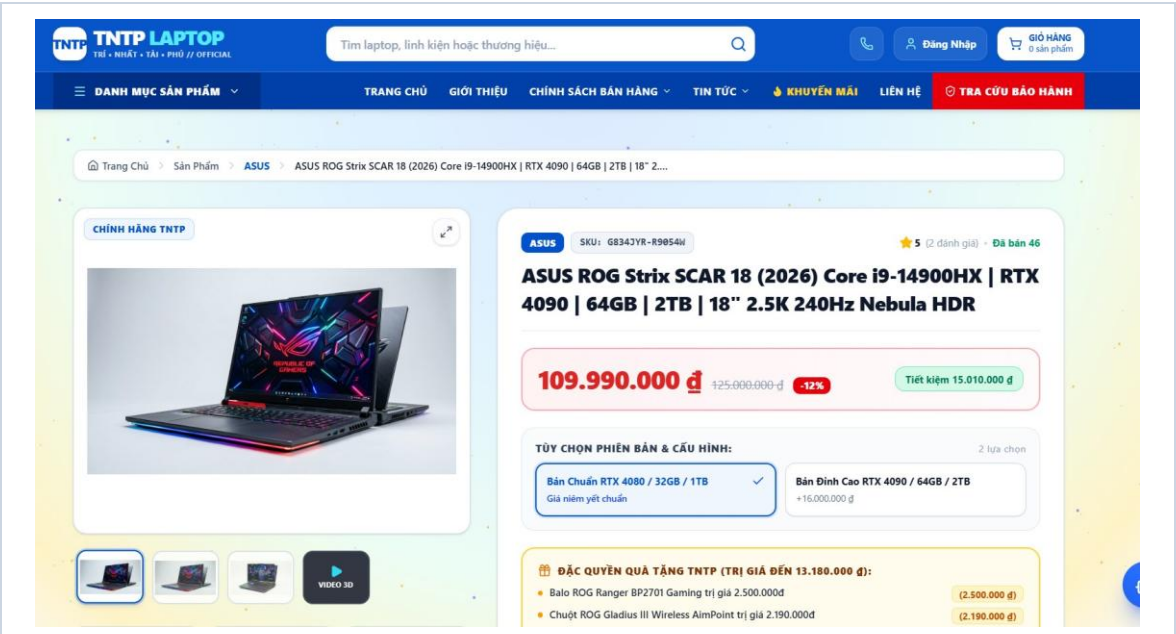

**Hình 3.2. Trang chủ website LaptopNew**

### 3.2.2. Danh sách và chi tiết sản phẩm

Khách tìm kiếm, lọc theo thương hiệu, khoảng giá, CPU, card đồ họa và sắp xếp theo giá hoặc độ bán chạy. Trang chi tiết có thư viện ảnh, các phiên bản cấu hình, giá khuyến mãi, quà tặng và tồn kho theo chi nhánh.



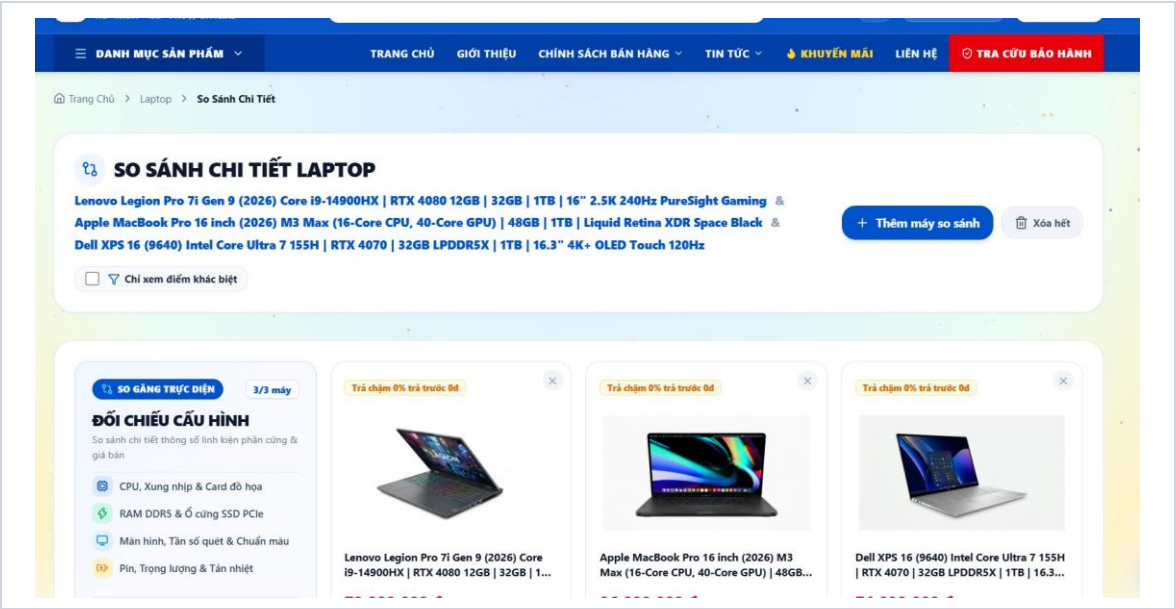

**Hình 3.3. Danh sách sản phẩm với bộ lọc**



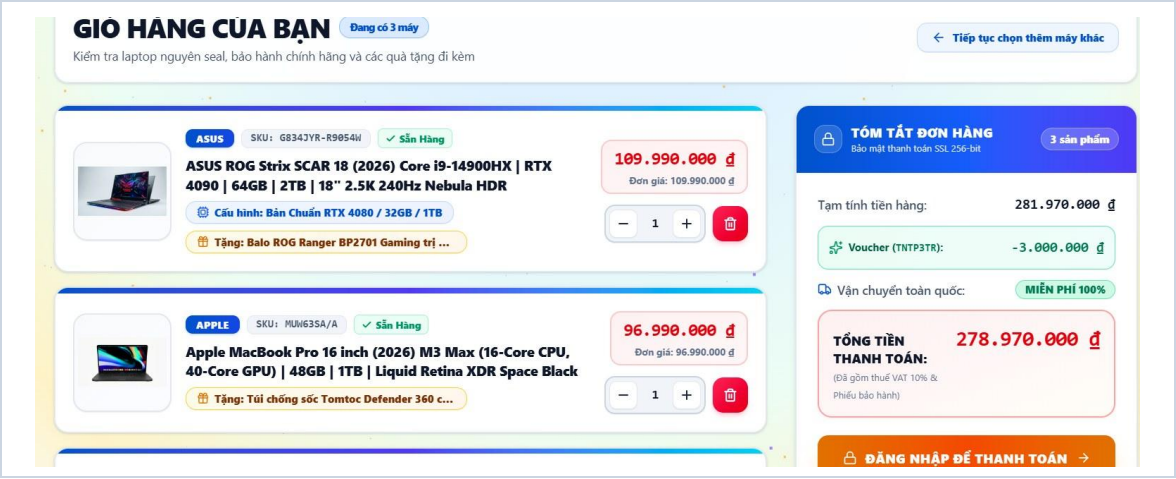

**Hình 3.4. Chi tiết sản phẩm: ảnh, cấu hình, giá, phiên bản**

### 3.2.3. So sánh sản phẩm và giỏ hàng

Khách chọn tối đa vài máy để đặt cạnh nhau so sánh CPU, RAM, màn hình, pin. Giỏ hàng hiển thị rõ từng món, quà tặng, mã giảm giá và tổng tiền. Khi giá hoặc tồn kho thay đổi, giỏ tự cập nhật và báo cho khách biết.




**Hình 3.5. Trang so sánh chi tiết các laptop**

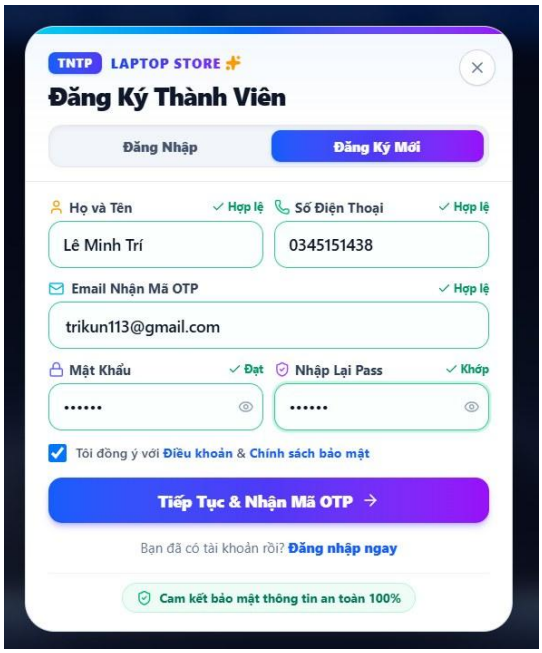



**Hình 3.6. Giỏ hàng: sản phẩm, tóm tắt đơn và nút thanh toán**

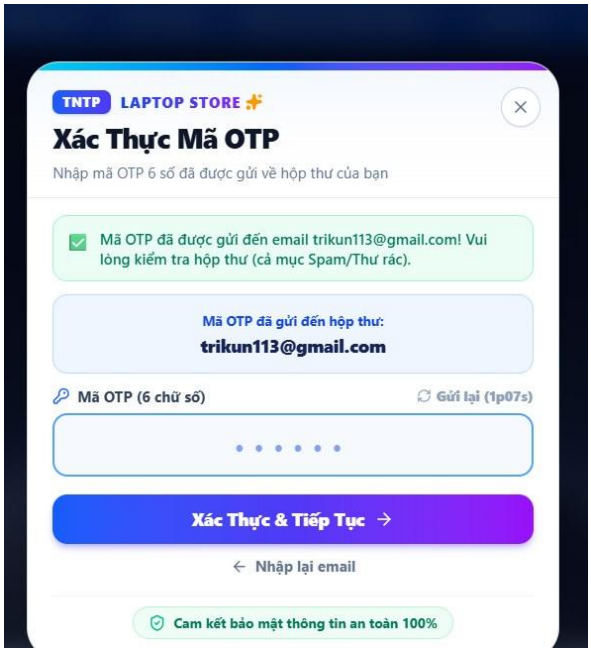
## 3.3. Chức năng tài khoản

### 3.3.1. Đăng ký và kích hoạt bằng OTP

Ô nhập hiện chữ "Hợp lệ" màu xanh ngay khi dữ liệu đúng. Sau khi bấm đăng ký, mã OTP gửi về email và khách nhập vào ô xác thực (Hình 3.7). Đăng ký chỉ hoàn tất khi nhập đúng mã.



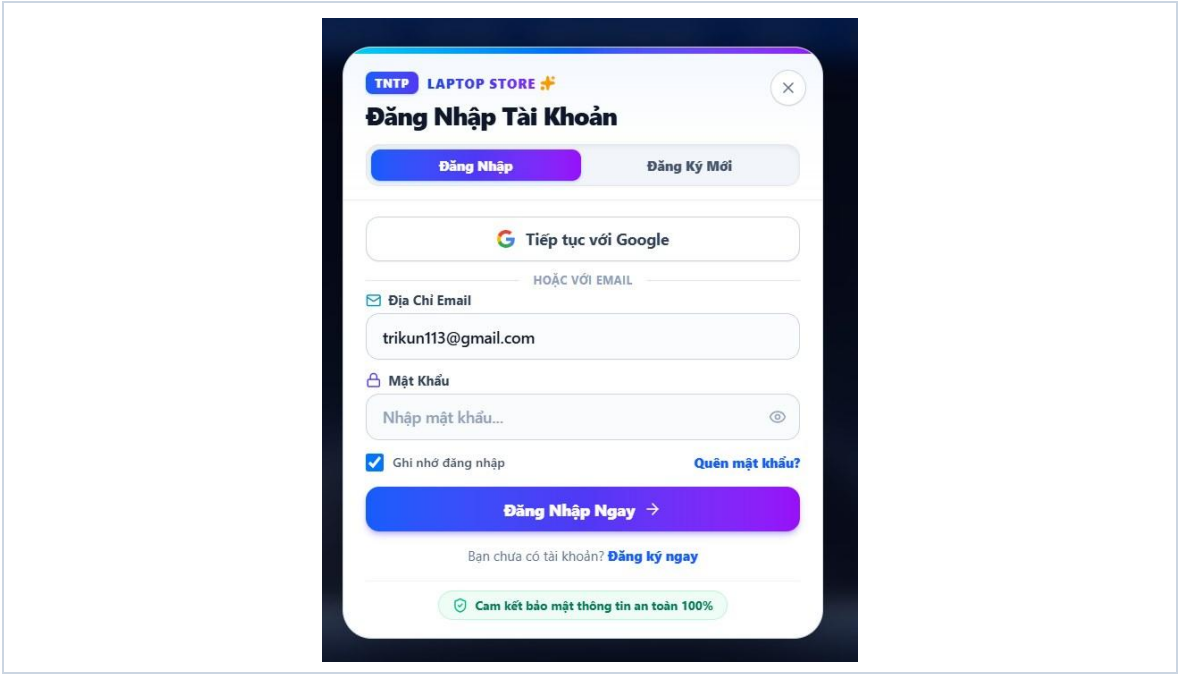

**Hình 3.7. Biểu mẫu đăng ký, kiểm tra từng ô**




**Hình 3.8. Nhập mã OTP 6 số để xác thực**

### 3.3.2. Đăng nhập, đăng nhập Google và quên mật khẩu

Khách đăng nhập bằng email và mật khẩu hoặc bấm “Tiếp tục với Google”. Khi quên mật khẩu, hệ thống gửi OTP đặt lại mật khẩu về email. Mật khẩu mới phải từ 8 ký tự và có cả chữ lẫn số.

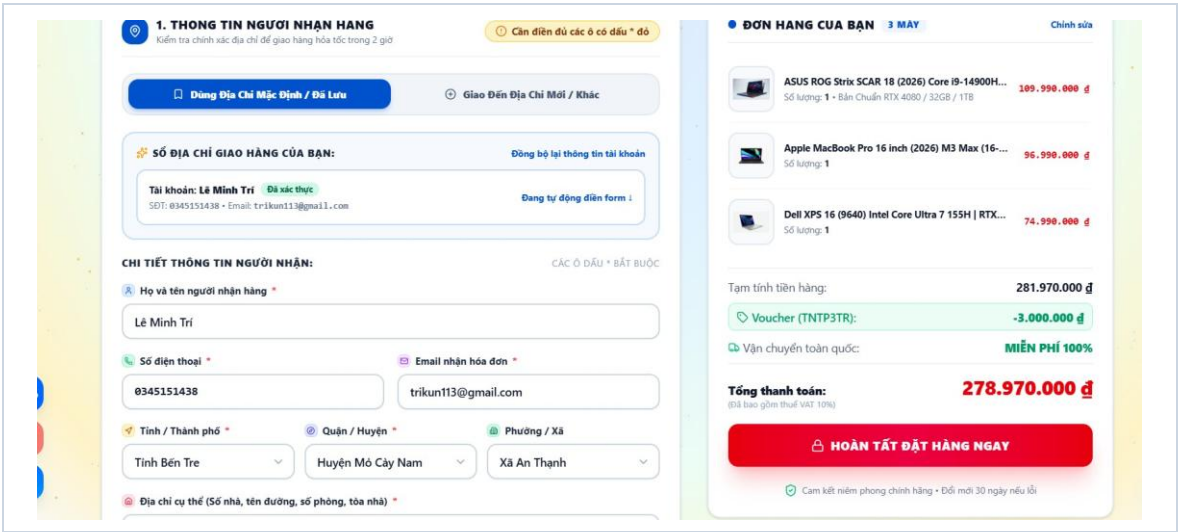



**Hình 3.9. Biểu mẫu đăng nhập có nút Google**

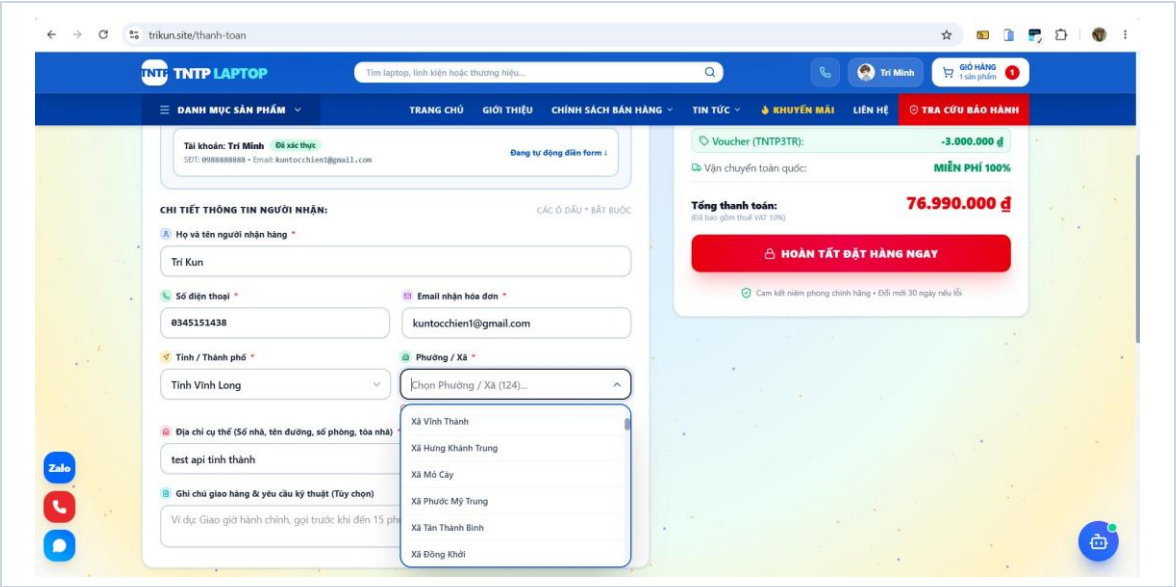
## 3.4. Chức năng mua hàng

### 3.4.1. Trang thanh toán và địa chỉ hành chính mới

Trang thanh toán gom thông tin người nhận, địa chỉ, phương thức thanh toán và tóm tắt đơn. Địa chỉ dùng danh sách **34 tỉnh / thành và phường / xã theo địa giới sau sáp nhập 2025** (nguồn Provinces Open API v2), khách chọn từ danh sách thay vì gõ tự do. Địa chỉ cũ tự được quy đổi sang tỉnh mới; nếu API ngoài lỗi, hệ thống có sẵn danh mục dự phòng nên ô chọn không bao giờ trống.



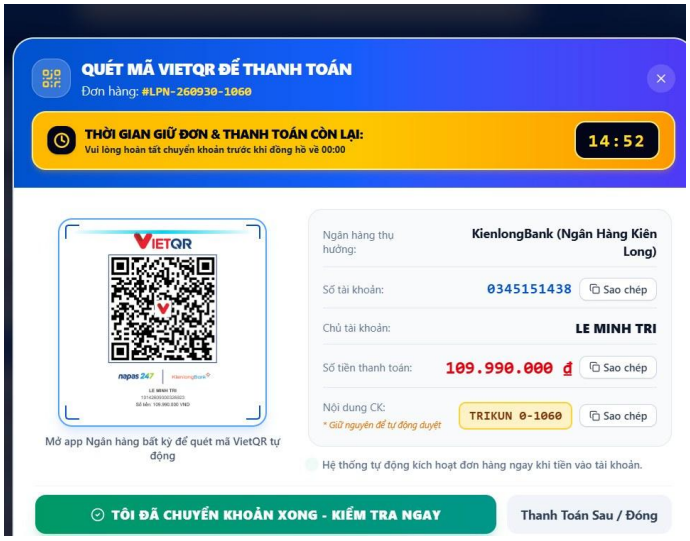

**Hình 3.10. Trang thanh toán: thông tin người nhận và tóm tắt đơn**



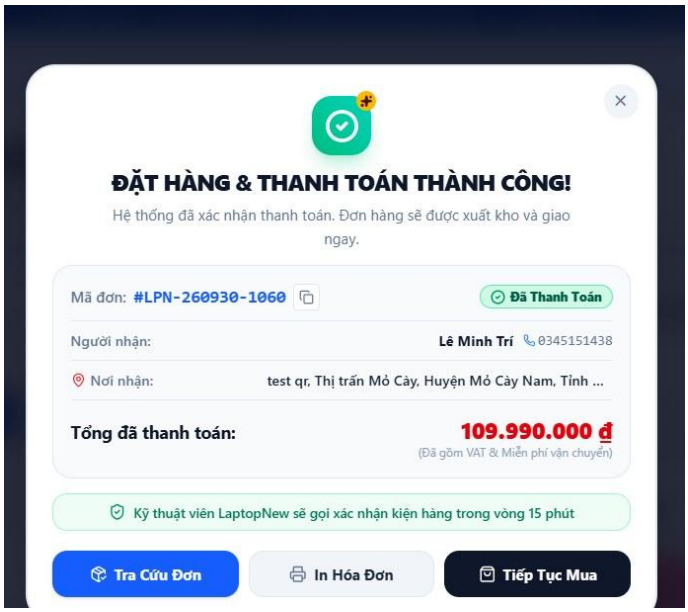

**Hình 3.11. Chọn Tỉnh/Thành và Phường/Xã theo địa giới mới**

### 3.4.2. Thanh toán QR và xác nhận tự động

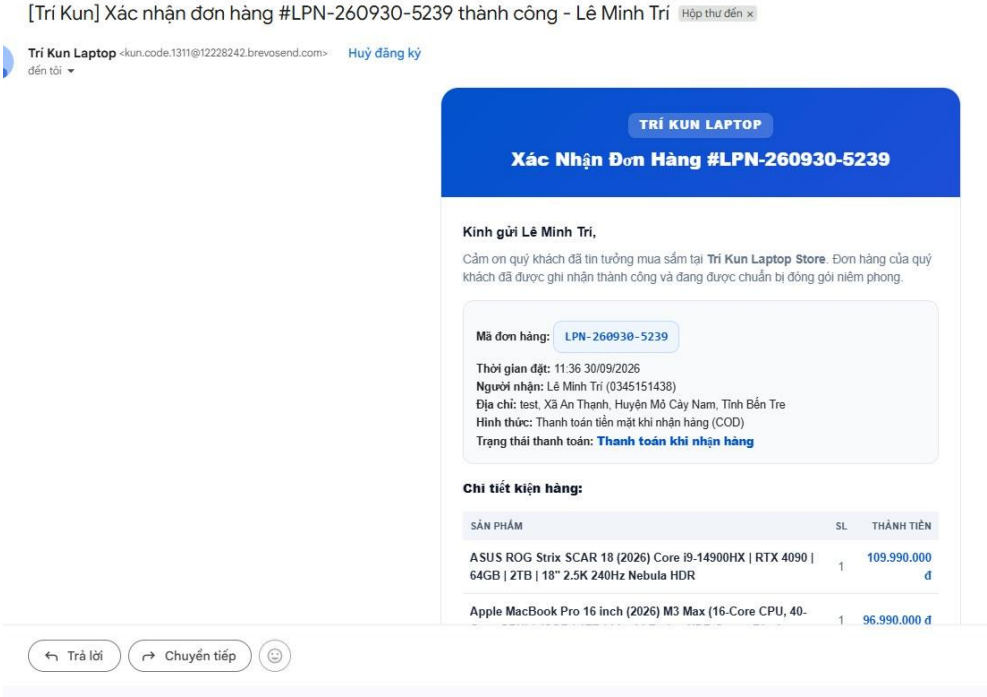
Với chuyển khoản, khách thấy mã VietQR kèm số tài khoản, số tiền, nội dung và đồng hồ đếm ngược giữ đơn 15 phút. Ngay khi tiền về, PayOS báo Webhook, trang chuyển sang "Đặt hàng & thanh toán thành công" và khách nhận email xác nhận.




**Hình 3.12. Mã VietQR có sẵn số tiền và nội dung**




**Hình 3.13. Thanh toán thành công, đơn tự chuyển trạng thái**



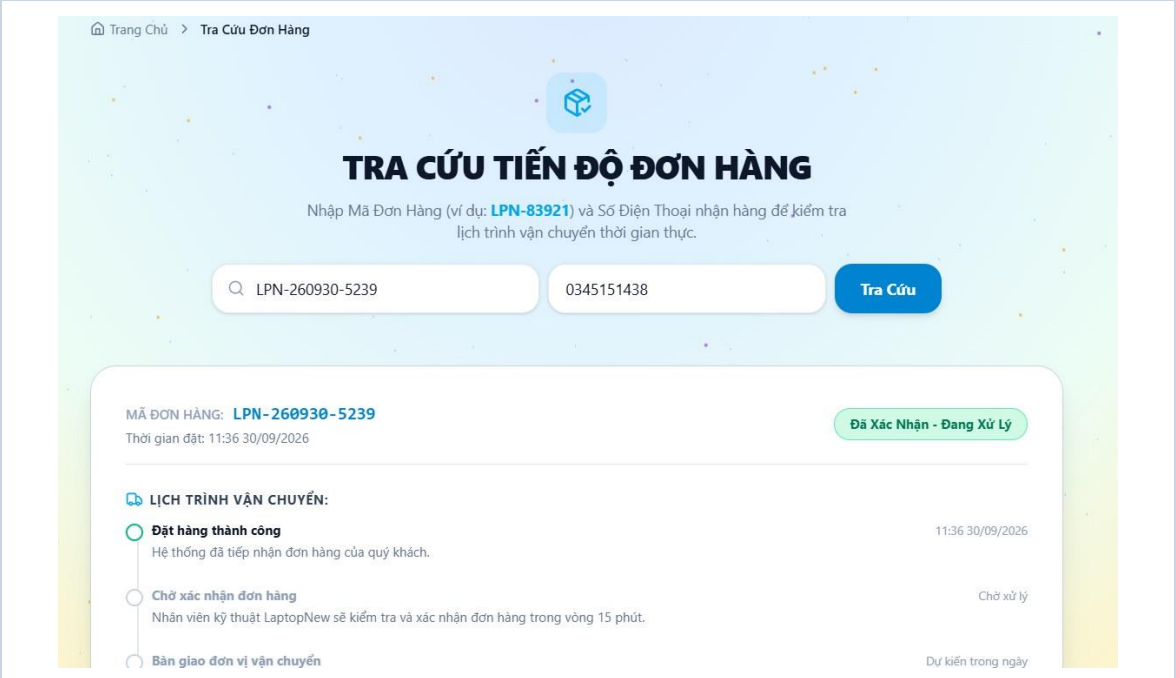

**Hình 3.14. Email xác nhận đơn hàng gửi tới khách (hóa đơn HTML)**

### 3.4.3. Tra cứu tiến độ đơn hàng

Khách tra cứu đơn bằng mã đơn và số điện thoại nhận hàng, không cần đăng nhập. Hệ thống chỉ trả lời khi **cả hai thông tin đều đúng**, và che bớt tên, số điện thoại, email, địa chỉ chi tiết. Bảng 3.2 liệt kê các trạng thái đơn.

**Bảng 3.2. Các trạng thái của đơn hàng**

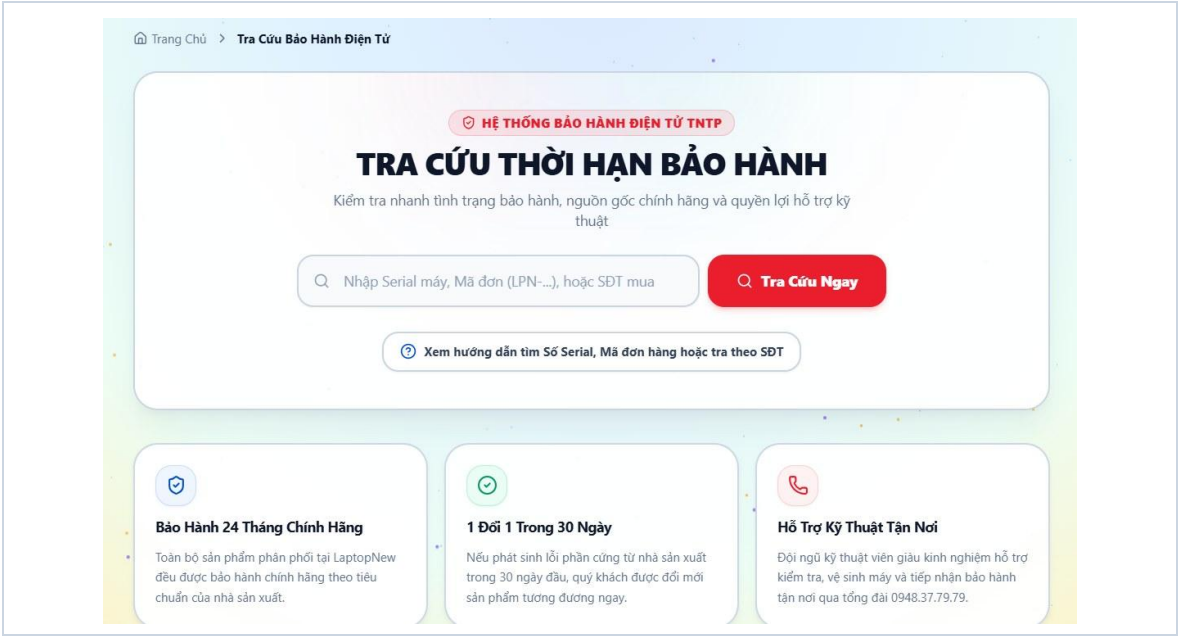
| Trạng thái | Ý nghĩa | Ai chuyển |
|---|---|---|
| cho_xac_nhan | Vừa đặt, chờ cửa hàng duyệt (đã giữ hàng) | Hệ thống |
| da_xac_nhan | Cửa hàng đã duyệt, chuẩn bị hàng | Admin hoặc khi PayOS báo đã thanh toán |
| dang_giao | Đã bàn giao cho đơn vị vận chuyển | Admin |
| da_giao | Giao thành công, đồng bộ trạng thái thanh toán | Admin |
| da_huy | Đã hủy, hàng được hoàn lại kho | Khách (khi chờ duyệt) hoặc Admin |



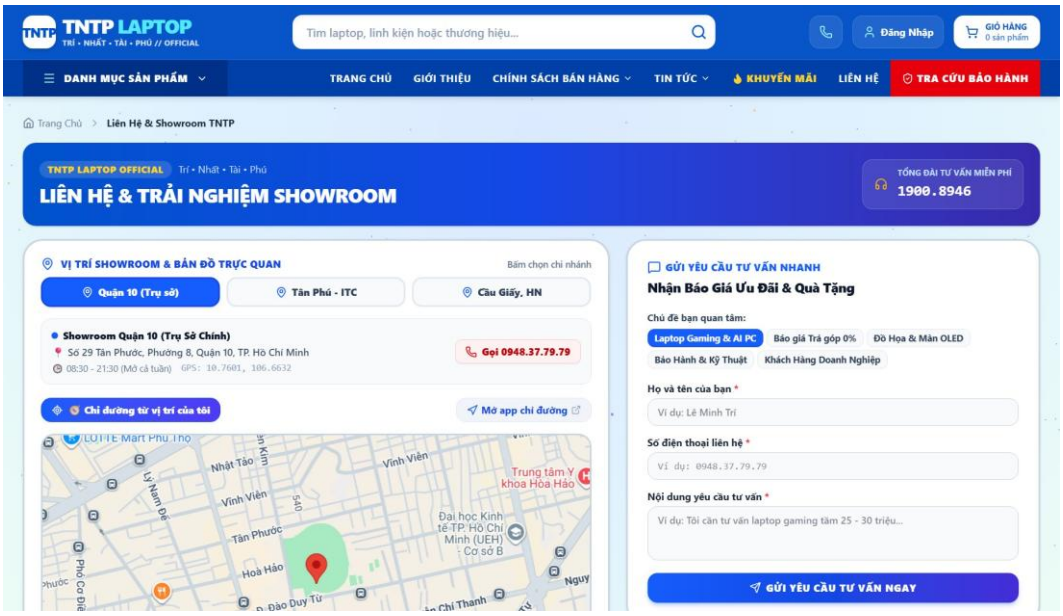

**Hình 3.15. Trang tra cứu tiến độ đơn hàng**

## 3.5. Bảo hành, liên hệ, Trợ lý AI và Telegram

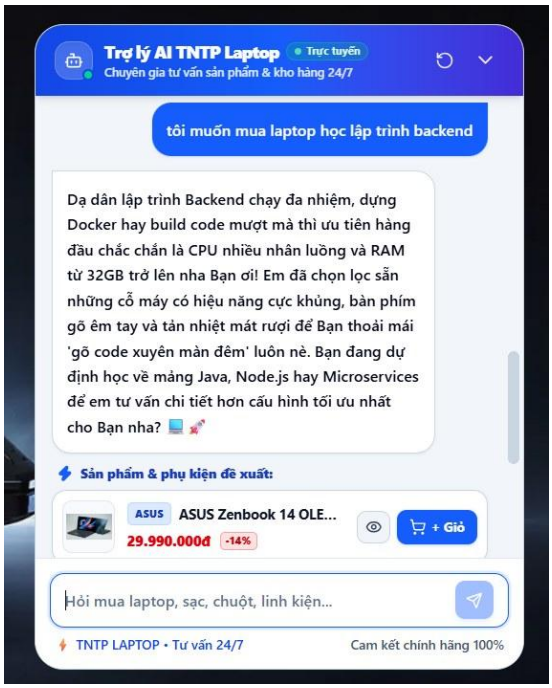
Ba chức năng chăm sóc khách: **tra cứu bảo hành** theo mã đơn hoặc serial, **liên hệ và showroom** có bản đồ chỉ đường, và **Trợ lý AI** tư vấn laptop theo nhu cầu bằng tiếng Việt, kèm thẻ sản phẩm gợi ý.




**Hình 3.16. Trang tra cứu bảo hành điện tử**




**Hình 3.17. Trang liên hệ: showroom, bản đồ và biểu mẫu tư vấn**

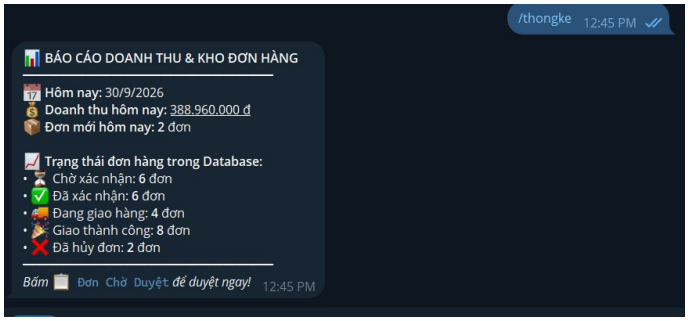



**Hình 3.18. Hộp chat Trợ lý AI trả lời câu hỏi và gợi ý sản phẩm thật**

Phía quản trị, Telegram Bot gửi tin nhắn đơn mới kèm nút bấm và trả lời lệnh thống kê doanh thu, số đơn theo trạng thái (Hình 3.19).



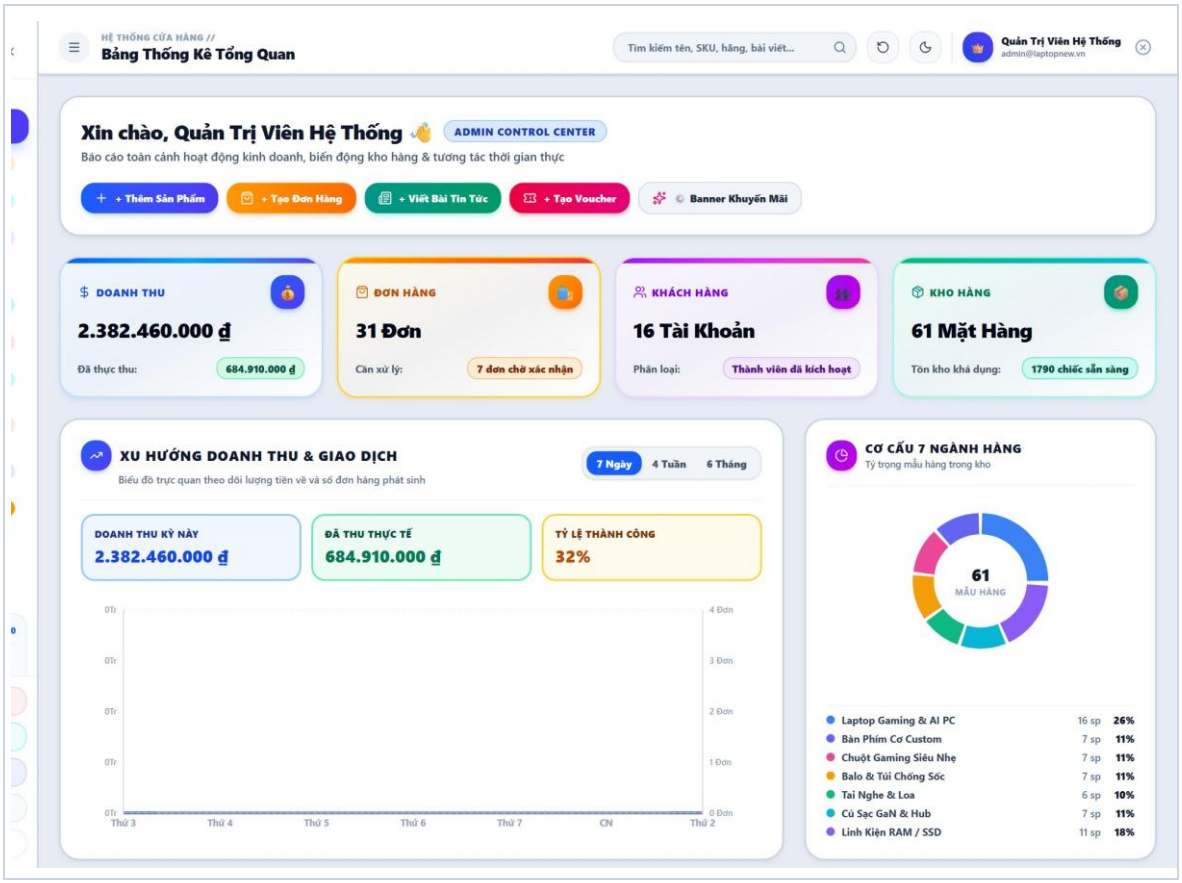

**Hình 3.19. Tin nhắn đơn mới kèm các nút duyệt**




**Hình 3.20. Kết quả lệnh /thongke**

## 3.6. Trang quản trị

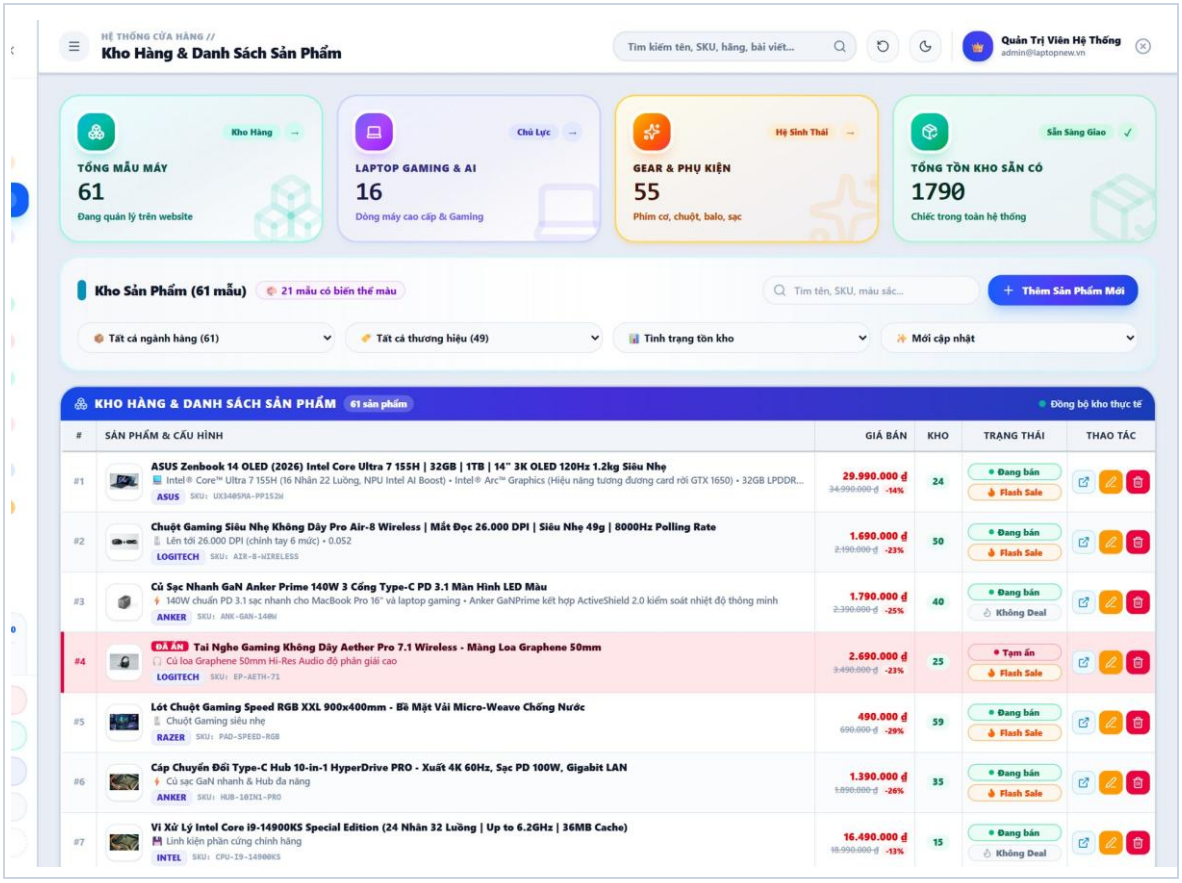
Mọi dữ liệu cửa hàng được quản lý tại `/admin`, chỉ mở được bằng tài khoản Admin. Mỗi nhóm dữ liệu đều có đủ bốn thao tác **thêm, xem, sửa, xóa** (CRUD): thêm ở nút đầu bảng, xem ở bảng có tìm kiếm và bộ lọc, sửa bằng biểu tượng cây bút, xóa bằng biểu tượng thùng rác có hộp xác nhận.



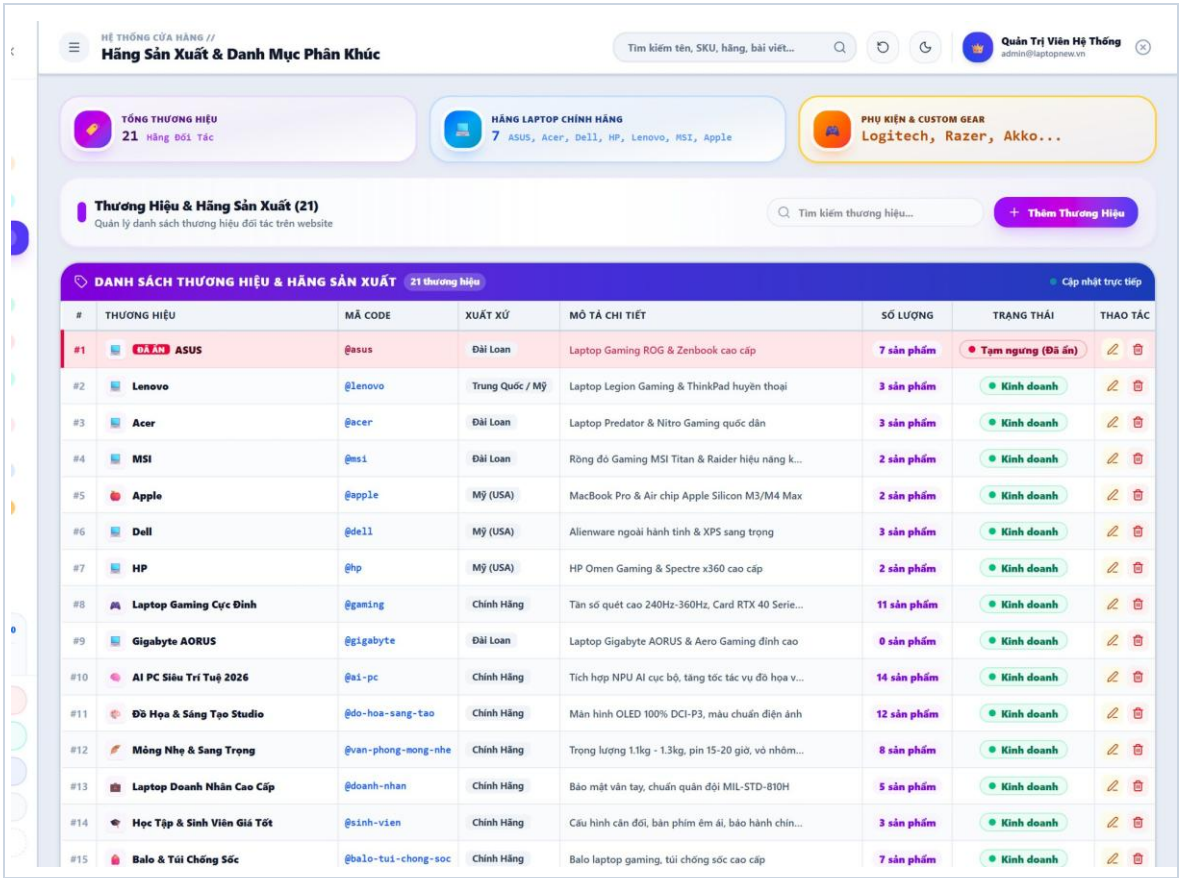

**Hình 3.21. Tổng quan: doanh thu, đơn hàng, khách hàng, kho**

### 3.6.1. Quản lý sản phẩm, thương hiệu và đơn hàng

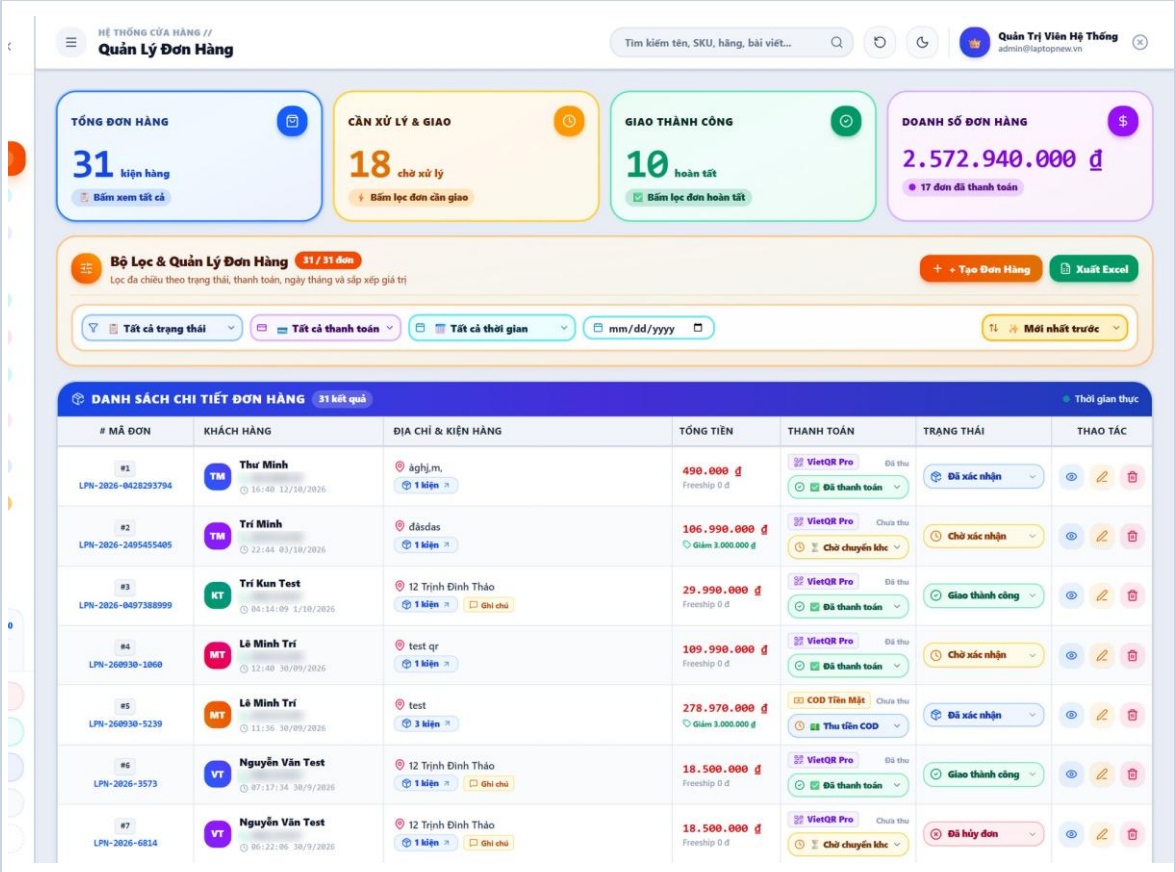
Tab **Kho Sản Phẩm** có thống kê nhanh, bộ lọc và biểu mẫu bốn bước (thông tin và giá, cấu hình, biến thể màu, ảnh). Server tự kiểm tra giá (giá niêm yết không được thấp hơn giá bán) và tự tính phần trăm giảm. Tab **Đơn Hàng** cho đổi trạng thái ngay trên từng dòng, xem chi tiết, in phiếu hóa đơn / phiếu xuất kho và xuất báo cáo Excel.



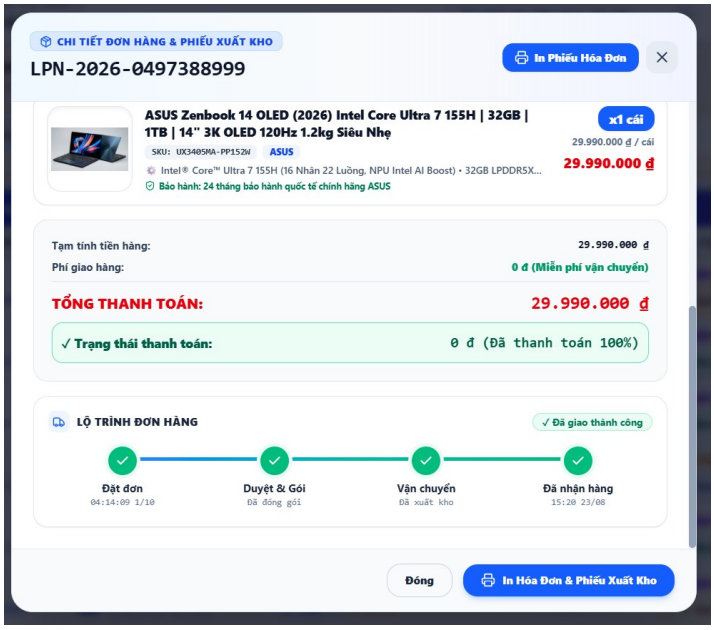

**Hình 3.22. Danh sách sản phẩm trong kho**



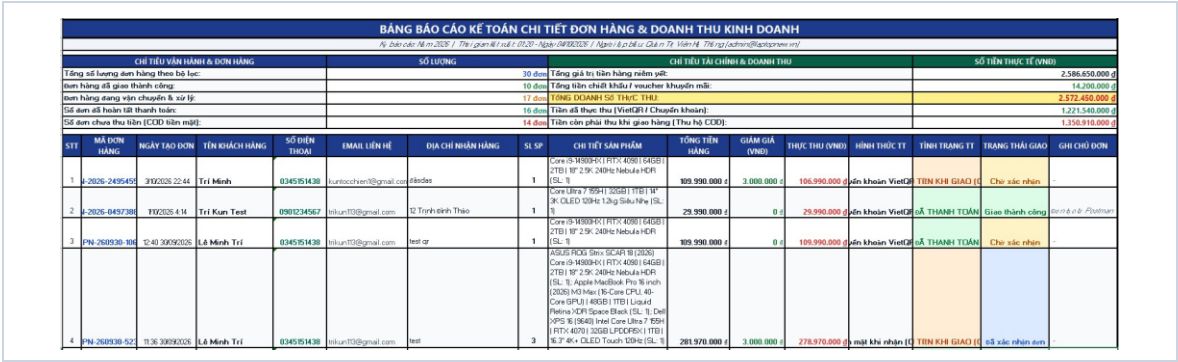

**Hình 3.23. Danh sách thương hiệu và danh mục**




**Hình 3.24. Danh sách đơn hàng, bộ lọc, nút tạo đơn và xuất Excel**




**Hình 3.25. Chi tiết đơn, lộ trình giao hàng, nút in phiếu**



BẢNG BÁO CÁO KẾ TOÁN CHI TIẾT ĐƠN HÀNG & DOANH THU KINH DOANH

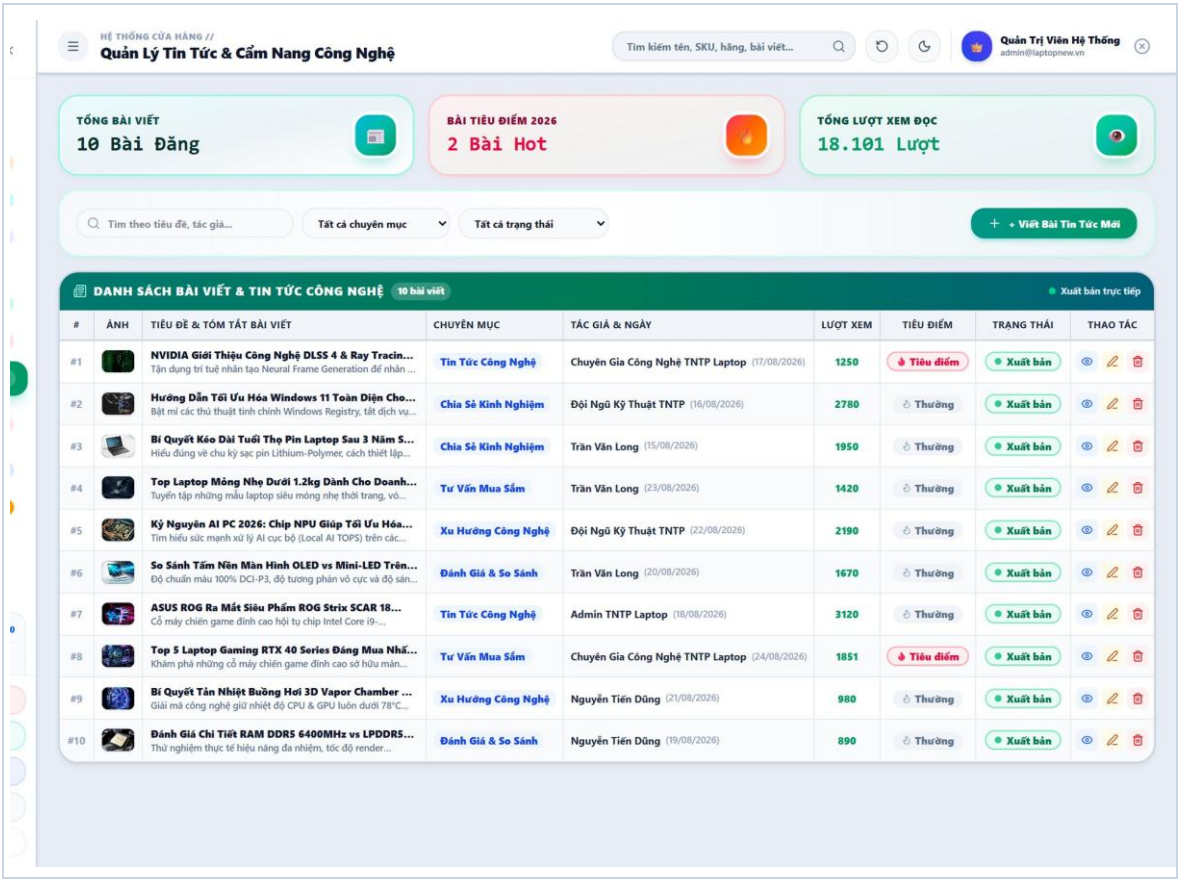
| CHỈ TIÊU VẬN HÀNH & ĐƠN HÀNG | SỐ LƯỢNG | CHỈ TIÊU TÀI CHÍNH & DOANH THU | SỐ TIỀN THỰC TẾ (VND) |
|---|---|---|---|
| Tổng số lượng đơn hàng theo bộ lọc: | 30 đơn | Tổng giá trị tiền hàng niêm yết: | 2.586.650.000 ₫ |
| Đơn hàng đã giao thành công: | 10 đơn | Tổng tiền chiết khấu / voucher khuyến mãi: | 14.200.000 ₫ |
| Đơn hàng đang vận chuyển & xử lý: | 17 đơn | TỔNG DOANH SỐ THỰC THU: | 2.572.450.000 ₫ |
| Số đơn đã hoàn tất thanh toán: | 16 đơn | Tiền đã thực thu (VietQR / Chuyển khoản): | 1.221.540.000 ₫ |
| Số đơn chưa thu tiền (COD tiền mặt): | 14 đơn | Tiền còn phải thu khi giao hàng (Thu hộ COD): | 1.350.910.000 ₫ |

| STT | MÃ ĐƠN HÀNG | NGÀY TẠO ĐƠN | TÊN KHÁCH HÀNG | SỐ ĐIỆN THOẠI | EMAIL LIÊN HỆ | ĐỊA CHỈ NHẬN HÀNG | SL SP | CHI TIẾT SẢN PHẨM | TỔNG TIỀN HÀNG | GIẢM GIÁ (VND) | THỰC THU (VND) | HÌNH THỨC TT | TÌNH TRẠNG TT | TRẠNG THÁI GIAO | GHI CHÚ ĐƠN |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| 1 | LP-2026-249545 | 30/03/2026 22:44 | Trí Minh | 0345151438 | kuntocchien1@gmail.com | đâsdas | 1 | Core i9-14900HX \| RTX 4090 \| 64GB \| 2TB \| 18" 2.5K 240Hz Nebula HDR (SL: 1) | 109.990.000 ₫ | 3.000.000 ₫ | 106.990.000 ₫ | Chuyển khoản VietQR | TIỀN KHI GIAO (C | Chờ xác nhận | |
| 2 | LP-2026-049738 | 11/02/2026 4:14 | Trí Kun Test | 0901234567 | trikun113@gmail.com | 12 Trịnh đình Thảo | 1 | Core Ultra 7 155H \| 32GB \| 1TB \| 14" 3K OLED 120Hz 1.2kg Siêu Nhẹ (SL: 1) | 29.990.000 ₫ | 0 ₫ | 29.990.000 ₫ | Chuyển khoản VietQR | ĐÃ THANH TOÁN | Giao thành công | Bình thường - Postman |
| 3 | LP-260330-106 | 12:40 30/03/2026 | Lê Minh Trí | 0345151438 | trikun113@gmail.com | test qr | 1 | Core i9-14900HX \| RTX 4090 \| 64GB \| 2TB \| 18" 2.5K 240Hz Nebula HDR (SL: 1) | 109.990.000 ₫ | 0 ₫ | 109.990.000 ₫ | Chuyển khoản VietQR | ĐÃ THANH TOÁN | Chờ xác nhận | |
| 4 | LP-260330-523 | 11:36 30/03/2026 | Lê Minh Trí | 0345151438 | trikun113@gmail.com | test | 3 | ASUS ROG Strix SCAR 18 (2026) Core i9-14900HX \| RTX 4090 \| 64GB \| 2TB \| 18" 2.5K 240Hz Nebula HDR (SL: 1); Apple MacBook Pro 16 inch (2026) M3 Max (16-Core CPU, 40-Core GPU) \| 48GB \| 1TB \| Liquid Retina XDR Space Black (SL: 1); Dell XPS 16 (9640) Intel Core Ultra 7 155H \| RTX 4070 \| 32GB LPDDR5X \| 1TB \| 16.3" 4K+ OLED Touch 120Hz (SL: 1) | 281.970.000 ₫ | 3.000.000 ₫ | 278.970.000 ₫ | Tiền mặt khi nhận (C | TIỀN KHI GIAO (C | Đã xác nhận đơn | |

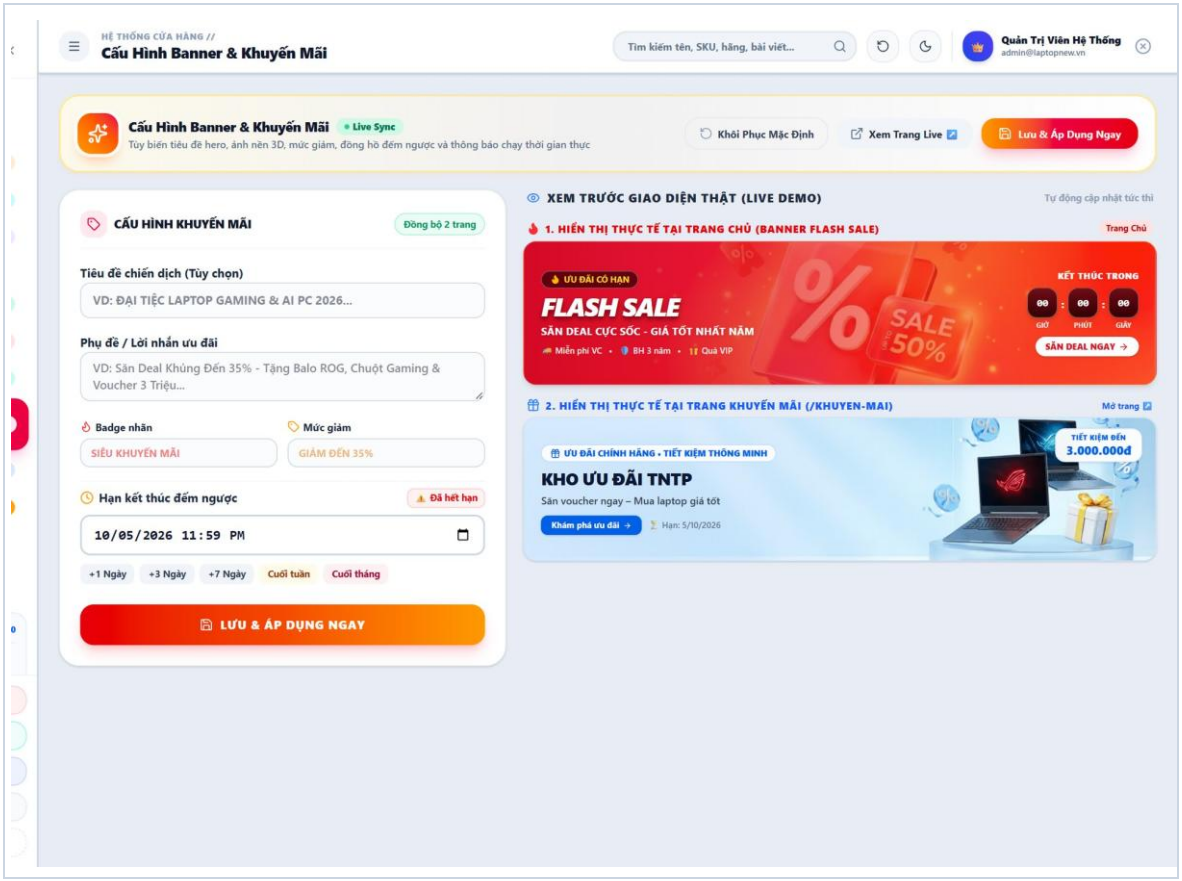
**Hình 3.26. Tệp Excel báo cáo kế toán do chức năng Xuất Excel tạo ra**

### 3.6.2. Tin tức, banner khuyến mãi và showroom

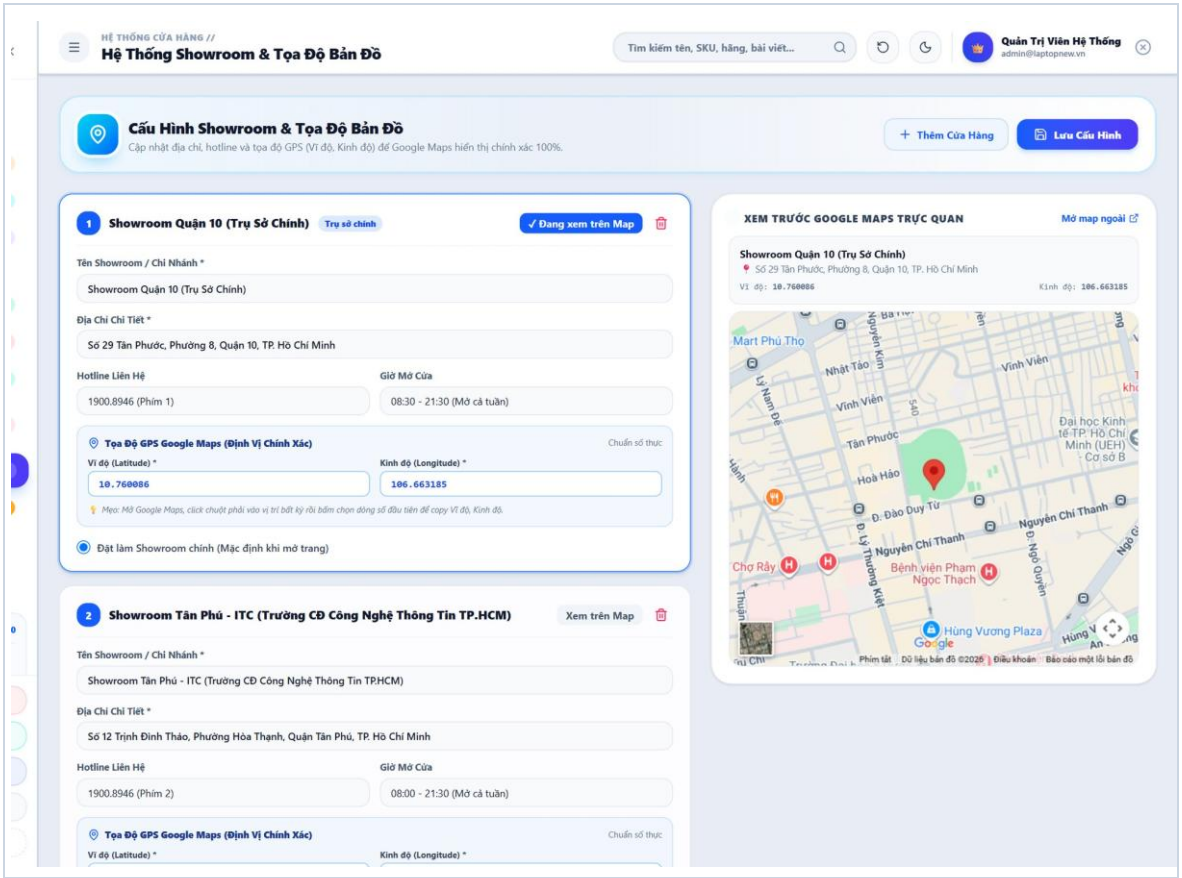
Admin viết bài tin tức (tải ảnh bìa từ máy), cấu hình banner Flash Sale kèm **bản xem trước giao diện thật**, và quản lý showroom với tọa độ GPS để bản đồ hiển thị đúng vị trí. Khi bấm lưu, thay đổi được ghi vào MongoDB và khách thấy sau vài giây.




**Hình 3.27. Danh sách bài viết tin tức**



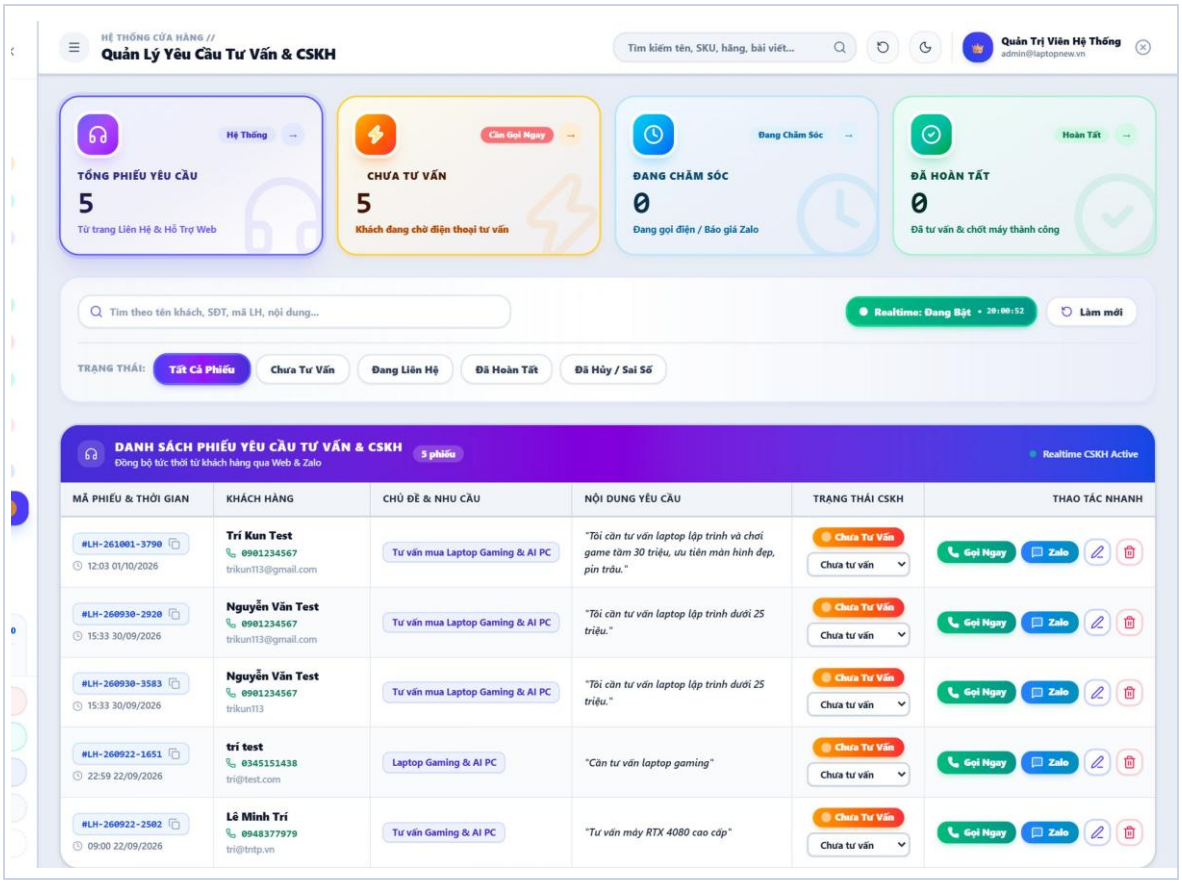

**Hình 3.28. Cấu hình banner và khuyến mãi, có xem trước**



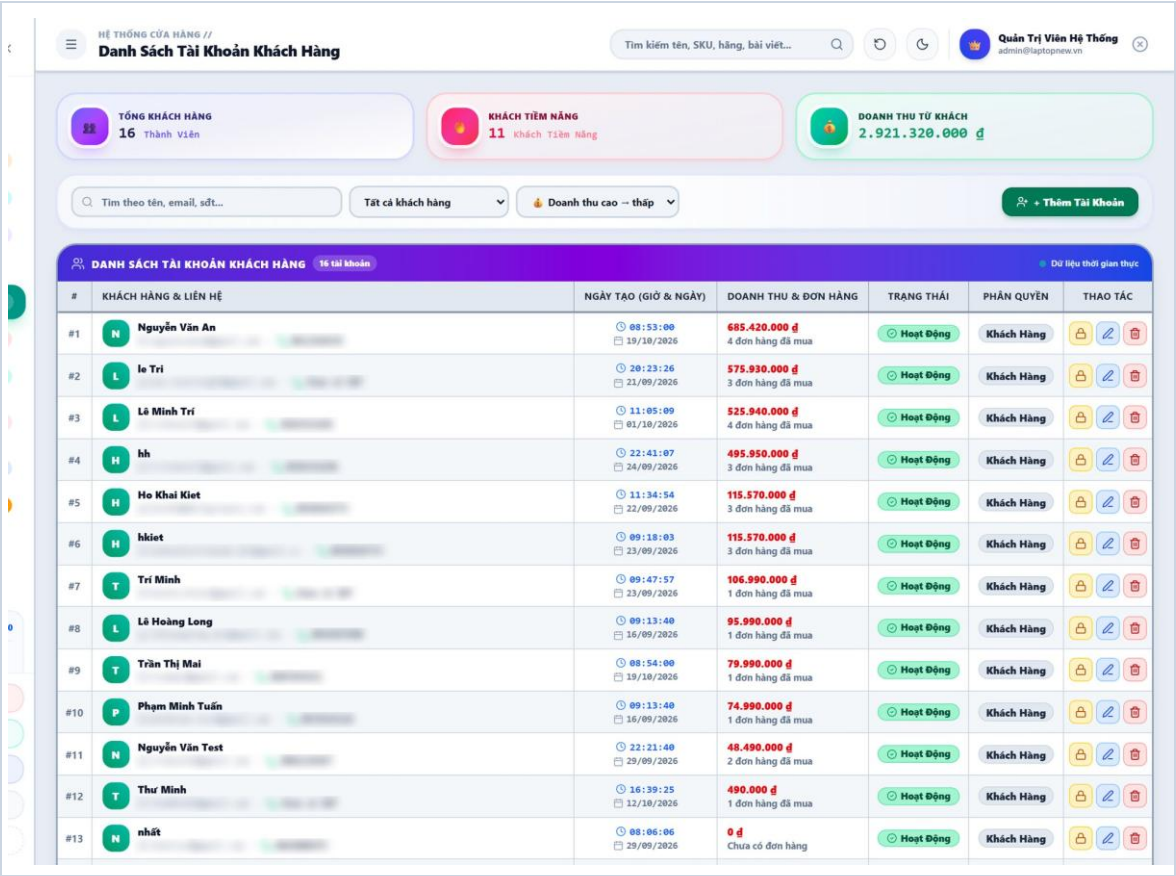

**Hình 3.29. Cấu hình showroom, tọa độ GPS và bản đồ**

### 3.6.3. Phiếu tư vấn, khách hàng và mã giảm giá

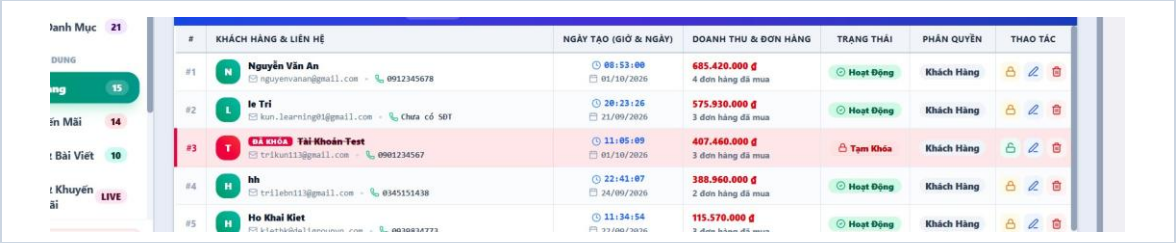
Tab **Yêu Cầu Tư Vấn** nhận phiếu khách gửi từ trang Liên hệ; Admin đổi trạng thái, gọi hoặc nhắn Zalo cho khách. Tab **Khách Hàng** có khóa / mở khóa, sửa và xóa tài khoản; khóa tài khoản làm phiên đăng nhập cũ hết hiệu lực ngay (Hình 3.30). Tab **Mã Khuyến Mãi** bật / tắt nhanh từng voucher, theo dõi số lượt đã dùng.



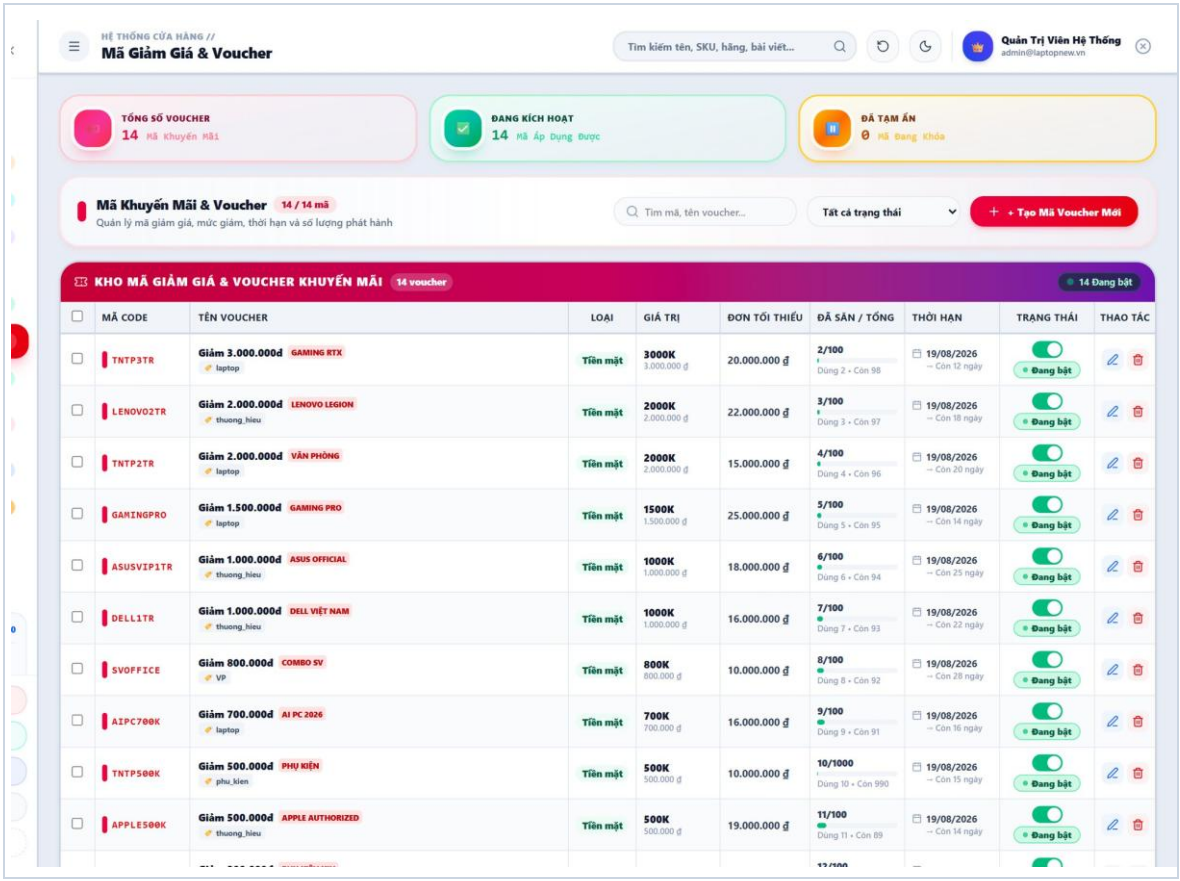

**Hình 3.30. Danh sách phiếu yêu cầu tư vấn**




**Hình 3.31. Danh sách tài khoản khách hàng**




**Hình 3.32. Tài khoản đang bị khóa hiện nhãn "Tạm khóa" màu đỏ**




**Hình 3.33. Kho mã giảm giá và voucher**

## 3.7. Giao diện tự đồng bộ khi Admin thay đổi

Trong lúc kiểm thử trên máy chủ thật, nhóm phát hiện Admin sửa dữ liệu nhưng khách không thấy ngay. Nhóm bổ sung một API rất nhẹ `/api/dong-bo` trả "chữ ký" của từng bảng. Trình duyệt của khách hỏi chữ ký mỗi 5 giây (chỉ khi đang xem trang) và chỉ tải lại đúng bảng có thay đổi, nên giao diện **tự cập nhật ngầm, không cần F5** (Hình 3.34).



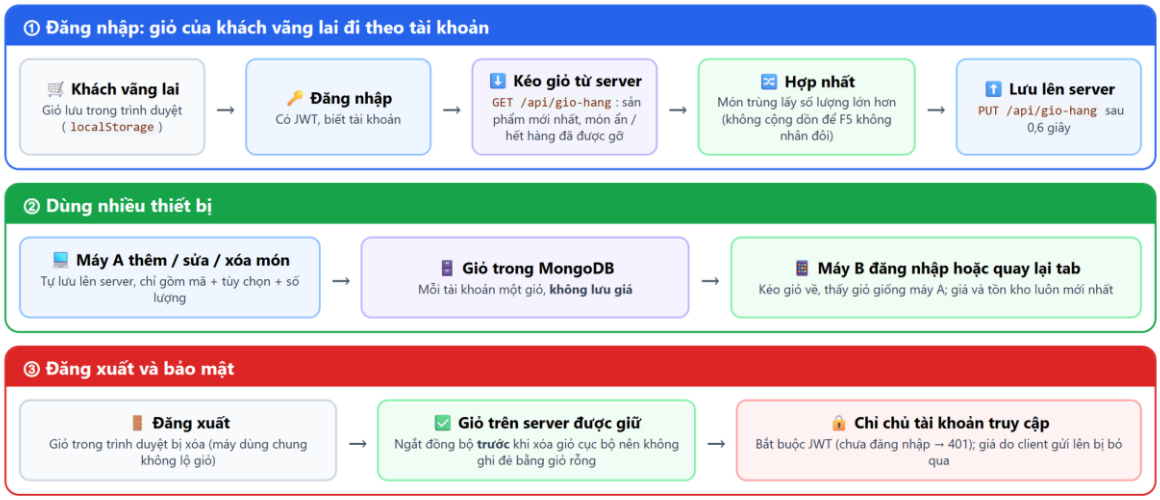

**Hình 3.34. Cơ chế tự đồng bộ: Admin thay đổi → chữ ký phiên bản → trình duyệt khách tải lại đúng phần**

**Bảng 3.3. Kết quả của cơ chế đồng bộ và giỏ hàng theo tài khoản**

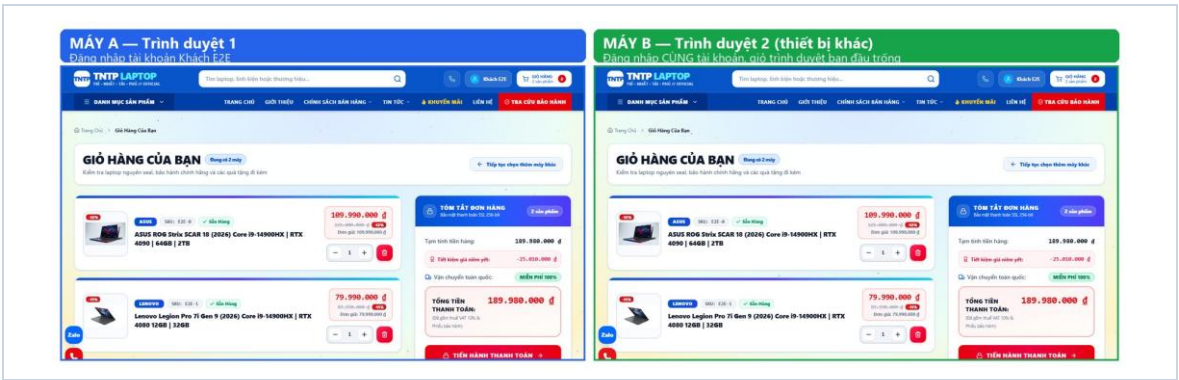
| Tình huống | Hệ thống xử lý |
|---|---|
| Admin ẩn sản phẩm hoặc sản phẩm hết hàng | Khách không còn thấy; trang chi tiết trả 404; Admin vẫn thấy để nhập hàng |
| Admin đổi giá | Giỏ của khách tự cập nhật và hiện thông báo "giá cũ → giá mới" |
| Admin đổi banner / khuyến mãi | Lưu trong MongoDB nên mọi khách đều thấy sau vài giây |
| Khách đăng nhập trên máy khác | Giỏ hàng đi theo tài khoản; server chỉ lưu mã và số lượng, giá luôn lấy lại từ database |
| Giỏ chứa món đã hết hàng | Tự gỡ món đó và hạ số lượng về đúng tồn kho |



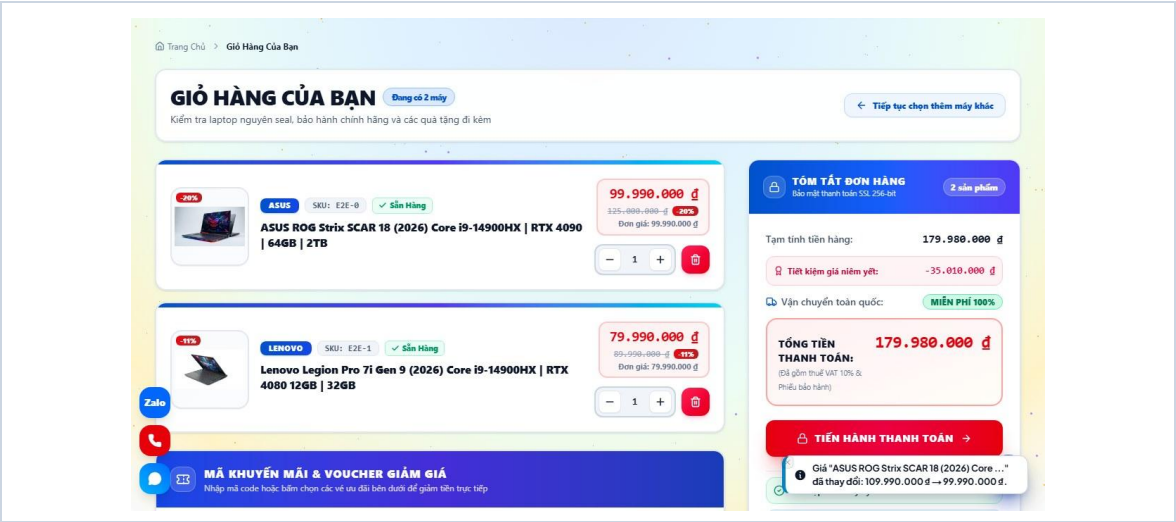

**Hình 3.35. Luồng xử lý sản phẩm ẩn, hết hàng và đổi giá**




**Hình 3.36. Luồng giỏ hàng theo tài khoản: hợp nhất khi đăng nhập, dùng nhiều thiết bị**




**Hình 3.37. Cùng một tài khoản hiển thị cùng giỏ hàng trên hai trình duyệt**




**Hình 3.38. Thông báo giá thay đổi "cũ → mới" trong giỏ**

## 3.8. Kết quả đạt được

**Bảng 3.4. Tổng hợp kết quả các chức năng chính**

| Chức năng | Kết quả |
|---|---|
| Đăng ký, đăng nhập, Google, quên mật khẩu | Hoàn thành, OTP an toàn, có khóa chống đoán mật khẩu |
| Sản phẩm: tìm, lọc, so sánh, yêu thích | Hoàn thành, 61 sản phẩm thật |
| Giỏ hàng và mã giảm giá | Hoàn thành, giỏ đi theo tài khoản, 14 voucher |
| Đặt hàng, giữ hàng, hủy đơn | Hoàn thành, chống bán lố bằng thao tác nguyên tử |
| Thanh toán QR PayOS / VietQR | Hoàn thành, tự xác nhận bằng Webhook có chữ ký |
| Tra cứu đơn, bảo hành, liên hệ | Hoàn thành, dữ liệu cá nhân được che |
| Trợ lý AI và Telegram Bot | Hoàn thành, có dự phòng nhiều tầng |
| Trang quản trị CRUD, Excel, in hóa đơn | Hoàn thành cho 9 nhóm dữ liệu |
| Tài liệu API Swagger | Hoàn thành, 68 thao tác gọi thử được |
| Chạy thật trên Internet | Hoàn thành tại trikun.site và api.trikun.site |

# CHƯƠNG 4. XỬ LÝ LỖI, BẢO MẬT VÀ KIỂM THỬ

Một hệ thống bán hàng thật phải làm tốt ba việc: **báo lỗi rõ ràng** khi có sự cố, **không để kẻ xấu lợi dụng**, và **chứng minh được** mình chạy đúng. Chương này trình bày cả ba.

## 4.1. Xử lý lỗi trong ứng dụng

Mọi API đều trả đúng **mã trạng thái HTTP** kèm một câu thông báo tiếng Việt dễ hiểu, không lộ chi tiết kỹ thuật. Bảng 4.1 là các mã hệ thống sử dụng.

**Bảng 4.1. Các mã trạng thái HTTP được sử dụng**

| Mã | Tên | Khi nào xảy ra |
|---|---|---|
| 200, 201 | Thành công / Đã tạo | Xem, sửa, xóa thành công; đăng nhập; tạo đơn, sản phẩm, voucher |
| 400 | Yêu cầu sai | Thiếu thông tin, sai định dạng, mật khẩu yếu, OTP sai hoặc hết hạn, chữ ký Webhook sai, JSON hỏng |
| 401 | Chưa xác thực | Thiếu / sai / hết hạn token; token đã bị thu hồi; sai email hoặc mật khẩu |
| 403 | Không đủ quyền | Không phải Admin, tài khoản bị khóa, xem hoặc sửa đơn của người khác, website lạ gọi API |
| 404 | Không tìm thấy | Không có sản phẩm, đơn, voucher hoặc đường dẫn |
| 409 | Xung đột | Trùng mã sản phẩm, voucher hết lượt lưu, đơn đã thanh toán, đánh giá trùng |
| 413 | Dữ liệu quá lớn | Nội dung gửi lên vượt 1 MB |
| 429 | Quá nhiều yêu cầu | Vượt giới hạn tần suất hoặc nhập sai mật khẩu 5 lần |
| 500, 502 | Lỗi máy chủ / dịch vụ ngoài | Lỗi chưa lường trước; không gửi được email OTP |

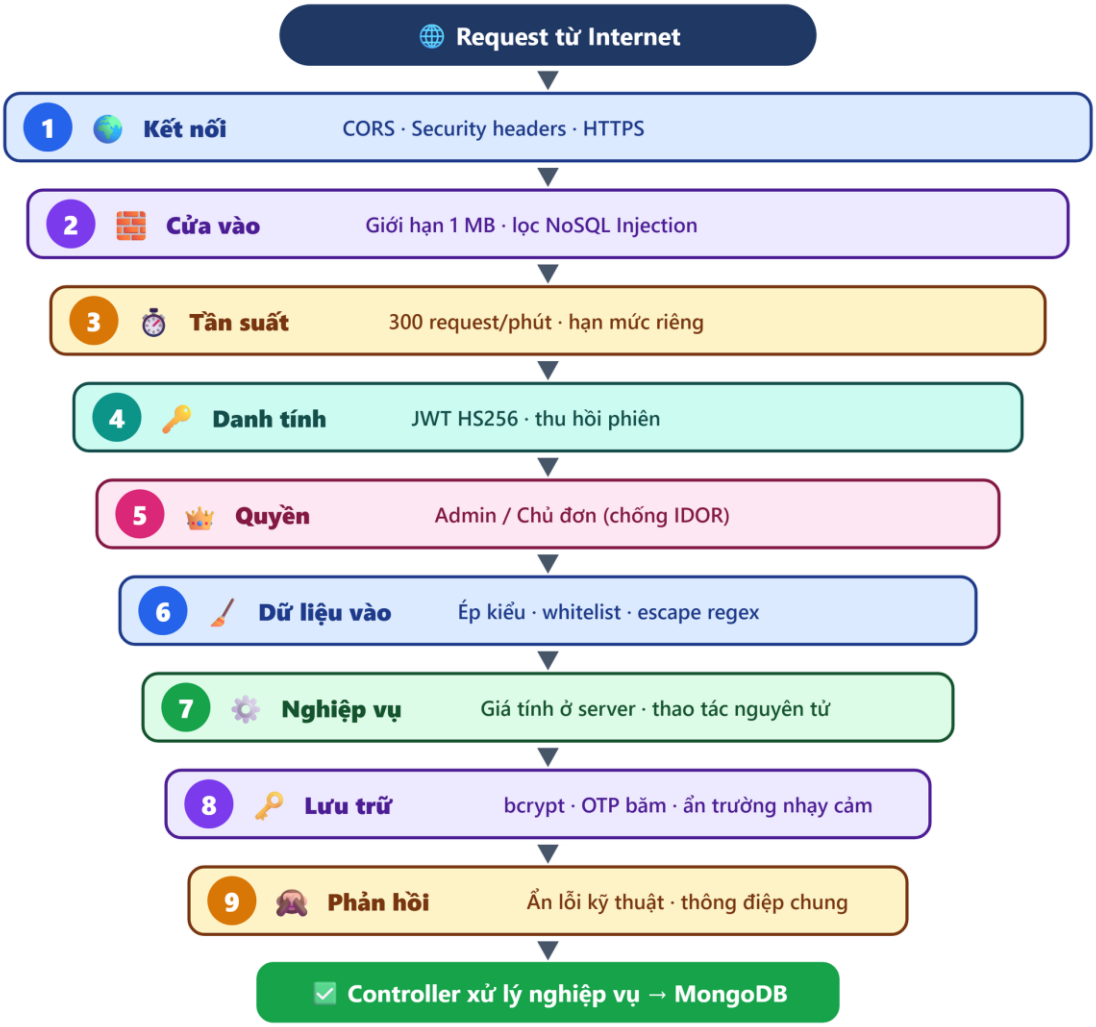
Bảng 4.2 cho thấy một số tình huống lỗi thường gặp và cách hệ thống phản ứng, để người dùng luôn biết mình cần làm gì tiếp theo.

**Bảng 4.2. Một số tình huống lỗi và cách hệ thống phản ứng**

| Tình huống | Hệ thống phản ứng | Mã |
|---|---|---|
| Đăng nhập sai email hoặc mật khẩu | Báo chung một câu, không cho biết ô nào sai | 401 |
| Nhập sai mật khẩu 5 lần | Khóa đăng nhập 15 phút, kể cả khi đổi địa chỉ IP | 429 |
| Nhập sai OTP | Báo còn mấy lần thử; sai 5 lần thì hủy mã | 400 |
| Token hết hạn hoặc bị thu hồi | Yêu cầu đăng nhập lại | 401 |
| Khách gọi API dành cho Admin | Từ chối kèm giải thích | 403 |
| Đặt món đã hết hàng | Báo rõ món nào không đủ, không tạo đơn | 400 |
| Dịch vụ email hoặc AI gặp sự cố | Báo lỗi nhẹ nhàng, hoặc chuyển sang nhà cung cấp dự phòng | 502 / 200 |
| Có lỗi bất ngờ | Trả câu chung; chi tiết kỹ thuật chỉ ghi vào nhật ký, không gửi cho khách | 500 |

## 4.2. Bảo mật hệ thống

Nguyên tắc của nhóm là **không tin bất kỳ dữ liệu nào từ phía người dùng** và **không dựa vào một lớp bảo vệ duy nhất**. Mỗi yêu cầu đi qua nhiều lớp; nếu một lớp bị vượt qua, lớp sau vẫn chặn được (Hình 4.1).




**Hình 4.1. Mô hình bảo mật nhiều lớp: một yêu cầu phải qua 9 lớp kiểm tra**

### 4.2.1. Đối chiếu với OWASP API Security Top 10

**OWASP API Security Top 10** là danh sách mười rủi ro bảo mật API phổ biến nhất do tổ chức OWASP công bố. Nhóm lấy danh sách này làm "đề thi" để tự kiểm tra hệ thống (Bảng 4.3).

**Bảng 4.3. Đối chiếu hệ thống với OWASP API Security Top 10 (2023)**

| Mã | Rủi ro | Hệ thống phòng ngừa thế nào |
|---|---|---|
| API1 | Xem / sửa dữ liệu của người khác | Chủ đơn xác định theo tài khoản; tra cứu công khai cần mã đơn + SĐT và che thông tin |

| Mã | Rủi ro | Hệ thống phòng ngừa thế nào |
|---|---|---|
| API2 | Xác thực yếu | bcrypt, JWT có thu hồi, khóa đăng nhập, OTP băm và giới hạn lần nhập, Google được xác minh |
| API3 | Lộ hoặc sửa trường không được phép | Chỉ nhận danh sách trường cho phép; không trả mật khẩu, OTP, tokenVersion |
| API4 | Dùng tài nguyên không giới hạn | Rate limit toàn cục và riêng, giới hạn 1 MB, giới hạn số bản ghi, chống ReDoS |
| API5 | Gọi chức năng không có quyền | Mọi API quản trị đều qua xác thực rồi phân quyền Admin |
| API6 | Lạm dụng luồng nghiệp vụ | Săn voucher nguyên tử; hạn mức tạo thanh toán, đánh giá, liên hệ; chỉ người đã mua được đánh giá |
| API7 | Giả mạo yêu cầu phía server (SSRF) | Server chỉ gọi các địa chỉ cố định; không tải URL do người dùng nhập |
| API8 | Cấu hình sai | Security headers, ẩn công nghệ, CORS cho tên miền đã khai báo, bắt buộc JWT_SECRET, ẩn lỗi chi tiết |
| API9 | Quản lý danh mục API kém | 82 route được thống kê đầy đủ, có tài liệu Swagger; API ngừng dùng trả 410 |
| API10 | Tin dịch vụ ngoài quá mức | Webhook có chữ ký, kiểm số tiền, xử lý một lần; token Google được xác minh với Google |

### 4.2.2. Rà soát và vá 21 lỗ hổng

Sau khi xong chức năng, nhóm đóng vai kẻ tấn công để tìm điểm yếu. Kết quả là **21 lỗ hổng**, toàn bộ đã được vá và kiểm chứng. Bảng 4.4 mô tả dễ hiểu từng lỗ hổng.

**Bảng 4.4. 21 lỗ hổng đã phát hiện và cách khắc phục**

| # | Lỗ hổng | Kẻ xấu làm được gì nếu chưa vá | Đã khắc phục bằng |
|---|---|---|---|
| **Mức nghiêm trọng** | | | |
| 1 | Đăng nhập Google giả | Gửi email bất kỳ để vào tài khoản người khác | Chỉ tin dữ liệu do Google xác nhận (kiểm tra chữ ký, ứng dụng, email đã xác minh) |
| 2 | API quản trị người dùng công khai | Tự tạo tài khoản admin | Bắt buộc đăng nhập + quyền Admin; chỉ nhận trường cho phép |
| 3 | Mật khẩu tài khoản Google đoán được | Đăng nhập bằng mật khẩu mặc định | Mật khẩu ngẫu nhiên 32 byte |
| **Mức cao** | | | |
| 4 | Lộ mã OTP qua API | Đọc OTP trong hồ sơ để chiếm tài khoản | Ẩn mọi trường nhạy cảm; OTP chỉ lưu dạng băm |
| 5 | NoSQL Injection | Đăng nhập mà không cần biết mật khẩu | Lọc ký tự nguy hiểm toàn cục và ép kiểu chữ |
| 6 | Xem trộm đơn hàng (IDOR) | Đổi số điện thoại hồ sơ để xem đơn người khác | Chủ đơn chỉ xác định theo tài khoản |
| 7 | Tự xác nhận đã thanh toán | Nhận hàng mà không trả tiền | Khách chỉ được hủy đơn; thanh toán do Webhook hoặc Admin |

| # | Lỗ hổng | Kẻ xấu làm được gì nếu chưa vá | Đã khắc phục bằng |
|---|---|---|---|
| 8 | Sửa giá đơn hàng | Mua laptop 30 triệu với giá 1.000đ | Server tính lại giá, voucher, tổng tiền từ database |
| 9 | Tin tức, liên hệ, showroom không cần đăng nhập | Sửa bài viết, đọc dữ liệu khách | Bắt buộc quyền Admin cho thao tác ghi và xem |
| **Mức trung bình** | | | |
| 10 | Dò OTP | Thử đủ 1.000.000 mã | Sai 5 lần thì hủy mã; sinh OTP bằng bộ sinh ngẫu nhiên an toàn |
| 11 | OTP dùng sai mục đích | Dùng OTP đổi mật khẩu để đặt lại mật khẩu | Kiểm tra đúng loại OTP |
| 12 | Đoán mật khẩu | Thử hàng nghìn mật khẩu | Khóa 15 phút sau 5 lần sai, lưu trong database |
| 13 | Token còn dùng sau đăng xuất | Dùng token bị lộ tới 7 ngày | Thu hồi phiên phía server (tokenVersion) |
| 14 | ReDoS | Ô tìm kiếm độc hại làm treo server | Escape ký tự đặc biệt trước khi tìm |
| 15 | Tự nâng quyền qua hồ sơ | Gửi thêm vaiTro = admin khi sửa hồ sơ | Chỉ nhận danh sách trường cho phép |
| 16 | Bán lố kho, phát vượt voucher | Hai yêu cầu cùng lúc cùng thành công | Thao tác nguyên tử có điều kiện |
| 17 | Chèn HTML vào email | Họ tên chứa liên kết lừa đảo | Mã hóa ký tự đặc biệt trong mẫu email |
| **Mức thấp** | | | |
| 18 | Thiếu security headers, lộ lỗi | Biết công nghệ, nhận thông báo lỗi chi tiết | Thêm headers, ẩn lỗi kỹ thuật |
| 19 | Bản nháp tin tức xem được | Đọc bài chưa xuất bản | Chỉ Admin xem bản nháp |
| 20 | Cấu hình JWT chưa chặt | Khóa mặc định, thuật toán không ghim | Bắt buộc biến môi trường, chỉ chấp nhận HS256 |
| 21 | Dò email đã đăng ký | Biết email nào có tài khoản | Luôn trả cùng một câu và thời gian đồng đều |

### 4.2.3. Giới hạn tần suất (Rate Limiting)

Mỗi người chỉ được gọi một số lần nhất định trong một khoảng thời gian; vượt quá sẽ nhận lỗi 429 kèm thời gian phải chờ. Bộ đếm tính theo địa chỉ IP, nên đổi đường dẫn cũng không lách được. Riêng đăng nhập còn có bộ đếm theo **tài khoản** lưu trong database (Bảng 4.5).

**Bảng 4.5. Hạn mức giới hạn tần suất đang áp dụng**

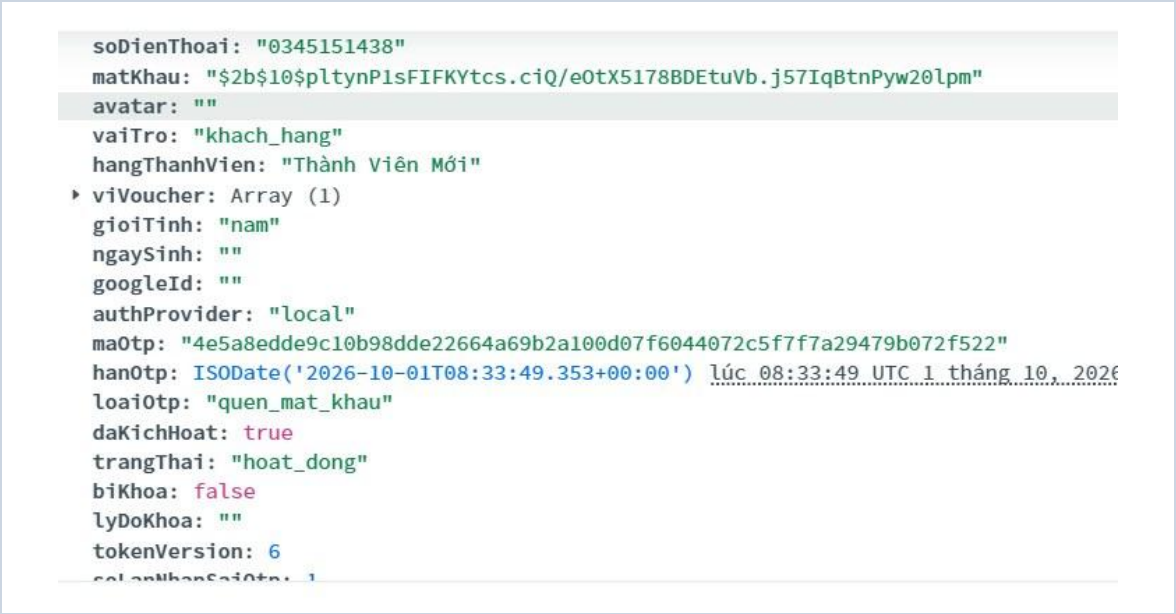
| API | Hạn mức mỗi IP | Mục đích |
|---|---|---|
| Mọi API /api/* | 300 lần / phút | Chống spam, quá tải |
| Đăng ký, đăng nhập, Google, xác nhận OTP | 30 lần / 15 phút | Chống đoán mật khẩu và OTP |

| API | Hạn mức mỗi IP | Mục đích |
|---|---|---|
| Quên mật khẩu, gửi lại OTP | 6 lần / 15 phút | Chống spam email |
| Tra cứu đơn công khai | 30 lần / 10 phút | Chống dò mã đơn |
| Tra cứu bảo hành | 30 lần / 15 phút | Chống dò dữ liệu khách |
| Tạo thanh toán / kiểm tra thanh toán | 20 lần / 15 phút · 60 lần / phút | Bảo vệ cổng PayOS |
| Kiểm tra voucher | 40 lần / 10 phút | Chống dò mã giảm giá |
| Gửi đánh giá / gửi phiếu liên hệ | 8 lần / giờ · 5 lần / giờ | Chống spam |
| Chat Trợ lý AI | 12 lần / phút | Bảo vệ hạn mức khóa AI |
| Đăng nhập theo tài khoản | 5 lần sai → khóa 15 phút | Chống đoán mật khẩu dù đổi IP |

### 4.2.4. Mật khẩu, OTP và thu hồi phiên

Ba cơ chế quan trọng nhất của xác thực được nhóm làm rất kỹ:

- **Mật khẩu:** tối thiểu 8 ký tự, có cả chữ và số; lưu bằng bcrypt nên không ai đọc ngược được, kể cả quản trị viên.
- **OTP:** sinh bằng bộ ngẫu nhiên an toàn mật mã, chỉ lưu bản băm (lộ database cũng không đọc được mã), hạn 10 phút, sai 5 lần thì hủy.
- **Thu hồi phiên:** mỗi tài khoản có số `tokenVersion`; khi đăng xuất, đổi mật khẩu, bị khóa hoặc đổi vai trò, số này tăng lên và mọi token cũ mất hiệu lực ngay lập tức.




**Hình 4.2. Trong MongoDB: matKhau là chuỗi bcrypt ($2b$10$…), maOtp là chuỗi băm 64 ký tự, không phải mã 6 số**

### 4.2.5. Thử tấn công thật

Bảo mật chỉ có giá trị khi được thử. Nhóm đóng vai kẻ tấn công, thực hiện **12 kịch bản** và ghi lại kết quả. Hình 4.3 tóm tắt các kịch bản tiêu biểu, Bảng 4.6 giải thích cách thử.




**Hình 4.3. Mười kịch bản tấn công thử và phản ứng của hệ thống**

**Bảng 4.6. Các kịch bản tấn công thử và kết quả**

| Kịch bản | Cách thử | Kết quả mong đợi | Thực tế |
|---|---|---|---|
| Xem đơn người khác | Đăng nhập tài khoản A, gọi đơn của B | 403 | Đạt |
| Tự báo đã thanh toán | Gửi da_thanh_toan = true | 403 | Đạt |
| Tự nâng quyền admin | Gửi vaiTro = admin khi sửa hồ sơ | Bỏ qua trường lạ | Đạt |
| Lộ OTP, mật khẩu | Xem hồ sơ cá nhân | Không có maOtp, matKhau | Đạt |
| Đoán mật khẩu | Nhập sai 6 lần | Khóa 15 phút (429) | Đạt |
| Đoán OTP | Nhập sai 5 lần | Hủy mã (400) | Đạt |
| Tra cứu đơn dồn dập | Gửi 31 lần trong 10 phút | 429 từ lần 31 | Đạt |
| Khóa tài khoản | Admin khóa rồi dùng token cũ | 403 / 401 | Đạt |
| Đăng xuất rồi dùng lại token | Gọi API bằng token cũ | 401 “đã bị thu hồi” | Đạt |

| Kịch bản | Cách thử | Kết quả mong đợi | Thực tế |
|---|---|---|---|
| NoSQL Injection | Gửi {"$ne": null} vào mật khẩu | 400, không cấp token | Đạt |
| Website lạ gọi API | Giả origin lạ | 403 | Đạt |
| Thiếu security headers | Kiểm tra header phản hồi | Có đủ, không lộ Express | Đạt |

### 4.2.6. Chống bán lố và chống xử lý trùng

Hai lỗi dễ xảy ra với mọi hệ thống bán hàng là **bán lố** (cùng một món bán cho hai người) và **xử lý trùng** (cộng tiền hai lần vì Webhook gửi lại). Hệ thống tránh cả hai: tồn kho và lượt voucher được trừ bằng một lệnh duy nhất có điều kiện; Webhook PayOS kiểm tra đơn đã xử lý chưa trước khi làm gì tiếp. Số liệu tồn kho được kiểm chứng trực tiếp trong database ở mục 4.4.

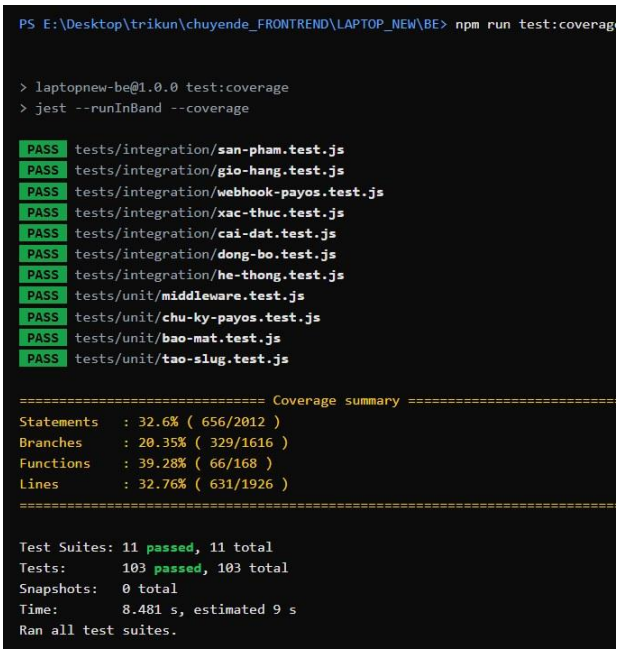
## 4.3. Kiểm thử hệ thống

### 4.3.1. Kiểm thử tự động bằng Jest

Bộ kiểm thử gồm **11 tệp, 103 ca**, chạy bằng Jest và Supertest. Các ca tích hợp dùng một MongoDB giả chạy trong bộ nhớ nên chạy được ở bất kỳ máy nào mà không đụng dữ liệu thật. Nhóm chạy lại ngày 13/10/2026: **103/103 ca đạt** trong khoảng 30 giây (Hình 4.4).

**Bảng 4.7. Các nhóm kiểm thử tự động**

| Loại | Tệp kiểm thử | Kiểm tra gì |
|---|---|---|
| Đơn vị (unit) | bao-mat, middleware, chu-ky-payos, tao-slug | OTP, mật khẩu, lọc NoSQL, giới hạn tần suất, phân quyền, chữ ký PayOS, tạo slug tiếng Việt |
| Tích hợp | xac-thuc | Đăng ký, đăng nhập, JWT, thu hồi phiên, khóa tài khoản |
| Tích hợp | san-pham | Ẩn / hết hàng, kiểm tra giá, phân quyền Admin |
| Tích hợp | gio-hang, dong-bo, cai-dat | Giỏ theo tài khoản, API đồng bộ, cấu hình khuyến mãi |
| Tích hợp | webhook-payos, he-thong | Webhook có chữ ký, CORS, lỗi 404 |




**Hình 4.4. Kết quả chạy Jest: 11 tệp, 103/103 ca đạt, kèm độ phủ mã**

### 4.3.2. Kiểm thử API bằng Postman

Ngoài Jest, toàn bộ API được gom trong một bộ Postman gồm **17 thư mục, 141 yêu cầu**; thư mục tự động có **40 ca (58 bài kiểm tra)**, lần chạy ngày 01/10/2026 đạt **58/58**. Bảng 4.8 tóm tắt kết quả.

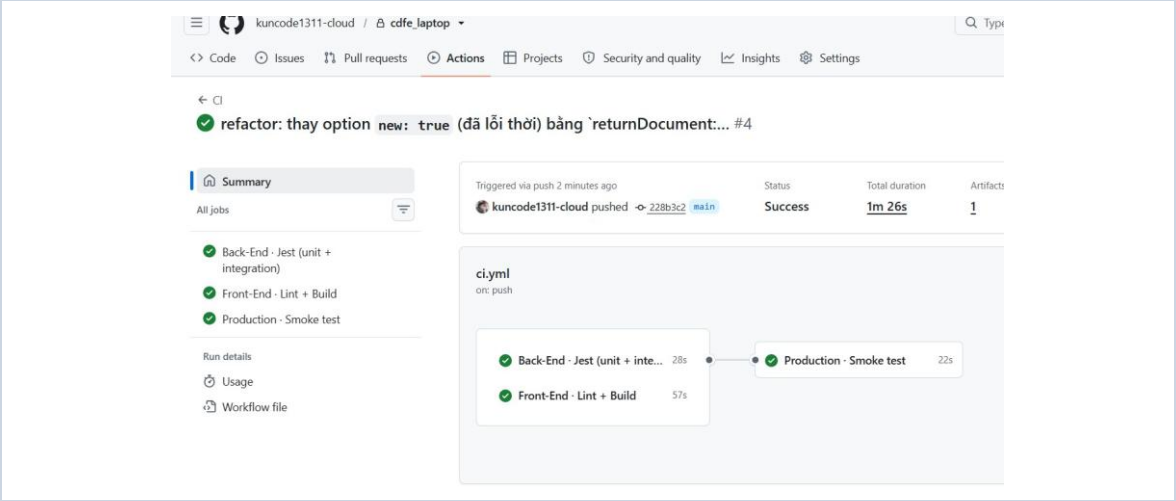
**Bảng 4.8. Tóm tắt kết quả kiểm thử Postman**

| Nhóm kiểm thử | Số ca | Kết quả |
|---|---|---|
| Giám sát, sản phẩm, danh mục, tin tức, showroom | TC01 – TC06, TC20 – TC22 | Đạt |
| Xác thực và phân quyền (đăng nhập, đăng ký, token, Admin) | TC07 – TC12 | Đạt |
| Mã giảm giá, bảo hành, đơn hàng, liên hệ | TC13 – TC19 | Đạt |
| Thanh toán và Trợ lý AI | TC23 – TC26 | Đạt |
| Tra cứu đơn an toàn (thiếu / sai / đúng SĐT, chủ đơn) | TC27 – TC30 | Đạt |
| Tấn công thử: NoSQL, ReDoS, JSON hỏng, CORS, headers, mật khẩu yếu, quyền | TC31 – TC40 | Đạt |
| Tổng | 40 ca / 58 bài kiểm tra | 58/58 đạt |

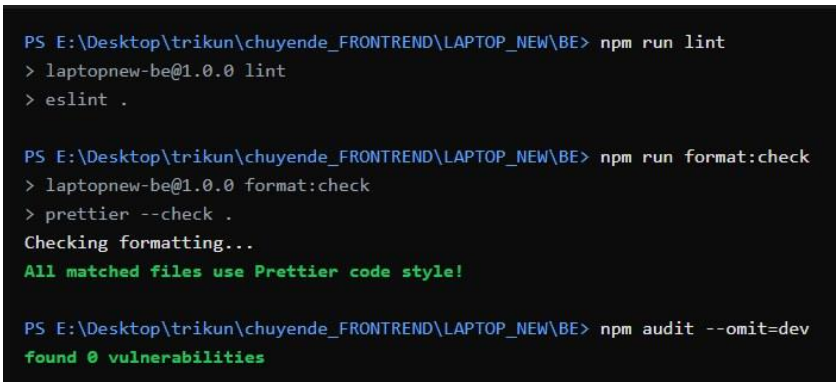
### 4.3.3. Chất lượng mã nguồn và tích hợp liên tục

Mỗi lần đẩy mã lên GitHub, hệ thống **GitHub Actions** tự chạy ba việc: kiểm thử Back-End (Jest), kiểm tra và dựng Front-End (lint + build), và kiểm tra nhanh máy chủ thật (smoke test). Kết quả hiện ngay trên từng lần cập nhật. Bên cạnh đó, ESLint soát

lỗi tiềm ẩn, Prettier thống nhất cách trình bày mã và `npm audit` kiểm tra thư viện có lỗ hổng: kết quả **0 lỗ hổng**.




**Hình 4.5. Một lần chạy CI thành công: cả 3 việc (Back-End, Front-End, kiểm tra máy chủ thật) đều đạt**




**Hình 4.6. ESLint, Prettier và npm audit: không có lỗi, không có lỗ hổng thư viện**

### 4.3.4. Kiểm thử chịu tải nhẹ

Để biết máy chủ thật có chịu được nhiều khách cùng lúc không, nhóm gửi 250 yêu cầu từ một máy tính cá nhân qua Internet, mỗi lần 10 yêu cầu chạy song song (Bảng 4.9). Mức này cố ý nằm dưới hạn mức 300 yêu cầu mỗi phút của hệ thống để không bị chặn nhầm. Kết quả: **không có yêu cầu nào lỗi**; thời gian trả lời đã gồm cả đường truyền Internet nên thực tế trên máy chủ còn nhanh hơn.

**Bảng 4.9. Kết quả kiểm thử chịu tải nhẹ trên máy chủ thật (19/10/2026)**

| Chức năng thử | Số yêu cầu | Thành công | Trung bình | Chậm nhất 5% |
|---|---|---|---|---|
| Kiểm tra máy chủ còn sống | 100 | 100 (200 OK) | 0,40 giây | 0,97 giây |
| Danh sách 12 sản phẩm đầu tiên | 150 | 150 (200 OK) | 0,61 giây | 0,96 giây |

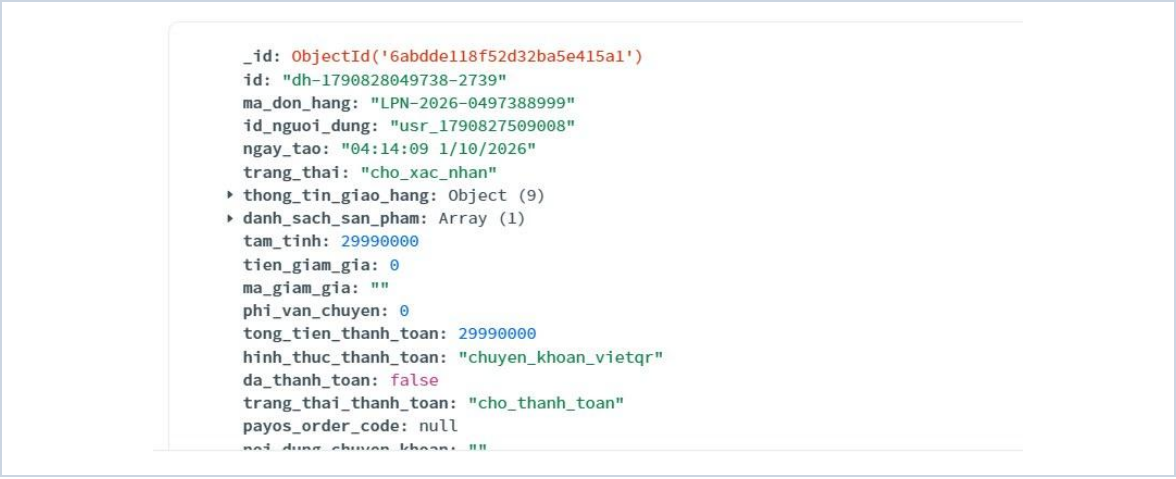
Kiểm thử chịu tải cường độ cao (hàng nghìn người cùng lúc) chưa được thực hiện, nhóm đưa vào hướng phát triển.

## 4.4. Kiểm chứng dữ liệu trong MongoDB

Nhận được phản hồi "thành công" chưa đủ; nhóm còn mở thẳng MongoDB Atlas để xem dữ liệu **có thật sự thay đổi đúng** hay không. Bảng 4.10 liệt kê các thao tác đã kiểm chứng.

**Bảng 4.10. Dữ liệu thay đổi đúng sau mỗi thao tác**

| Thao tác | Dữ liệu cần thấy trong MongoDB | Kết quả |
|---|---|---|
| Đăng ký rồi kích hoạt OTP | Bản ghi tạm có mật khẩu bcrypt và OTP băm; sau kích hoạt, tài khoản xuất hiện trong nguoi_dung | Đúng |
| Khách đặt hàng | Đơn mới ở trạng thái cho_xac_nhan, tổng tiền do server tính | Đúng |
| Giữ hàng và hoàn hàng | Tồn kho ASUS Zenbook 14 đi từ 25 → 24 khi đơn được ghi nhận và trở về 25 khi hủy; số đã bán 114 → 115 → 114 | Đúng |
| Lưu voucher vào ví | Số lượt còn lại giảm 50 → 49, phần trăm đã dùng 50 → 51 | Đúng |
| Gửi đánh giá | Đánh giá mới có nhãn đã mua hàng; điểm trung bình và số lượt đánh giá của sản phẩm được tính lại | Đúng |
| Admin khóa tài khoản | biKhoa = true và tokenVersion tăng | Đúng |
| Gửi phiếu liên hệ | Phiếu mới có mã LH-YYMMDD-XXXX, trạng thái chua_xu_ly | Đúng |




**Hình 4.7. Đơn hàng vừa tạo nằm trong collection don_hang**



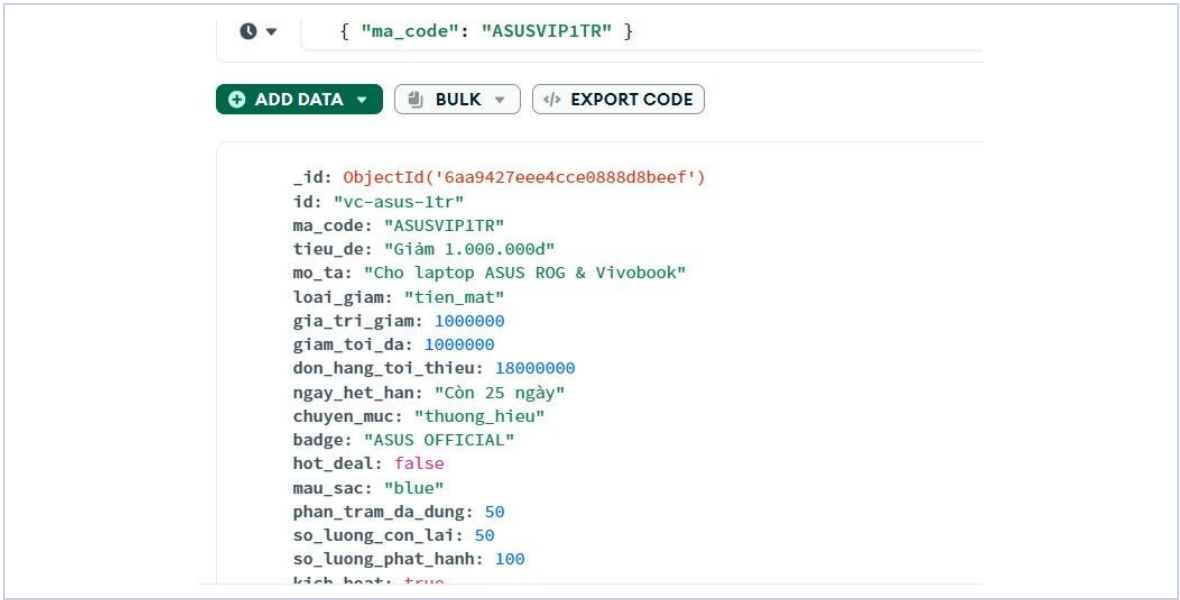

**Hình 4.8. Trước: tồn kho 25, đã bán 114**



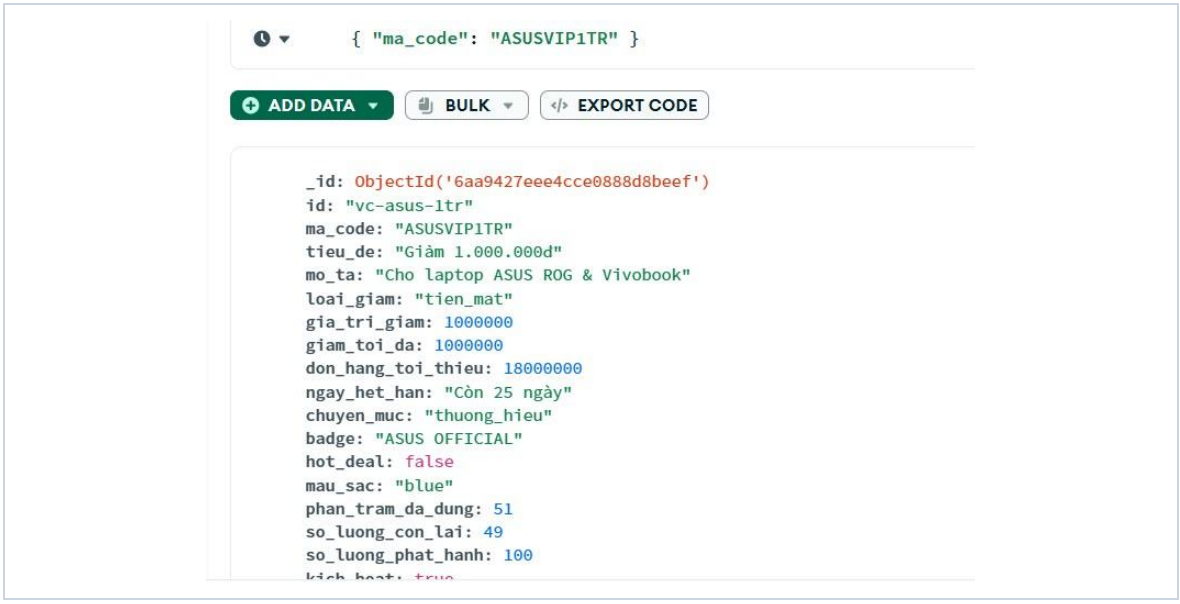

**Hình 4.9. Sau khi đơn được xử lý: tồn kho 24, đã bán 115**



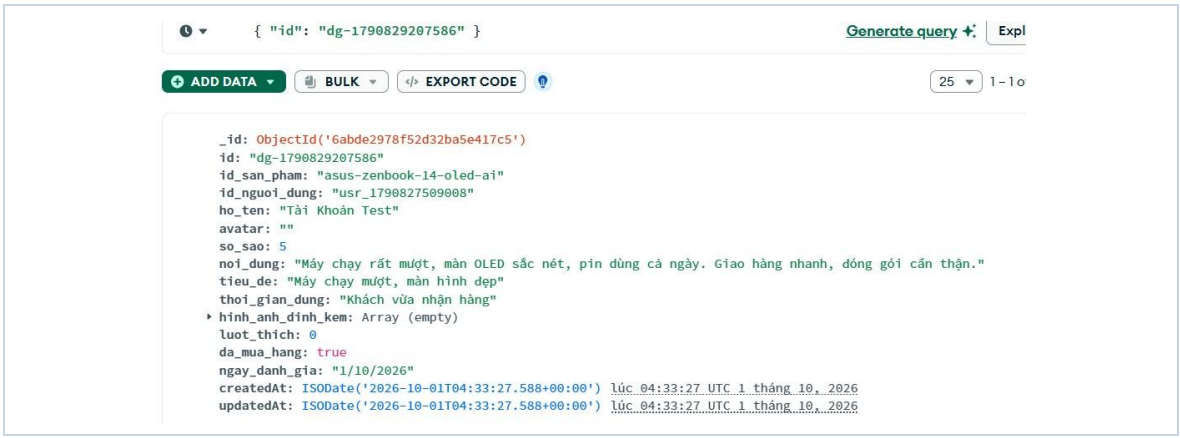

**Hình 4.10. Sau khi hủy đơn: hoàn lại 25 và 114**




**Hình 4.11. Trước khi lưu: voucher ASUSVIP1TR còn 50 lượt**




**Hình 4.12. Sau khi lưu: còn 49 lượt, đã dùng 51%**



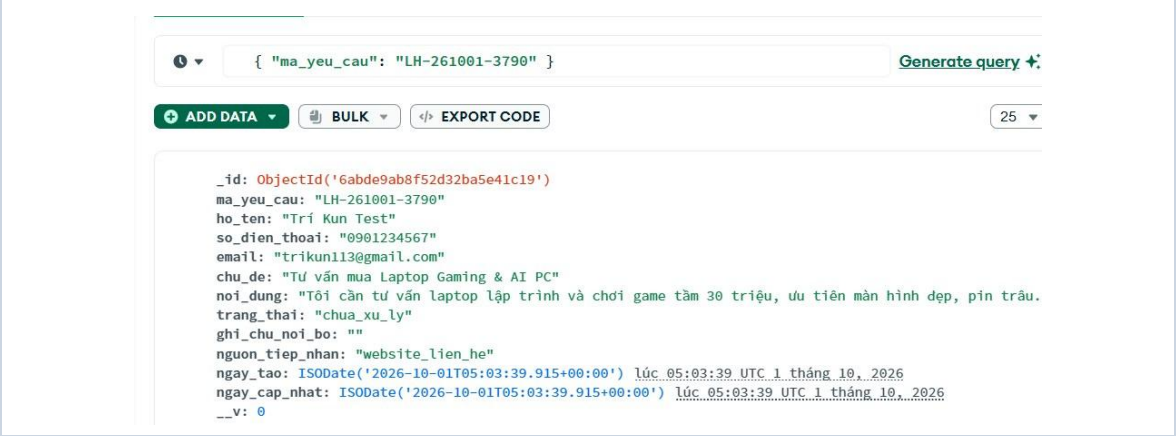

**Hình 4.13. Đánh giá mới (da_mua_hang = true)**




**Hình 4.14. Trước: trangThai = hoat_dong, tokenVersion = 0**



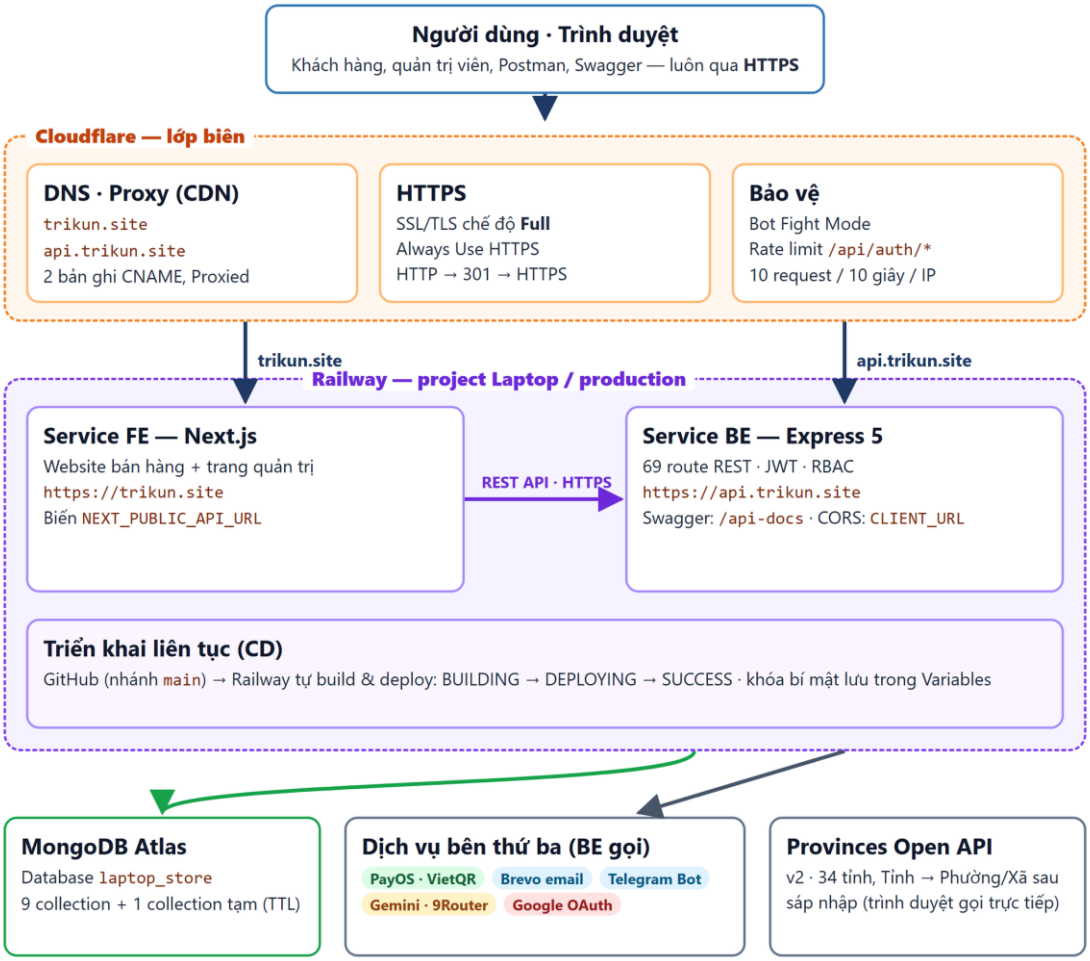

**Hình 4.15. Sau khi Admin khóa: biKhoa = true, tokenVersion = 1**




**Hình 4.16. Phiếu yêu cầu tư vấn mới trong collection lien_he**

## 4.5. Triển khai thực tế trên Internet

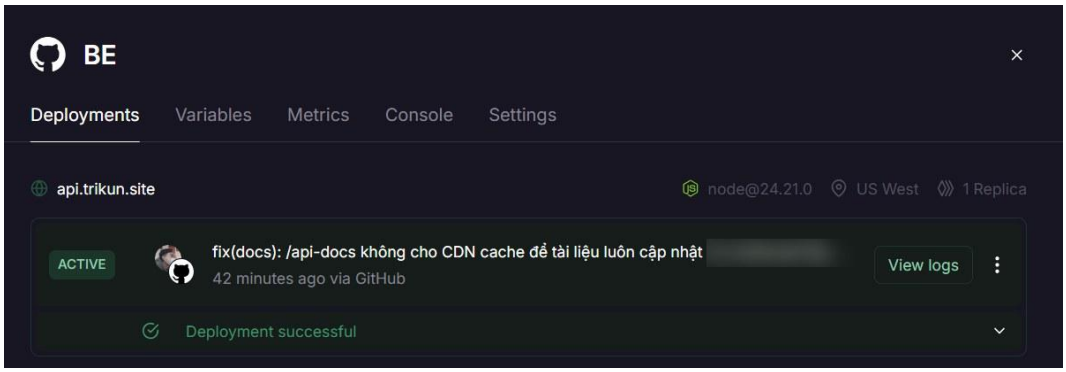
Hệ thống chạy thật với tên miền riêng: website tại **trikun.site**, API tại **api.trikun.site**. Hai ứng dụng chạy trên Railway, tự build và triển khai mỗi khi có mã mới trên nhánh `main` của GitHub; Cloudflare đứng trước làm DNS, HTTPS và lớp bảo vệ (Hình 4.17).



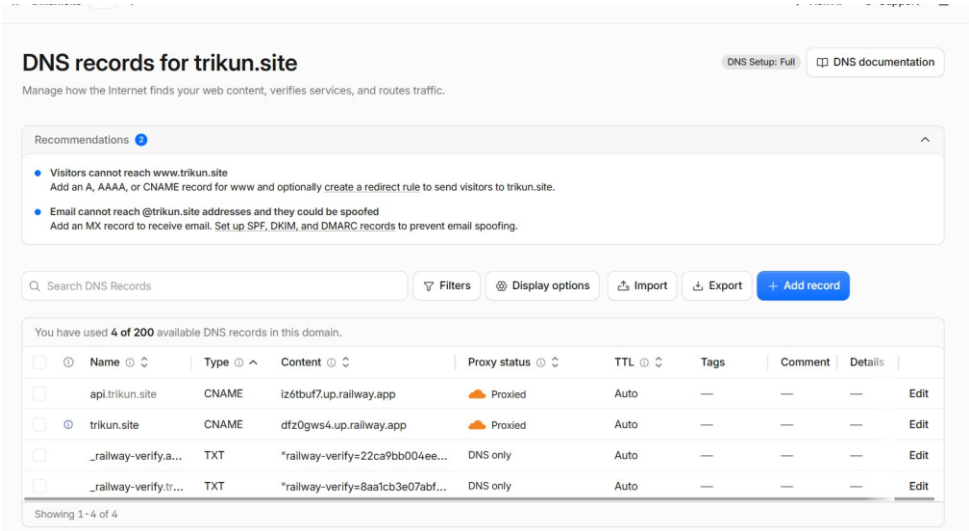

**Hình 4.17. Mô hình triển khai production: Cloudflare, Railway, MongoDB Atlas và dịch vụ ngoài**

**Bảng 4.11. Các lớp trong mô hình triển khai**

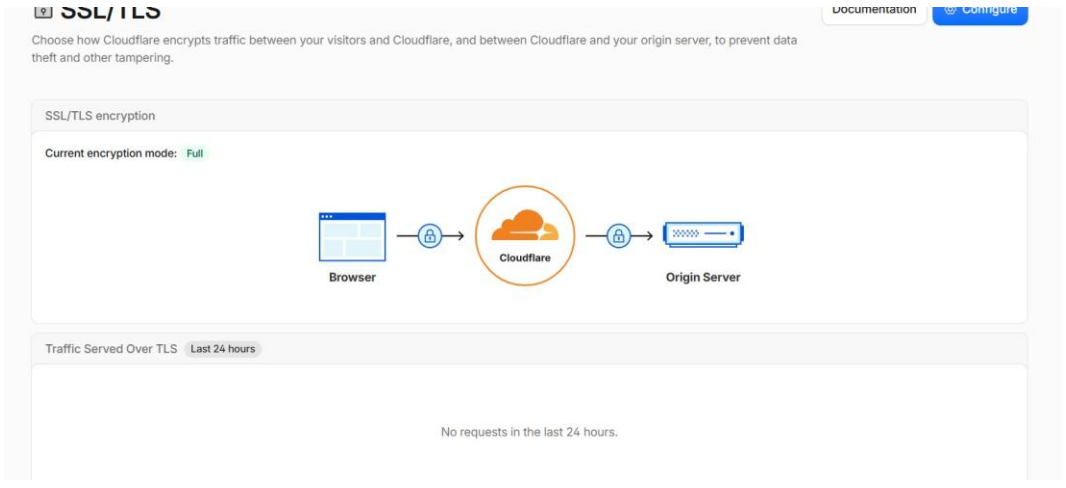
| Thành phần | Vai trò |
|---|---|
| Cloudflare | DNS cho trikun.site, proxy đứng trước Railway, HTTPS chế độ Full, Bot Fight Mode, luật giới hạn tần suất lớp biên |
| Railway: service Front-End | Chạy Next.js, trang web cho khách |
| Railway: service Back-End | Chạy Express 5, kèm tài liệu Swagger; khóa bí mật lưu trong biến môi trường |
| MongoDB Atlas | Database laptop_store, có sao lưu |
| Dịch vụ ngoài | PayOS, Brevo, Telegram, Gemini, Google OAuth, Provinces Open API |



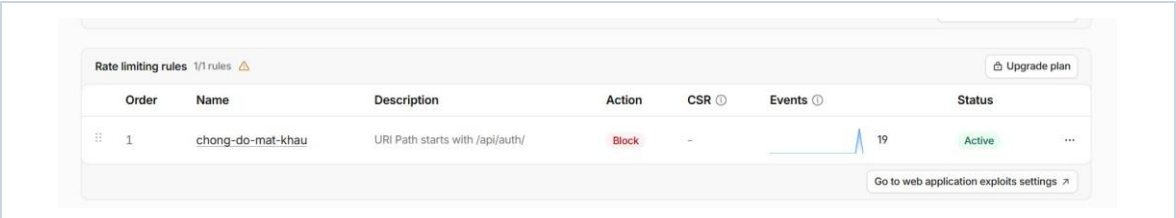

**Hình 4.18. Service Back-End trên Railway: bản triển khai mới nhất đang chạy tốt**




**Hình 4.19. Bản ghi DNS trên Cloudflare: hai CNAME ở chế độ Proxied**




**Hình 4.20. SSL/TLS chế độ Full: mã hóa cả hai chặng**




**Hình 4.21. Luật giới hạn tần suất chong-do-mat-khau cho /api/auth/***

Sau khi triển khai, nhóm kiểm tra trực tiếp trên máy chủ thật: các header bảo mật xuất hiện đầy đủ, API được bảo vệ trả 401 khi chưa đăng nhập, dữ liệu sản phẩm trả bình thường và máy chủ phản hồi mã 200 ở đường kiểm tra sức khỏe.

# CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

## 5.1. Kết luận

Đồ án đã xây dựng được một Back-End hoàn chỉnh cho website bán laptop, **chạy thật trên Internet** và đủ các chức năng của một cửa hàng trực tuyến: từ đăng ký, đặt hàng, thanh toán QR đến quản trị, thông báo và tư vấn bằng AI. Bảng 5.1 tóm tắt những điều đã đạt được.

**Bảng 5.1. Tóm tắt kết quả đồ án**

| Hạng mục | Kết quả |
|---|---|
| Quy mô | 82 route API trong 16 nhóm; 13 collection MongoDB; 61 sản phẩm, 31 đơn hàng thật trong database |
| Chức năng | Tài khoản có OTP và Google, giỏ hàng theo tài khoản, voucher, đặt hàng, thanh toán PayOS / VietQR, bảo hành, liên hệ, Trợ lý AI, Telegram, trang quản trị CRUD, xuất Excel |
| Bảo mật | Chuẩn OWASP API Top 10; tự tìm và vá 21 lỗ hổng; thử 12 kịch bản tấn công đều bị chặn |
| Kiểm thử | 103/103 ca Jest; 40 ca Postman (58/58 bài kiểm tra); CI tự động trên GitHub; 0 lỗ hổng thư viện |
| Triển khai | Chạy tại trikun.site và api.trikun.site; có Swagger; Cloudflare bảo vệ lớp biên |
| Tài liệu | Báo cáo, sơ đồ, bộ Postman và trang tài liệu API tương tác |

Ngoài sản phẩm, nhóm học được nhiều điều: cách chia Back-End thành các lớp rõ ràng; cách dùng MongoDB cho dữ liệu nhiều tầng; cách bảo vệ API bằng JWT, phân quyền và giới hạn tần suất; cách tích hợp dịch vụ ngoài (thanh toán, email, Telegram, AI) một cách an toàn; và quan trọng nhất là **tư duy bảo mật**: luôn hỏi "nếu có người cố tình làm sai thì chuyện gì xảy ra?" rồi tự kiểm thử bằng chính các kịch bản đó.

## 5.2. Hạn chế

- Bộ đếm giới hạn tần suất của Express lưu trong bộ nhớ nên bị xóa khi khởi động lại và chưa dùng chung được khi chạy nhiều máy chủ (đã có thêm lớp giới hạn ở Cloudflare để bù).
- Chưa có xác thực hai lớp (2FA) cho tài khoản Admin, chưa dùng refresh token và chưa ghi nhật ký kiểm toán các thao tác quản trị.
- Thao tác nguyên tử đang áp dụng cho từng bản ghi; tạo đơn nhiều sản phẩm chưa dùng giao dịch (transaction) nhiều bản ghi.
- Trang tra cứu bảo hành là API công khai, hiện đã che số điện thoại nhưng chưa che họ tên; được giảm thiểu bằng khớp chính xác và giới hạn tần suất.
- Danh sách yêu thích và so sánh sản phẩm ở phía khách chủ yếu lưu trong trình duyệt; trạng thái đơn do Admin đổi chưa tự cập nhật cho khách đang mở trang tra cứu.

## 5.3. Hướng phát triển

**Bảng 5.2. Hướng phát triển tiếp theo**

| Hướng | Nội dung dự kiến | Lợi ích |
|---|---|---|
| Bảo mật | Chuyển bộ đếm tần suất sang Redis; thêm 2FA cho Admin, access token ngắn hạn + refresh token; ghi nhật ký kiểm toán | Tăng khả năng chống tấn công và truy vết |
| Chất lượng | Tăng độ phủ kiểm thử; thêm kiểm thử giao diện tự động; kiểm tra tải | Phát hiện lỗi sớm hơn |
| Hiệu năng | Cache bằng Redis, tìm kiếm bằng Atlas Search, phân trang cho mọi danh sách | Nhanh hơn khi dữ liệu lớn |
| Tính năng | Cập nhật trạng thái đơn theo thời gian thực (WebSocket), kết nối đơn vị vận chuyển, gợi ý sản phẩm theo lịch sử xem | Trải nghiệm tốt hơn |
| Vận hành | Đóng gói Docker, giám sát và cảnh báo tự động, sao lưu định kỳ | Ổn định và dễ mở rộng |

# TÀI LIỆU THAM KHẢO

[1] Node.js Documentation — https://nodejs.org/docs

[2] Express 5.x API Reference — https://expressjs.com/en/5x/api.html

[3] MongoDB Manual — https://www.mongodb.com/docs/manual/

[4] Mongoose Documentation — https://mongoosejs.com/docs/

[5] RFC 7519 — JSON Web Token (JWT) — https://datatracker.ietf.org/doc/html/rfc7519

[6] jsonwebtoken (npm) — https://github.com/auth0/node-jsonwebtoken

[7] bcrypt.js — https://github.com/dcodeIO/bcrypt.js

[8] Nodemailer Documentation — https://nodemailer.com/

[9] Brevo API v3 Reference — https://developers.brevo.com/reference

[10] PayOS Developer Documentation — https://payos.vn/docs/

[11] VietQR Quick Link — https://www.vietqr.io/danh-sach-api/link-tao-ma-nhanh/

[12] Telegram Bot API — https://core.telegram.org/bots/api

[13] Google Identity — Verify the Google ID token — https://developers.google.com/identity/gsi/web/guides/verify-google-id-token

[14] Google Gemini API — https://ai.google.dev/gemini-api/docs

[15] OWASP API Security Top 10 — https://owasp.org/API-Security/

[16] MDN Web Docs — HTTP response status codes — https://developer.mozilla.org/en-US/docs/Web/HTTP/Status

[17] OWASP Cheat Sheet Series — https://cheatsheetseries.owasp.org/

[18] MongoDB — Atomicity and Transactions — https://www.mongodb.com/docs/manual/core/write-operations-atomicity/

[19] OpenAPI Specification 3.0 và Swagger UI — https://swagger.io/specification/

[20] Jest và Supertest — https://jestjs.io/ · https://github.com/ladjs/supertest

[21] GitHub Actions — https://docs.github.com/actions

[22] Cloudflare Docs (SSL/TLS, Rate limiting) — https://developers.cloudflare.com/

[23] Railway Docs — https://docs.railway.com/

[24] Provinces Open API v2 — https://provinces.open-api.vn/

# PHỤ LỤC A. DANH SÁCH API ĐẦY ĐỦ

Phụ lục liệt kê 74 chức năng API khác nhau (đã gộp các bí danh). Cột "Quyền": CK = công khai, JWT = cần đăng nhập, Admin = cần quyền quản trị.

**Bảng A.1. API nhóm Xác thực (/api/auth)**

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| POST | /dang-ky | CK | Đăng ký, gửi OTP kích hoạt |
| POST | /kich-hoat | CK | Xác nhận OTP, tạo tài khoản |
| POST | /dang-nhap | CK | Đăng nhập, nhận token |
| POST | /dang-xuat | JWT | Đăng xuất, thu hồi phiên |
| POST | /google | CK | Đăng nhập bằng Google |
| POST | /quen-mat-khau | CK | Gửi OTP quên mật khẩu |
| POST | /gui-otp | CK | Gửi lại OTP |
| POST | /xac-nhan-otp | CK | Kiểm tra OTP |
| POST | /dat-lai-mat-khau | CK | Đặt mật khẩu mới |
| GET | /toi | JWT | Xem hồ sơ của mình |
| PUT | /cap-nhat-ho-so | JWT | Cập nhật hồ sơ, sổ địa chỉ |
| POST | /doi-mat-khau/gui-otp | JWT | Gửi OTP đổi mật khẩu |
| PUT | /doi-mat-khau | JWT | Đổi mật khẩu |

**Bảng A.2. API nhóm Sản phẩm, Danh mục, Tin tức, Showroom**

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| GET | /api/san-pham | CK | Danh sách, tìm kiếm, lọc, sắp xếp |
| GET | /api/san-pham/:id | CK | Chi tiết sản phẩm |
| POST | /api/san-pham | Admin | Thêm sản phẩm |
| PUT | /api/san-pham/:id | Admin | Sửa sản phẩm |
| DELETE | /api/san-pham/:id | Admin | Xóa sản phẩm |
| GET | /api/danh-muc | CK | Danh sách danh mục |
| POST/PUT/DELETE | /api/danh-muc[/:id] | Admin | Thêm, sửa, xóa danh mục |
| GET | /api/tin-tuc[/:id] | CK | Danh sách và chi tiết bài viết |
| POST/PUT/DELETE | /api/tin-tuc[/:id] | Admin | Viết, sửa, xóa bài viết |
| GET | /api/cai-dat/showroom | CK | Danh sách showroom |

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| PUT | /api/cai-dat/showroom | Admin | Lưu showroom |
| GET | /api/cai-dat/khuyen-mai | CK | Cấu hình khuyến mãi |
| PUT | /api/cai-dat/khuyen-mai | Admin | Lưu khuyến mãi |
| POST | /api/cai-dat/showroom/khoi-phuc | Admin | Đã ngừng hỗ trợ (410) |

**Bảng A.3. API nhóm Đơn hàng, Thanh toán, Giỏ hàng, Yêu thích**

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| POST | /api/don-hang | JWT | Tạo đơn (giữ hàng) |
| GET | /api/don-hang | JWT | Đơn của tôi (Admin: tất cả) |
| GET | /api/don-hang/:id | CK* | Tra cứu (cần mã đơn + SĐT) |
| PUT | /api/don-hang/:id | JWT | Cập nhật / hủy đơn |
| DELETE | /api/don-hang/:id | Admin | Xóa đơn, hoàn kho |
| POST | /api/thanh-toan/tao-link | JWT | Tạo QR thanh toán |
| GET | /api/thanh-toan/kiem-tra/:code | CK | Kiểm tra đã thanh toán chưa |
| POST | /api/thanh-toan/webhook | PayOS | Nhận báo tiền về (có chữ ký) |
| GET / PUT | /api/gio-hang | JWT | Đọc / lưu giỏ hàng |
| GET / POST / DELETE | /api/yeu-thich[/:id] | JWT | Quản lý yêu thích |
| GET | /api/dong-bo | CK | Chữ ký dữ liệu để tự đồng bộ |

**Bảng A.4. API nhóm Mã giảm giá, Đánh giá, Bảo hành, Liên hệ, Người dùng, AI**

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| GET | /api/ma-giam-gia | CK | Danh sách voucher |
| POST | /api/ma-giam-gia/kiem-tra | CK | Kiểm tra mã, tính tiền giảm |
| POST | /api/ma-giam-gia/luu-ma | JWT | Lưu mã vào ví |
| GET | /api/ma-giam-gia/vi-cua-toi | JWT | Xem ví voucher |
| POST/PUT/DELETE | /api/ma-giam-gia[/:id] | Admin | Thêm, sửa, xóa voucher |
| GET | /api/danh-gia[/:id] | CK | Xem đánh giá |
| POST | /api/danh-gia | JWT | Gửi đánh giá (đã mua hàng) |
| PATCH | /api/danh-gia/:id/thich | CK | Thích đánh giá |
| GET / PATCH / DELETE | /api/danh-gia/quan-tri… | Admin | Ẩn / hiện / xóa đánh giá |

| Method | Đường dẫn | Quyền | Chức năng |
|---|---|---|---|
| GET | /api/bao-hanh/tra-cuu | CK | Tra cứu bảo hành |
| GET / PATCH | /api/bao-hanh/quan-tri… | Admin | Xem, ghi đè bảo hành |
| POST | /api/lien-he | CK | Gửi phiếu tư vấn |
| GET / PATCH / DELETE | /api/lien-he[/:id] | Admin | Quản lý phiếu |
| GET / POST / PUT / DELETE | /api/nguoi-dung[/:id] | Admin | Quản lý tài khoản |
| POST | /api/tro-ly-ai/chat[/stream] | CK | Chat với Trợ lý AI |
| GET | /api/tro-ly-ai/trang-thai | CK | Trạng thái Trợ lý AI |
| GET | / và /api/health | CK | Kiểm tra máy chủ |